第 5 章 网络安全

本章学习要点：

- 了解网络所面临的安全威胁；
- 掌握防止网络攻击的控制措施；
- 了解防火墙的体系结构、类型、能力和限制，掌握防火墙的基本工作原理；
- 了解入侵检测系统的功能及类型；
- 了解虚拟专用网的类型和协议；
- 了解移动通信网络安全和无线局域网安全。

网络安全从其本质上来讲就是网络上的信息安全，涉及的领域相当广泛，这是因为在目前的公用通信网络中存在着各种各样的安全漏洞和威胁。凡是涉及网络信息的保密性、完整性、可用性、真实性和可控性的相关技术和理论，都是网络安全所要研究的领域。严格地说，网络安全指网络系统的硬件、软件及其系统中的数据受到保护，不受偶然的或者恶意的原因而遭到破坏、更改、泄露，系统连续可靠正常地运行，网络服务不中断。

5.1 网络安全威胁与控制

5.1.1 网络安全威胁

5.1.1.1 威胁分类

网络所面临的安全威胁大体可分为两种：一种是对网络本身的威胁，另一种是对网络中信息的威胁。对网络本身的威胁包括对网络设备和网络软件系统平台的威胁；对网络中信息的威胁除了包括对网络中数据的威胁外，还包括对处理这些数据的信息系统、应用软件的威胁。

这些威胁主要来自人为的无意失误、人为的恶意攻击、网络软件系统的漏洞和“后门”三方面的因素。

(1) 人为的无意失误是造成网络不安全的重要原因。网络管理员在这方面不但肩负重任，还面临越来越大的压力。稍有考虑不周，安全配置不当，就会造成安全漏洞。另外，用户安全意识不强，不按照安全规定操作(如口令选择不慎，将自己的账户随意转借他人或与别人共享)，都会对网络安全带来威胁。

(2) 人为的恶意攻击是目前计算机网络所面临的最大威胁。人为的恶意攻击又可以分为两类：一类是主动攻击，它以各种方式有选择地破坏系统和数据的有效性和完整性；另一类是被动攻击，它是在不影响网络和应用系统正常运行的情况下，进行截获、窃取、破译，以获得重要机密信息。这两种攻击均可对计算机网络造成极大的危害，导致网络瘫痪或机密泄露。

(3) 网络软件系统不可能百分之百无缺陷和无漏洞。许多软件都存在编程人员为了方便而设置的“后门”。这些漏洞和“后门”恰恰是黑客进行攻击的首选目标。

多数安全威胁都具有相同的特征,即威胁的目标都是破坏机密性、完整性或可用性;威胁的对象包括数据、软件和硬件;实施者包括自然现象、偶然事件、无恶意的用户和恶意攻击者。

5.1.1.2 对网络本身的威胁

1. 协议的缺陷

网络协议是网络的基础,协议的缺陷是网络安全威胁的根源之一。互联网联盟为了详细检查所有因特网协议,而将它们公开发布出来。每一种被接受的协议都被分配了一个互联网征求意见稿(Request For Comments,RFC)标准(草案)编号。在协议被接受成为一个标准之前,许多协议中存在的问题就已经被那些敏锐的检查者发现并得到了校正。

但是,协议的定义是由人制定和审核的,协议本身可能是不完整的,也难免存在某些缺陷。某些网络协议的实现是很多安全缺陷的源头,攻击者可以利用这些错误,特别是下述软件的故障:网络管理(SNMP),寻址服务(DNS)和电子邮件(E-mail)服务(如 SMTP 和 S/MIME)。虽然不同的厂商会编写实现他们自己服务的代码,但他们常常基于通用(有缺陷)的原型。这样,在 Windows 上成功的交互,有可能在 UNIX 上失效。例如,针对 SNMP 缺陷(漏洞代码:107186),CERT 报告列出了建议使用的近 200 套不同的实现方案。

2. 网站漏洞

因为网络几乎完全暴露在用户面前,所以非常脆弱。如果用户使用应用程序,不会获取并查看程序代码。对于网站来说,攻击者能下载网站代码,再离线长时间研究。对于程序而言,几乎不能控制使用哪种顺序访问程序的不同部分,但是,网站攻击者可以控制以哪种顺序访问网页,甚至直接访问网页 5,而不按 1～4 的顺序访问。攻击者也能选择提供哪种数据,以及用不同的数据进行实验,以测试网站的反应。简而言之,攻击者在挑战控制权方面具有优势。

(1) 网站被“黑”。一种最广为人知的攻击方式是网站被“黑”式攻击。这不仅因为其结果是可见的,而且实施起来也比较容易。由于网站的设计使得代码可以下载,这就允许攻击者能够获取全部超文本文档和在加载进程中与客户相关的所有程序。攻击者甚至可以看到编程者在创建或维护代码时遗留下来的注解。下载进程实质上为攻击者提供了一份该网站的规划图。

(2) 缓冲区溢出。网页也存在缓冲区溢出问题。攻击者向一个程序中输入大量数据,比预期所要接收的数据多得多。由于缓冲区的大小是有限的,所以过剩的数据就会溢出到相邻的代码和数据区域中去。

知名的网页服务器缓冲区溢出之一是被称为 iishack 的文件名问题。这种攻击方式被写进了一个程序中(参见 http://www.technotronic.com),只需提供要攻击的站点和攻击者想要服务器执行的程序的 URL 作为参数,攻击者就可以执行该程序实施攻击。

其他网页服务器对于极长的参数字段也很容易发生缓冲区溢出错误。比如,长度为 10 000 的口令或者填充大量空格或空字符的长 URL。

(3) “../”问题。网页服务器代码应该一直在一个受到限制的环境中运行。在理想情况下,网页服务器上应该没有编辑器、xterm 和 Telnet 程序,甚至连绝大多数系统应用程序都不应该安装。通过这种方式限制了网页服务器的运行环境以后,即使攻击者从网页服务器的应用程序区跳到了别处,也没有其他可执行程序可以帮助攻击者使用网页服务器所在的计算机

和操作系统来扩大攻击的范围。用于网页应用程序的代码和数据可以采用手工方式传送到网页服务器。但是，相当多的应用软件程序员却喜欢在存放网页应用程序的地方编辑它，因此，他们认为有必要保留编辑器和系统应用程序，为他们提供一个完整的开发环境。

第二种阻止攻击的方法是创建一个界地址来限制网页服务器应用程序的执行区域。有了这样一个界地址，服务器应用程序就不能从它的工作区域中跳出来访问其他具有潜在危险的系统区域（如编辑器和系统应用程序）了。服务器把一个特定的子目录作为根目录，服务器需要的所有东西都放在以此根目录开始的同一个子目录中。

无论是在 UNIX 还是在 Windows 操作系统中，".."都代表某一个目录的父目录。以此类推，"../.."就是当前位置的祖父目录。因此，每输入一次".."就可以进入目录树的上一层目录。Cerberus Information Security 的分析家们发现微软索引服务器的扩展文件 webhits.dll 中就存在这个漏洞。例如，传递一个如下的 URL 会导致服务器返回请求的 autoexec.nt 文件，从而允许攻击者修改或者删除它：

```
http://yoursite.com/webhits.htw?ciwebhits&file=../../../../../winnt/
system32/autoexec.nt
```

（4）应用代码错误。用户的浏览器与网页服务器之间传递着一种复杂且无状态的协议交换。网页服务器为了使自己的工作更轻松一些，会向用户传递一些上下文字符串，而要求用户浏览器用全部上下文进行应答。一旦用户可以修改这种上下文内容，就会出现问题。

下面用一个假想的 CD 销售站点 CDs-R-Us 来说明这个问题。在某一个特定时刻，该站点的服务器可能有一千甚至更多个交易正处于不同的状态。该站点显示了供订购的货物清单网页，用户选择其中的一种货物，站点会显示出更多的货物，用户又选择其中的几种，如此进行下去，直到用户结束选择为止。然后，很多人会通过指定付账和填入邮购信息继续完成这份订单，但也有一些人将该网站作为在线目录或者指南，而没有实际订购货物的意图。比如利用该站点来查询 CD 的价格，即使用户确实有购物的诚意，有时也会由于网页连接失败而留下一个不完整的交易。正是考虑到这些因素，网页服务器常常通过一些紧跟在 URL 之后的参数字段来跟踪一个还没有完成的订单的当前状态。随着每个用户的选择或者页面请求操作，这些字段从服务器传递到浏览器，然后又返回给服务器。

假设你已经选择了一张 CD，正在查看第二个网页。网页服务器已经传递给你一个与此类似的 URL：

```
http://www.CDs-r-us.com/buy.asp?i1=459012&p1=1599
```

该 URL 意味着你已经选择了一张编号为 459012 的 CD，单价是 15.99 美元。现在，你选择了第二张 CD，而 URL 变成了：

```
http://www.CDs-r-us.com/buy. asp? i1=459012&p1=1599&i2=365217&p2=1499
```

如果你是一位高明的攻击者，就会知道在用户浏览器的地址窗口中的 URL 是可以编辑的。结果，将其中的 1599 和 1499 都改成了 199。这样，当服务器汇总你的订单时，两张 CD 的单价都只有 1.99 美元了。

在第一次需要显示价格的时候，服务器会设置（检查）每一项物品的价格。但后来，被检查过的数据项失去了控制，而没有对它们进行复核。这种情况经常出现在服务器应用程序代码

中，因为应用程序编程人员常常没有意识到其中存在的安全问题，以至于常常对一些恶意的举动没有预见性。

(5) 服务器端包含。一种具有代表性的更严重问题是服务器端包含(Server-Side Include，SSI)问题。该问题利用了一个事实：网页中可以自动调用一个特定的函数。例如，很多页面的最后都显示了一个“请与我联系”链接，并使用一些 Web 命令来发送电子邮件消息。这些命令(如 E-mail、if、goto 和 include 等)都被置于某一个区域，以便转换成 HTML 语言。

其中一种服务器端包含命令称为 exec，用于执行任意一个存放于服务器上的文件。例如，以下服务器端包含命令：

```
<!-#exec cmd="/usr/bin/telnet &"->
```

会以服务器的名义(也就是说，具有服务器的特权)打开一个在服务器上运行的 Telnet 会话。攻击者会对执行像 chmod(改变一个对象的访问权限)、sh(建立一个命令行解释器)或 cat(复制到一个文件)这样的命令很感兴趣。

3. 拒绝服务

可用性攻击，有时被称为拒绝服务攻击或 DoS 攻击，在网络中比在其他的环境中更加值得重视。可用性或持续服务面临着很多意外或恶意的威胁。

(1) 传输故障。有很多原因会导致通信故障。比如：电话线被切断；网络噪声使得一个数据包不能被识别或不能被投递；传输路径上的一台设备出现软件或硬件故障；一台设备因维修或测试而停止服务；某台设备被太多任务所淹没，从而拒绝接收其他输入数据，直到所有过载数据被清除为止。在一个主干网络(包括因特网)中，其中的许多问题都是临时出现或能够自动恢复(通过绕道的方式)的。

然而，一些故障却很难修复。比如，连接到你使用的计算机的唯一一根通信线路(例如，从网络到你的网卡或者连到你的 Modem 上的电话线)被折断了，就只能通过另外接一根线或修理那根被损坏的线来进行恢复。网络管理员会说“这对网络的其他部分不会造成影响”，但对你而言，这句话起不到任何作用。

站在一个恶意的立场来看，所有可以切断线路、干扰网络或能使网络过载的人都可以造成你得不到服务。来自物理上的威胁是相当明显的。

(2) 连接洪泛。最早出现的拒绝服务攻击方式是使连接出现泛滥。如果一名攻击者给你发送了太多数据，以至于你的通信系统疲于应付，这样，就没空接收任何其他数据了。即使偶尔有一两个来自其他人的数据包被你收到，你们之间的通信质量也会出现严重降级。

一些更为狡猾的攻击方式使用了互联网协议中的元素。除了 TCP 和 UDP 协议以外，互联网协议中还有一类协议，被称为网际控制报文协议(Internet Control Message Protocol，ICMP)，通常用于系统诊断。这些协议与用户应用软件没有联系。ICMP 协议内容如下。

- Ping：用于要求某个目标返回一个应答，目的是看目标系统是否可以到达，以及是否运转正常。
- Echo：用于请求一个目标将发送给它的数据发送回来，目的是看连接链路是否可靠(Ping 实际上是 Echo 的一个特殊应用)。
- Destination Unreachable：用于指出一个目标地址不能被访问。
- Source Quench：意味着目标即将达到处理极限，数据包的发送端应该在一段时间内暂

停发送数据包。

这些协议对于网络管理有重要的作用。但是，它们也可能用于对系统的攻击。由于这些协议都是在网络堆栈中进行处理的，因而在接收主机端检测或阻塞这种攻击是很困难的。下面介绍怎样发动该类型的攻击。

① 响应索取。这种攻击发生在两台主机之间。chargen 是一个用于产生一串数据包的协议，常常用于测试网络的容量。攻击者在主机 A 上建立起一个 chargen 进程，以产生一串包，作为对目标主机 B 的响应包。然后，主机 A 生成一串包发送给主机 B，主机 B 通过响应它们，返回这些包给主机 A。这一系列活动使得网络中包含主机 A 和主机 B 部分的基础设施进入一种无限循环状态。更有甚者，攻击者在发送第一个包的时候，将它的目标地址和源地址都设置成主机 B 的地址，这样，主机 B 就会陷入一个循环之中，不断地对它自己发出的消息做出应答。

② 死亡之 Ping。死亡之 Ping(Ping of death)是一种简单的攻击方式。因为 Ping 要求接收者对 Ping 请求做出响应，故攻击者所要做的事情就是不断地向攻击目标发送大量的 Ping，以淹没攻击目标。然而，这种攻击要受攻击路径上最小带宽的限制。如果攻击者使用的是 10 Mb/s 带宽的连接，而被攻击目标的路径带宽为 100 Mb/s 甚至更高，那么，单凭攻击者自身是不足以淹没攻击目标的。但是，如果将这两个数字对换一下，即攻击者使用 100 Mb/s 的连接，而被攻击目标的路径带宽为 10 Mb/s，则攻击者可以轻易地淹没攻击目标。这些 Ping 包将会把攻击目标的带宽堵塞得满满当当。

③ Smurf 攻击。Smurf 攻击是 Ping 攻击的一个变体。它采用与 Ping 攻击方式相同的载体——Ping 包，但使用了另外两种手法。首先，攻击者需要选择不知情的受害者所在的网络。攻击者假造受害者的主机地址作为 Ping 包中的源地址，以使 Ping 包看起来像是从受害者主机发出来的一样。然后，攻击者以广播模式(通过将目标地址的最后一字节全部设置为 1)向网络发送该请求，这些广播包就会发布给网络上的所有主机，如图 5.1 所示。

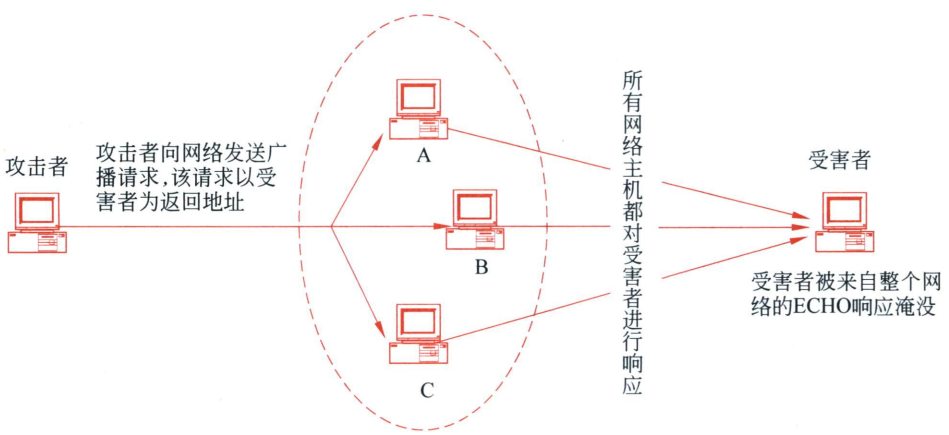


图 5.1 Smurf 攻击

④ 同步洪泛。同步洪泛(SYN flood)是另一种流行的拒绝服务攻击。这种攻击利用了 TCP 协议组，使用这些面向会话的协议来实施攻击。

对于一个协议(如 Telnet)，在协议的对等层次之间将建立一个虚拟连接，称为一个会话(session)，以便对 Telnet 终端模仿自然语言中来来回回、有问有答的交互过程进行同步。三次 TCP 握手建立一个会话。每个 TCP 包都有一些标记位，其中有两个标记位表示同步

(SYN)和应答(ACK)。在开始一次 TCP 连接时,连接发起者会发送一个设置了 SYN 标记的包。如果接收方准备建立一个连接,就会用一个设置了 SYN 和 ACK 标记的包进行应答。然后,发起方发送一个设置了 ACK 标记的包给接收方,这样就完成了建立一个清晰完整的通信通道的交换过程,如图 5.2 所示。

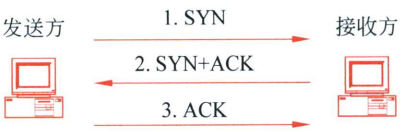


图 5.2 三次连接握手

包在传输过程中偶尔会出现丢失或者损坏的情况。因此,在接收端维持着一个称为 SYN_RECV 连接的队列,用于跟踪已经发送了 SYN-ACK 信号但还没有收到 ACK 信号的项。在正常情况下,这些工作在一段很短的时间内就会完成。但如果 SYN+ACK 或 ACK 包丢失,最终目标主机会由于这个不完整的连接超时而将它从等待队列中丢掉。

攻击者可以通过发送很多 SYN 请求而不以 ACK 响应,从而填满对方的 SYN_RECV 队列来对目标进行拒绝服务攻击。通常 SYN_RECV 队列相当小,只能容纳 10 个或者 20 个表项。由于在互联网中存在潜在的传输延迟,通常在 SYN_RECV 队列中保留数据的时间最多可达几分钟。因此,攻击者只需要每隔几秒钟发送一个新的 SYN 请求,就可以填满该队列。

攻击者在使用这种方法的时候,通常还要做一件事情:在初始化 SYN 包中使用一个不存在的返回地址来欺骗对方。这样做有两个原因:第一,攻击者不希望泄露真实的源地址,以免被通过检查 SYN_RECV 队列中的包而试图识别攻击者的人认出来;第二,攻击者想要使这些伪造的 SYN 包与用于建立真实连接的合法 SYN 包没有区别。为每个包选择一个不同的(骗人的)源地址,以使它们是唯一的。一个 SYN+ACK 包发往一个不存在的地址会导致网络发出一个“目标不可达”的 ICMP 报文,但这不是 TCP 所期待的 ACK 信号。TCP 和 ICMP 是不同的协议组,因此,一个 ICMP 应答不需要返回到发送者的 TCP 处理部分。

⑤ Teardrop 攻击。Teardrop 攻击滥用了被设计用来改善网络通信的特性。一个网络 IP 数据报是一个变长的对象。为了支持不同的应用和不同的情况,数据报协议允许将单个数据单元分片,即分成小段数据,分别发送。每个分片可表明其长度和在数据单元中的相对位置。接收端负责重新将分片组装成单个数据单元。

在 Teardrop 攻击中,攻击者发送一系列数据报,这些数据报不能被正确组装在一起。一个数据报表明它的位置在长度为 60 字节的数据单元的位置 0 处。另一个表明它在 90 字节的数据单元的位置 30 处,还有一个表明它在 173 字节的数据单元位置 41 处。这三个分片是重叠的,所以,其不能正确重组。在极端情况下,操作系统将把不能重组的数据单元部分锁住,而导致拒绝服务。

(3) 流量重定向。路由器工作在网络层,是一种在源主机所在网络与目标主机所在网络之间,通过一些中间网络来向前传递消息的设备。因此,如果攻击者可以破坏寻址,路由器就不能正确传递消息。

路由器使用复杂的算法来决定如何进行路径选择。不管采用何种算法,从本质上说都是为了寻找一条最好的路径(在这里,“最好”是通过一些综合指标来进行衡量的,如距离、时间、费用和质量等)。每个路由器只知道与它共享相同网络连接的路由器,路由器之间使用网关协议来共享一些信息,这些信息是关于彼此之间的通信能力的。每个路由器都要向它的相邻路由器通告它自己到达其他网络的路径情况。这个特点可以被攻击者用来破坏网络。

说到底,路由器都只是一台带有两块或者更多网卡的计算机。假设一台路由器向它的所有相邻路由器报告:它到整个网络的每一个其他地址都有最好的路径。很快,所有相邻路由

器都会将所有通信传递到该路由器。这样，这台路由器就会被大量通信所淹没，或者只能将大多数通信一丢了之。无论出现哪一种情况，都会造成大量通信永远不能到达预期的目标。

(4) DNS攻击。最后一种拒绝服务攻击是一类基于域名服务器(Domain Name Server，DNS)的攻击。DNS是一张表，用于将域名(如ATT.COM)转换成对应的网络地址(如211.217.74.130)，这个过程称为域名解析。域名服务器在遇到它不知道的域名时，通过向其他域名服务器提出询问来进行解析。出于效率的考虑，它会将收到的域名解析应答进行缓存，以便将来在解析该域名的时候能够更快一些。

在绝大多数采用UNIX实现域名服务的系统中，域名服务器运行的软件称为BIND(Berkeley Internet Name Domain)或Named(name daemon的简写)。在BIND中存在着大量缺陷，包括现在大家熟悉的缓冲区溢出缺陷。

通过接管一个域名服务器或者使其存储一些伪造的表项(称为DNS缓存中毒)，攻击者可以对任何通信进行重定向，从而造成拒绝服务。

在2002年10月，大量洪泛流量淹没了顶级域名DNS服务器，这些服务器构成了互联网寻址的基石。大约一半的流量仅来自200个地址。虽然人们认为这些问题是防火墙的误配置，但没有人确知是什么引起了攻击。

在2005年3月，一次攻击利用了Symantec防火墙的漏洞，该漏洞允许修改Windows系统中的DNS记录。但这次攻击的目的不是拒绝服务。在这次攻击中，“中招”的DNS缓存将用户重定向到了广告网站，这些广告网站在每次用户访问网站时进行收费。同时，这次攻击也阻止用户访问合法网站。

4. 分布式拒绝服务(DDoS)

上面所列举的拒绝服务攻击本身就已经非常具有威力了，但是，攻击者还可以采取一种两阶段的攻击方式，攻击效果可以扩大很多倍。这种乘数效应为分布式拒绝服务攻击提供了巨大威力。攻击者发起DDoS攻击的第一步是在Internet上寻找有漏洞的主机并试图侵入，入侵成功后在其中安装后门或木马程序；第二步是在入侵各主机上安装攻击程序，由程序功能确定其扮演的不同角色；最后由各部分主机各司其职，在攻击者的调遣下对目标主机发起攻击，制造数以百万计的数据分组流入欲攻击的目标，致使目标主机或网络极度拥塞，从而造成目标系统的瘫痪。

与DoS一次只能运行一种攻击方式攻击一个目标不同，DDoS可以同时运用多种DoS攻击方式，也可以同时攻击多个目标。攻击者利用成百上千个被“控制”节点向受害节点发动大规模的协同攻击。通过消耗带宽、CPU和内存等资源，造成被攻击者性能下降，甚至瘫痪和死机，从而造成合法用户无法正常访问。与DoS相比，其破坏性和危害程度更大，涉及范围更广，更难发现攻击者。DDoS的攻击原理如图5.3所示。

(1) 攻击者。攻击者可以是网络上的任何一台主机。在整个攻击过程中，它是攻击主控台，向主控机发送攻击命令，包括被攻击者主机地址，控制整个攻击过程。攻击者与主控机的通信一般不包括在DDoS工具中，可以通过多种连接方法完成，最常用的是Telnet TCP终端会话，还可以是绑定到TCP端口的远程Shell、基于UDP的客户/服务器远程Shell等。

(2) 主控机。主控机和代理主机都是攻击者非法侵入并控制的一些主机，它们分成了两个层次，分别运行非法植入的不同的攻击程序。每个主控机控制一部分代理主机，主控机有其控制的代理主机的地址列表，它监听端口接收攻击者发来的命令后，将命令转发给代理主机。主控机与代理主机的通信根据DDoS工具的不同而有所不同。例如，Trinoo使用UDP协议，

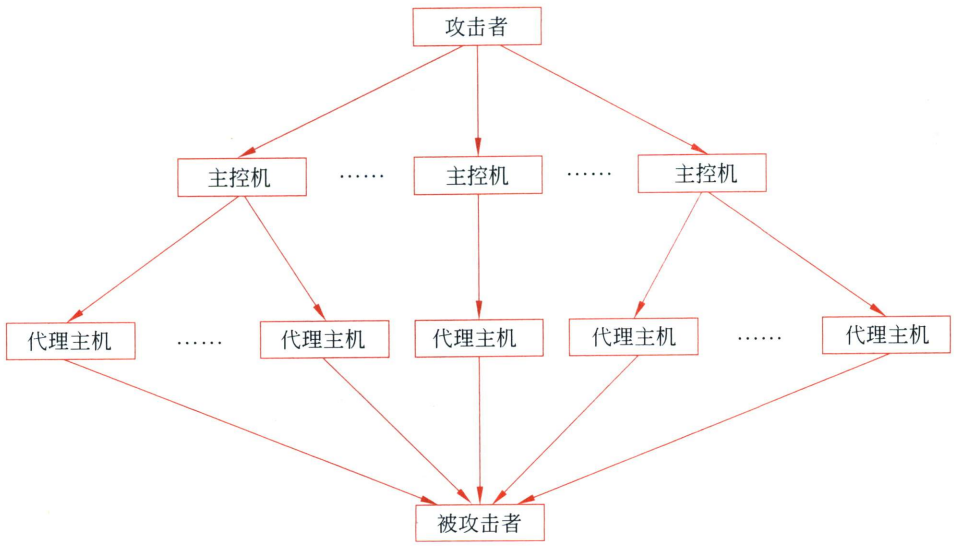


图 5.3 分布式拒绝服务攻击原理图

TFN 使用 ICMP 协议，Stacheldraht 使用 TCP 和 ICMP 协议。

(3) 代理主机。代理主机运行攻击程序，监听端口接收和运行主控机发来的命令，是真正进行攻击的机器。

(4) 被攻击者。被攻击者可以是路由器、交换机、主机等。遭受攻击时，它们的资源或带宽被耗尽。防火墙、路由器的阻塞还可能导致恶性循环，加重网络拥塞情况。

除了巨大的乘数效应以外，也很容易通过脚本来实施分布式拒绝服务攻击，这也是一个严重的问题。只要给出了一套拒绝服务攻击方式和一种特洛伊木马繁殖方式，人们就可以很容易地写出一个程序来植入特洛伊木马，该特洛伊木马就可以用任何一种或所有的拒绝服务攻击方法实施攻击。DDoS 攻击工具最早出现于 1999 年，包括 TFN(Tribal Flood Network)、Trinoo 及 TFN2K(Tribal Flood Network，Year 2000 Edition)。随着一些新弱点的发现，特洛伊木马的植入方式也随之发生了一些改变，而且，随着一些新的拒绝服务攻击方式被发现，也相应出现了一些新的组合工具。

5. 来自活动或移动代码的威胁

活动代码(active code)或移动代码(mobile code)是对被“推入”客户端执行的代码的统称。网页服务器为什么要浪费宝贵的资源和带宽去做那些客户工作站能做的简单工作呢？假设想让你的网站上出现一些熊跳着舞跨过页面顶部的画面。为了下载这些正在跳舞的熊，你可能会在这些熊每一次运动的时候下载一幅新图像：向前移动一点，再向前移动一点，如此继续下去。然而，这种方法占用了服务器太多的时间和带宽，因为需要服务器来计算这些熊的位置并下载很多新的图像。一种更有效利用(服务器)资源的方式是直接下载一个实现熊运动的程序，让它在客户计算机上运行即可。

下面将介绍不同种类活动代码的相关潜在弱点。

(1) Cookie。严格来说，Cookie 不是活动代码，而是一些数据文件，远程服务器能够存入或获取 Cookie。然而，由于 Cookie 的使用可能造成从一个客户到服务器的不期望的数据传送，所以它的一个缺点就是失去了机密性。

Cookie 是一个数据对象，可以存放在内存中(一次会话 Cookie)，也可以为将来使用而存

储在磁盘上(持久 Cookie)。Cookie 可以存储浏览器允许的与客户相关的任何内容，如用户按键、机器名称、连接详细内容(比如 IP 地址)、日期和类型等。在服务器命令控制下，浏览器将 Cookie 的内容发送给服务器。一次会话 Cookie 在关闭浏览器的时候被删除，而持久 Cookie 却可以保留一段预先设定的日期，可能几天甚至是未来的几年时间。

Cookie 为服务器提供了一个上下文。通过使用 Cookie，某些主页可以使用“欢迎回来，James Bond”这样的欢迎词来对用户表示欢迎，或者反映出用户的一些选择，比如“我们将把该订单上的货物邮寄到××大街××号，对吗?”但是，任何人只要拥有了某人的 Cookie，他在某些情形中就代表着这个人。这样，任何人只要窃听或获得了一个 Cookie，就可以冒充该 Cookie 的所有者。

Cookie 中究竟包含着关于用户的哪些信息呢? 尽管这些都是用户的信息，但通常用户不会知道 Cookie 里边到底是些什么内容，因为 Cookie 的内容使用一个来自服务器的密钥进行了加密。

因此，Cookie 会占用用户的磁盘空间，保存着一些用户不能看到但与用户相关的信息，能传递给服务器但用户不知道服务器什么时候想要它，服务器也不会通知用户。

(2) 脚本。客户可以通过执行服务器上的脚本来请求服务。通常情况是，网页浏览器显示一个页面，当用户通过浏览器与网站进行交互时，浏览器把用户输入的内容转化成一个预先定义好的脚本中需要的参数；然后，它发送这个脚本和参数给服务器执行。但是，所有通信都是通过 HTML 来进行的，服务器不能区分这些命令到底是来自一个浏览器上的用户完成一个主页后提交的，还是一个用户用手工写出来的。一些怀有恶意的用户可能会监视一个浏览器与服务器之间的通信，观察怎样改变一个网页条目可以影响浏览器发送的内容，以及其后服务器会做出何种反应。具备了这些知识，怀有恶意的用户就可以操纵服务器的活动。

这种操纵活动是十分容易的。程序员们通常不能预见到恶意的举动；通常程序员们认为用户都是合法的，会按照程序预先设定的操作规程来使用一个程序。正是由于这个原因，程序员们常常忽略过滤脚本参数，以保证用户的操作是合理的，而且执行起来也是安全的。一些脚本允许包含到任何文件中，或者允许执行任何命令。攻击者可以在一个字符串中看到这些文件或命令，并通过改变它们来做一些实验。

一种大家都很熟悉的针对网页服务器的攻击方式是 Escape 字符(Escape-Character)攻击。一种常用于网页服务器的脚本语言——公共网关接口(Common Gateway Interface，CGI)，定义了一种不依赖于具体机器的方法来对通信数据编码。按照编码惯例，使用“%nn”来代表特殊的 ASCII 字符。例如，“%0A”(行结束)指示解释器将紧接着的一些字符当作一个新的命令。下面的命令是请求复制服务器的口令文件：

```
http: //www. test.com/cgi-bin/query? %0a/bin/cat%20/etc/passwd
```

CGI 脚本也可以直接在服务器上启动一个动作。例如，如果攻击者观察到一个 CGI 脚本中包含着如下格式的一个字符串：

```
<! - -#action argl=value arg2=value -->
```

攻击者用以下字符串替代上述字符串后，就提交一个命令：

```
<! --#exec cmd="rm * "-->
```

这就会引起命令行解释器执行一个命令删除当前目录下的所有文件。

微软的动态服务器页面(Active Server Page,ASP)也具有像脚本一样的能力。这些页面指导浏览器怎样显示文件、维护上下文及与服务器交互。它们在浏览器端也可以被看到,所以任何存在于 ASP 代码中的编程漏洞都可用于侦察和攻击。

服务器永远不应相信来自客户端的任何东西,因为远程用户可以向服务器发送手工写出来的字符串,替换由服务器发送给客户端的善意的程序。正是由于有如此多的远程访问方式,所有这些例子证明了这样一点:如果用户允许其他人在其机器上运行程序,那这台机器就不会有绝对的安全保障。

(3) 活动代码。通过以下几个步骤就可以开始显示主页:产生文本,插入图像,并通过鼠标单击来获取新页。很快,人们就在他们的站点上使用了一些精心设计的内容:蹒跚学步的孩子在页面上跳舞、三维旋转的立方、图像时隐时现、颜色不断改变,以及显示总数等。其中,特别是涉及运动的小技巧显然会占用重要的计算能力,还需要花大量时间和通信从服务器上把它们下载到客户端。然而,通常情况下,客户自身有一个有能力却没有被充分利用的处理器,因此,无须担心活动代码占用客户端计算时间的问题。

为了充分利用处理器的能力,服务器可以下载一些代码到客户端去执行。这些可执行代码被称为活动代码。两种主要的活动代码是 Java 代码(Java code)和 Activex 控件(Activex control)。

① **Java 代码**。恶意的 Applet(Hostile Applet)是一种可以下载的 Java 代码,会对客户系统造成损害。由于 Applet 在下载以后失去了安全保护,而且通常以调用它的用户的权限运行,因此恶意的 Applet 会造成严重破坏。安全执行 Applet 的必要条件包括如下几个方面。

- 系统必须控制 Applet 对重要系统资源的访问,如文件系统、处理器、网络、用户显示和内部状态变量等。
- 编程语言必须通过阻止伪造内存指针和数组(缓冲区)溢出来保护内存。
- 在创建新对象的时候,系统必须通过清除内存内容来阻止对象的重用;在不再使用某些变量的时候,系统应该使用垃圾回收机制来收回所占用的内存。
- 系统必须控制 Applet 之间的通信,以及控制 Applet 通过系统调用对 Java 系统外的环境产生的影响。

② **Activex 控件**。微软公司针对 Java 技术的应对措施是 ActiveX 控制。使用 ActiveX 控件以后,任何类型的对象都可以下载到客户端。如果该客户有一个针对这种对象类型的阅读器或处理程序,就可以调用该阅读器来显示这个对象。例如,下载一个微软 Word 的.docx 文件就会调用系统上安装的 Word 程序来显示该文件。对于那些客户端没有相应处理程序的文件将会导致下载更多的其他代码。正是由于这个特点,从理论上来说,攻击者可以发明一种新的文件类型,如.bomb 的类型,就会导致那些毫无戒心的用户在下载一个包含.bomb 文件的主页时,也随同下载了可以执行.bomb 类型文件的代码。

为了阻止任意下载文件,微软公司使用了一种鉴别方案,在这种鉴别方案下,下载的代码是有密码标记的,而且在执行之前需要验证签名。但是,鉴别验证的仅仅是源代码,而不是它们的正确性或安全性。来自微软公司(Netscape 或任何其他生产商)的代码并不是绝对安全的,具有未知来源的代码可能会更安全,但也可能更不安全。事实证明,不论代码来自何处,用户都不能假设它到底有多好或者有多安全。况且,有些弱点还可以允许 ActiveX 绕过这种鉴别。

（4）根据类型自动执行。数据文件是通过程序进行处理的。对于某些产品而言，文件类型是通过文件的扩展名来表示的。比如，扩展名为.docx 的文件是一个 Word 文档，扩展名为.pdf的文件是一个 Adobe Acrobat 文件，而以.exe 为扩展名的文件是一个可执行文件。在许多系统中，当一个具有某种扩展名的文件到达时，操作系统会自动调用相应的处理程序来处理它。

把一个 Word 文档本身当作一个可执行文件是让人难以理解的。为了阻止人们通过输入名字作为命令来运行.docx 文件，微软在文件中内置了它的真实类型。只需要在 Windows 文件浏览器窗口中双击该文件，就可以激活相应的程序来处理这个文件。

但是，这种方案也为攻击者提供了一个机会。一名怀有恶意的代理可能会给用户发送一个名为 innocuous.docx 的文件，使用户以为它是一个 Word 文档。由于它的扩展名是.docx，因此 Word 会试图打开它。假设该文件被重命名为 innocuous（没有扩展名.docx），但如果内置的文件类型是.docx，那么双击 innocuous 也会激活 Word 程序打开该文件。这个文件中可能包含着一些不怀好意的宏命令，或者通过请求打开另一个更危险的文件。

在通常情况下，可执行文件是危险的，而文本文件相对比较安全，一些带有活动内容的文件（如.docx 文件）介乎两者之间。如果一个文件没有明显的文件类型，将会使用它内置的文件处理程序来打开，此时，会使计算机陷入危险的境地。攻击者常常使用没有明显文件类型的方法来隐藏恶意的活动文件。

（5）蠕虫。蠕虫（Bot）是黑客机器人，是在远程控制的一段有恶意的代码。这些目标代码是分布在大量受害者主机的特洛伊木马。如果忽略它们消耗的计算机资源和网络资源，由于不干扰或损害用户的计算机，因而通常不易被察觉。

通过常用的网络，如在线聊天系统（Internet Relay Chat，IRC）通道、P2P 网络，蠕虫之间或蠕虫与主控机之间进行相互协作。由蠕虫构成的网络称为 Botnet，其结构类似松散协作的 Web 站点，该结构允许任何一个蠕虫或蠕虫组失效，并存在多个连接通道用于信息与协调工作，因此，灵活性非常好。

Botnet 常用于分布式拒绝服务攻击，从很多站点发起对受害者的并行攻击。它们也常常用于垃圾邮件或其他大邮件攻击，发送服务提供者发送极大邮件可能引起网络堵塞。

5.1.1.3 对网络中信息的威胁

1. 传输中的威胁：偷听与窃听

实施攻击的最简便方法就是偷听（eavesdrop）。攻击者无须额外努力就可以毫无阻碍地获取受害者正在传送的通信内容。例如，一名攻击者（或一名系统管理员）正在通过监视流经某个节点的所有流量进行偷听。管理者可能出于一种合法的目的。比如，查看是否有员工不正确地使用资源（例如，通过公司内部网络访问与工作不相干的网站），或者与不合适的对象进行通信（例如，从一台军用计算机向敌人传递一些文件）。

窃听（wiretap）即通过一些方法窃取通信信息。被动窃听（passive wiretapping）只是“听”，与偷听非常相近。而主动窃听（active wiretapping）则意味着还要在通信信息中注入某些东西。例如，A 可以用他自己的通信内容来取代 B 的通信内容，或者以 B 的名义创建一次通信。窃听源于电报和电话通信中的窃听，常常需要进行某种物理活动，在这种活动中，使用某种设备从通信线路上获取信息。事实上，由于与通信线路进行实际的接触不是必需的条件，所以有时可以偷偷地实施窃听，甚至通信的发送者和接收者都不会知道通信的内容已经被截取了。

窃听是否成功与通信媒介有关。下面详细介绍针对不同通信媒介的可能攻击方法。

(1) 电缆。对大多数局部网络而言,在一个以太网或其他 LAN 中,任何人都可以截取电缆中传送的所有信号。每一个 LAN 连接器(如计算机网卡)都有一个唯一的地址,每一块网卡及其驱动程序都预先设计好了程序,用它的唯一地址(作为发送者的"返回地址")来标识它发出的所有数据包,并只从网络中接收以其主机为目的地址的数据包。

但是,仅仅删除发往某个给定主机地址的数据包是不可能的,并且用户也没有办法阻止一个程序检查经过的每一个包。但数据包嗅探器(packet sniffer)可以获取一个 LAN 上的所有数据包。还有一种方法,可以对一个网卡重新编程,使它与 LAN 上另一块已经存在的网卡具有相同的地址。这样,这两块不同的网卡都可以获取发往该地址的数据包(为避免被其他人察觉,这张伪造的网卡必须将它所截取的包复制后发回网络)。就目前而言,这些 LAN 通常仅仅用在相当友好的环境中,因此这种攻击很少发生。

一些高明的攻击者会利用电缆线的特性,不需要进行任何物理操作就可以读取其中传递的数据包。电缆线(及其他电子元件)会发射无线电波,通过自感应(inductance)过程,入侵者可以从电缆线上读取辐射出的信号,而无须与电缆进行物理接触。电缆信号只能传输一段较短的距离,而且可能受其他导电材料的影响。由于这种用来获取信号的设备并不昂贵而且很容易得到,因此对采用电缆作为传输介质的网络应高度重视自感应威胁。为了使攻击能起作用,入侵者必须相当接近电缆,因此,这种攻击形式只能在有合理理由接触到电缆的环境中使用。

如果与电缆的距离不能靠得足够近,攻击者因无法实施自感应技术时,就可能采取一些更极端的措施。窃听电缆信号最容易的形式是直接切断电缆。如果这条电缆已经投入使用,切断它将会导致所有服务都停止。在进行修复的时候,攻击者可以很容易地分接出另外一根电缆,然后通过这根电缆就可以获取在原来电缆线上传输的所有信号。

网络中传输的信号是多路复用(multiplexed)的,意味着在某个特定的时刻不止一个信号在传输。例如,两个模拟(声音)信号可以合成起来,像一种音乐和弦中的两个声调一样;同样,两个数字信号也可以通过交叉合成起来,就像玩扑克牌时洗牌一样。LAN 传输的是截然不同的包,但是在 WAN 上传输的数据却在离开发送它们的主机以后经过了复杂的多路复用处理。这样,在 WAN 上的窃听者不仅需要截取自己想要的通信信号,而且需要将这些信号从同时经过多路复用处理的信号中区分开来。只有能够同时做到这两件事情,这种攻击方式才值得一试。

(2) 微波。微波信号不是沿着电缆传输的,而是通过空气传播的,这使得它们更容易被局外人接触到。一个传输者的信号通常都是正对着它的接收者发送的。信号路径必须足够宽,才能确保接收者收到信号。从安全的角度来说,信号路径越宽,越容易招引攻击。一个人不仅可以在发送者与接收者连线的中间截取微波信号,而且可以在与目标焦点有稍许偏差的地方,架设一根天线来获取完整的传输信号。

微波信号通常都不采取屏蔽或隔离措施以防止截取。因此,微波是一种很不安全的传输介质。然而,由于微波链路中携带着巨大的流量,因此,几乎不可能(但不是完全不能够)将某一个特定的通信信号从同时进行了多路复用处理的其他传输信号中分离出来。但对于一条专有的微波链路而言,由于只传输某一个组织机构的通信信息,从而不能很好地获得因容量大而产生的保护。

(3) 卫星通信。卫星通信也存在着与微波信号相似的问题,因为发射的信号散布在一个

比预定接收点广得多的范围内。尽管不同的卫星具有不同的特点，但有一点是相同的：在一个几百公里宽上千千米长的区域内都可以截取卫星信号。因此，潜在被截取的可能性比微波信号更大。然而，由于卫星通信通常都经过了复杂的多路复用处理，因而被截取的危险相对于任何只传输一种通信信号的介质要小得多。

（4）光纤。光纤相对于其他通信介质而言，提供了两种特有的安全优势。第一，在每次进行一个新的连接时，都必须对整个光纤网络进行仔细调整。因此，没有人能够在不被系统察觉的情况下分接光纤系统。只要剪断一束光纤中的一根就会打破整个网络的平衡。第二，光纤中传输的是光能，而不是电能。电会发射电磁场，而光不会。因此，不可能在光纤上使用自感应技术。然而，即使使用光纤也不是绝对安全可靠的，还需要使用加密技术。在通信线路中间需要安放中继器、连接器和分接器等设备，在这些位置获取数据比从光纤本身获取数据要容易得多。从计算设备到光纤的连接处也可能有一些渗透点。

（5）无线通信。无线通信是通过无线电波进行信号传送的。在美国，无线计算机连接与车库开门器、本地无线电（如用于婴儿监控器）、一些无绳电话及其他短距离的应用设备共享相同的频率。尽管频率带宽显得很拥挤，但是对某一个用户而言，很少同时使用相同带宽上的多个设备，因此，争夺带宽或干扰不构成问题。

但其主要的威胁不是干扰，而是截取。无线通信信号的范围能够达到100～200英尺（1英尺＝0.3米），可以很容易地收到强信号。而且，使用便宜的调谐天线就可以在几千米外的地方接收到无线信号。换句话说，某些人如果想要接收用户发出的信号，可以在几条街区的范围内做这件事情。通过停在路边的一辆卡车或有篷货车，拦截者就可以在相当长的一段时间内监视用户的通信，而不会引起任何怀疑。在无线通信中，通常不使用加密技术，而且在一名执着的攻击者面前，某些无线通信设备中内置的加密往往显得不是足够健壮。

无线网络还存在一个问题：有骗取网络连接的可能性。很多主机都运行了动态主机配置协议（Dynamic Host Configuration Protocol，DHCP），通过该协议，一名客户可以从一个主机获得一个临时IP地址和连接。这些地址原本放在一个缓冲池中，并随时可以取用。一名新客户可以通过DHCP向主机请求一个连接和一个IP地址，然后服务器从缓冲池中取出一个IP地址，并分配给请求的主机。

这种分配机制在鉴别上存在一个很大的问题：除非主机在分配一个连接之前对用户的身份进行了鉴别，否则，任何进行请求的客户都可以分配到一个IP地址，并以此进行对网络的访问（通常分配发生在客户工作站上的用户真正到服务器上进行身份确认之前，因此，在分配的时候，DHCP服务器不可能要求客户工作站提供一个已鉴别的用户身份）。这种状况非常严重，因为通过一些城区的连接示意图，就可以找到很多可用的无线连接。

从安全的观点看来，应该假设在网络节点之间所有的通信链路都有被突破的可能。由于这个原因，商业网络用户采取加密的方法来保护他们通信的机密性，尽管出于性能的考虑，商业网络更倾向于采用加强物理上和管理上的安全来保护本地连接，但还是可以对局部的网络通信进行加密。

2. 假冒

在很多情况下，有一种比采用偷听、窃听技术获取网络信息更简单的方法：假冒另一个人或另外一个进程。如果可以直接获取相同的数据，为何还要冒险从一根电缆线上去感应信息，或费力地从很多通信中分离出其中的一个通信呢？

在广域网中采用假冒技术比在局域网中具有更大的威胁。在局域网中有更好的方法获取

对其他用户的访问。比如，他们直接坐到一台无人注意的工作站上，就可以开始工作了。但是，即使是在局域网环境中，假冒攻击也是不容忽视的。因为，局域网有时会在未经安全考虑的情况下就被连接到一个更大的网络中去。

在假冒攻击中，攻击者有以下几种方式可供选择。

- 猜测目标的身份和鉴别细节。
- 从一个以前的通信或者通过窃听技术获取目标的身份和鉴别细节。
- 绕过目标计算机上的鉴别机制或使其失效。
- 使用一个不需要鉴别的目标。
- 使用一个采用众所周知的鉴别方法的目标。

下面对每一种选择方式进行详细介绍。

(1) 通过猜测突破鉴别。口令猜测的原因是很多用户选择了默认口令或容易被猜出的口令。在一个值得信赖的环境中(如一个办公用 LAN)，口令可能仅仅是一个象征性的信号，表明该用户不想让其他人使用这台工作站或这个账户。有时，受到口令保护的工作站上含有一些敏感的数据，如员工的薪水清单或关于一些新产品的信息。一些用户可能认为只要有口令就可以使有好奇心的同事知趣地走开，他们似乎没有理由防范一心要搞破坏的攻击者。然而，一旦这种值得信赖的环境连接到了一个不能信赖的较大范围的网络中，所有采用简单口令的用户就会成为很容易攻击的目标。实际情况是，一些系统原本没有连接到较大的网络中，因此它们的用户处在一个较少暴露的环境中。一旦进行了与较大网络的连接，这种状况就明显地改变了。

(2) 以偷听或窃听突破鉴别。由于分布式和客户/服务器计算环境不断增加，一些用户常常对几台联网的计算机都有访问权限。为了禁止任何外人使用这些访问权限，就要求在主机之间进行鉴别。这些访问可能直接由用户输入，也可能通过主机对主机鉴别协议代表用户自动做这些事情。不论是在哪种情况下，都要求将账户和鉴别细节传送到目标主机。当这些内容在网络上传输时，它们就暴露在网络上任何一个正在监视该通信的人面前。这些同样的鉴别细节可以被一个假冒者反复使用，直到它们被改变为止。

由于显式地传输一个口令是一个明显的弱点，所以有人开发出了一些新的协议，它们可以使口令不离开用户的工作站。但是，保管和使用等细节是非常重要的。

微软公司的 LAN Manager 是一种早期用于实现联网的方法，它采用了一种口令交换机制，使得口令自身不会显式地传输出去；当需要传输口令时，所传送的只是一个加密的 Hash 代码。口令可以由多达 14 个字符组成，其中，可以包含大小写字母、数字或一些特殊字符，则口令的每个位置有 67 种可能的选择，所以，一共有 67^{14} 种可能——这是一个令人生畏的工作因数(work factor)。然而，这 14 个字符并不是分布在整个 Hash 表中的，它们被分成子串分两次发送出去，分别代表字符 1～7 和 8～14。如果口令中只有 7 个或不到 7 个字符，则第二个子串全用 Null 替代，从而可以立即被识别。一个包含 8 个字符的口令，在第二个子串中有 1 个字符和 6 个 Null，因此，只需进行 67 次猜测就可以找出这个字符。即使在最大情况下，对一个包含 14 个字符的口令，工作因数从 67^{14} 下降到了 $67^7 + 67^7 = 2 \times 67^7$。这些工作因数也大约相当于一个 100 亿的不同因数。LAN Manager 鉴别仍保留在很多后来出现的系统之中(包括 Windows NT)，只是作为一种可选项使用，以支持向下兼容像 Windows 95/98 这样的系统。这说明了为什么安全和加密都是很重要的，而且必须从设计和实现的概念阶段就开始由专家对其进行严密监控。

（3）避开鉴别。很显然，鉴别只有在它运行的时候才有效。对于一个有弱点或有缺陷的鉴别机制来说，任何系统或个人都可以绕开该鉴别过程而访问该系统。

在一个典型的操作系统缺陷中，用于接收输入口令的缓冲区大小是固定的，并对所有输入的字符进行计数，包括用于改错的退格符。如果用于输入的字符数量超过了缓冲区的容纳能力，就会出现溢出，从而导致操作系统省略对口令的比较，并把它当作经过了正确鉴别的口令一样对待。这些缺陷或弱点可以被任何寻求访问的人所利用。

许多网络主机，尤其是连接到广域网上的主机，运行的操作系统很多都是 UNIX System V 或 BSD UNIX。在一个局部网络环境中，很多用户都不知道正在使用的是哪一种操作系统；仅有少数几个人知道，或有能力知道这些信息，另外也有少数人对利用操作系统的缺陷很感兴趣。然而，在广域网中，一些黑客会定期扫描网络，以搜寻正在运行着有弱点或缺陷的操作系统的主机。因此，连接到广域网（尤其是因特网）会将这些缺陷暴露给更多企图利用它们的人。

（4）不存在的鉴别。如果有两台计算机供一些相同的用户存储数据和运行程序，并且每一台计算机在每一个用户第一次访问时都要对他进行鉴别，用户可能会认为计算机对计算机（computer-to-computer）或者本地用户对远程进程（local user-to-remote process）的鉴别是没有必要的。如果两台计算机及其用户同处于一个值得信赖的环境中，重复鉴别将增加复杂性，这看起来有些多余。

然而，这种假设是不正确的。为了说明这个问题，下面介绍 UNIX 系统的处理方法。在 UNIX 系统中，.rhosts 文件列出了所有可信任主机，.rlogin 文件列出了所有可信任用户，它们都被允许不经鉴别就可以访问系统。使用这些文件的目的是支持已经经过其所在域的主机鉴别过的用户进行计算机对计算机的连接。这些“可信任主机”也可以被局外人所利用：他们可以通过一个鉴别弱点（如一个猜出来的口令）获取对一个系统的访问，然后就可以实现对另外一个系统的访问（只要这个系统接受来自其可信任列表中的真实用户）。

攻击者也可能知道一个系统有一些身份不需要经过鉴别。一些系统有 Guest 或 Anonymous 账户，以便允许其他人可以访问系统对所有人发布的信息。例如，一家银行可能发布目前的外币汇率列表，所有在线目录的图书馆可能想把这个目录提供给任何人进行搜索，一家公司可能会允许任何人访问它的一些报告。一个用户可以用 Guest 登录系统，并获取一些公开的有用信息。通常，这些系统不会对这些账号要求口令；或者向用户显示一条消息，提示他们在要求输入口令的地方输入 GUEST（或用户的名字，只需要任何一个看起来像人名的任何字符串都行）。这些账户都允许未经鉴别的用户进行访问。

（5）众所周知的鉴别。鉴别数据应该是唯一的，而且很难被猜出来。然而，遗憾的是，采用方便的鉴别数据和众所周知的鉴别方案，有时会使得这种保护形同虚设。例如，一家计算机制造商计划使用统一的口令，以便它的远程维护人员可以访问遍布世界各地的任何一台客户的计算机。幸运的是，在该计划付诸实施之前，安全专家们指出了其中潜在的危险。

系统网络管理协议（SNMP）广泛应用于网络设备（如路由器和交换机）的远程管理，不支持普通的用户。SNMP 使用了一个公用字符串（community string），这是一个重要的口令，用于公用设备彼此之间的交互。然而，网络设备被设计成可以进行带有最小配置的快速安装，并且很多网络管理员并不改变这个安装在一个路由器或者交换机中默认的公用字符串。这种疏忽使得这些在网络上的设备很容易受到多种 SNMP 的攻击。

目前，一些销售商仍然喜欢在出售计算机时附带安装一个系统管理员账号和默认口令，有些系统管理员也忘记了改变他们的口令或者删除这些账号。

3. 欺骗

通过猜测或获取一个实体(用户、账户、进程、节点、设备等)的网络鉴别证书后,攻击者可以该实体的身份进行一个完整的通信。在假冒方式中,攻击者扮演了一个合法的实体。与此密切相关的是欺骗(spoofing),指一名攻击者在网络的另一端以不真实的身份与用户交互。欺骗方式包括伪装、会话劫持和中间人攻击。

(1) **伪装**。伪装(masquerade)指一台主机伪装成另一台主机。伪装的常见手段是混淆URL。域名很容易被混淆,域名的类型也很容易被人们搞混。比如,xyz.com、xyz.org 和 xyz.net 可能是三个不同的组织机构,也可能只有一个(假设 xyz.com)是某个真正存在的组织机构的域名,而其他两个是由某个具有伪装企图的人注册的相似域名。名称中有无连字符(coca-cola.com 对应 cocacola.com),以及容易混淆的名称(10pht.com 对应 lopht.com,或者 citibank.com 对应 citybank.com)也都是实施伪装的候选名称。

假设某黑客想要攻击一家真正的银行——芝加哥 First Blue Bank。该银行的域名是 Blue Bank.com,因此,他注册了一个域名 Blue-Bank.com。然后,用 Blue-Bank.com 建立一个网站,还将他从真正的 Blue Bank.com 上下载的首页作为这个网站的首页,并使用真正的 Blue Bank 图标等,以使这个网站看起来尽可能像 First Blue Bank 的网站。最后,黑客邀请人们使用他们的姓名、账号及口令或 PIN 登录这个网站(这种访问重定向可以采用很多种方法来完成。比如,可以在某些有影响的网站上花钱申请一个横幅广告,使它链接到这个站点,而不是真正的银行站点;或者可以发邮件给一些芝加哥居民,邀请他们访问这个站点)。在从几个真正的银行用户处收集了一些个人信息之后,黑客可以删除这个链接,将这个链接传递给真正的 Blue Bank 银行,或者继续收集更多的信息。黑客甚至可以不留痕迹地将这个连接转换成一个真正的 Blue Bank 的已鉴别访问,这样,这些用户就永远不会意识到背后发生的故事。

这种攻击的另一种变化形式是"钓鱼欺诈"(phishing)。假设黑客发送了一封 E-mail,其包含有真实的 Blue Bank 的标志,诱使用户打开其中链接,然后将受害者带到 Blue Bank 网站。使用这种方法获得受害者的账户,或者黑客通过金钱奖励让受害者回答调查题(从而需要账号与 PIN 来返还金钱),或其他合法的解释来获得账户信息。这个链接可能是伪装的域 Blue-Bank.com,该链接可能写着"单击这里可访问你的账户"(单击这个链接到黑客假冒的网站),或者黑客可能针对 URL 使用其他小把戏来愚弄受害者,如 www.redirect.com/bluebank.com。

在另一种伪装方法中,攻击者利用了受害者网页服务器的一个缺陷,从而可以覆盖受害者的主页。尽管换掉某人的主页会让他在公众面前很没面子,也许还带有一些与该网站的目标相悖的不堪入目的内容或极端的信息(比如,在屠宰场的网站上出现了一些素食主义者的恳求),但绝大多数人都不会被显示出来的与该网站的目标格格不入的消息所愚弄。然而,高明的攻击者可能要狡猾得多,他们不会将真正的网站弄得面目全非,而是尽量模仿原来的站点建立一个虚假的站点,以便获取一些敏感的信息(姓名、鉴别号、信用卡号等),或者诱导用户进行真正的交易。例如,如果有一家书店的网站(不妨称为 Books-R-Us),被另一家书店(称之为 Books Depot)巧妙地替换了。那么,那些天真的用户还以为是在跟 Books-R-Us 做交易,殊不知订单的处理、填单及付账等操作都被 Books Depot 在背后接管了。"钓鱼欺诈"已成为一个严重的问题。http://survey.mailfrontier.com/survey/quiztest.html 网站可测试用户从真正的网站中识别出"钓鱼欺诈"网站的能力。

(2) **会话劫持**。会话劫持(session hijacking)指截取并维持一个由其他实体开始的会话。假设有两个实体已经进入了一个会话,然后第三个实体截取了他们的通信并以其中某一方的

名义与另一方进行会话。仍以 Books-R-Us 书店为例来说明这项技术。如果 Books Depot 书店采用窃听技术窃听了在用户和 Books-R-Us 之间传递的数据包，Books Depot 书店最初只需要监视这些信息流，让 Books-R-Us 去完成那些不容易做的工作，如显示售货清单及说服用户购买等。然后，当用户填完了订单，并发出订购信息的时候，Books Depot 书店截取内容是“我要付账”的数据包，然后与用户进行接下来的工作：获取邮购地址和信用卡号等。对 Books-R-Us 书店而言，这次交易看起来像是一次没有完成的交易：用户仅仅是在网页进行了浏览，但由于某些原因并未进行购买。这样，Books Depot 书店就劫持了这次会话。

另一种与此不同的例子涉及交互式会话，如使用 Telnet。如果一名系统管理员以特权账户的身份进行远程登录，使用会话劫持工具可以介入该通信并向系统发出命令，就好像这些命令是由系统管理员发出的一样。

（3）**中间人攻击**。在会话劫持中要求在两个实体之间进行的会话有第三方介入，而中间人攻击（man-in-the-middle）是一种与此相似的攻击形式，也要求有一个实体侵入两个会话的实体之间。它们之间的区别在于，中间人攻击通常在会话的开始就参与进来了，而会话劫持发生在一个会话建立之后。其实它们之间的区别仅仅是一种语义上的区别，而在实际上却没有多大的意义。中间人攻击常常通过协议来描述，如图 5.4 所示。

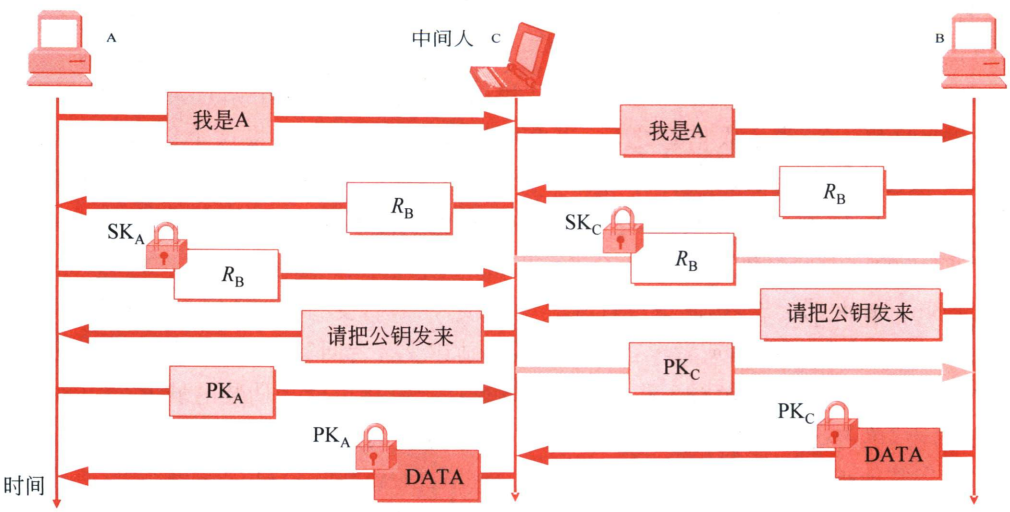


图 5.4 中间人攻击

- A 向 B 发送“我是 A”的报文，并给出了自己的身份。此报文被中间人 C 截获，C 把此报文原封不动地转发给 B。B 选择一个不重数 R_B 发送给 A，但同样被 C 截获后也照样转发给 A。
- 中间人 C 用自己的私钥 SK_C 对 R_B 加密后发回给 B，使 B 误以为是 A 发来的。A 收到 R_B 后也用自己的私钥 SK_A 对 R_B 加密后发回给 B，中途被 C 截获并丢弃。B 向 A 索取其公钥，此报文被 C 截获后转发给 A。
- C 把自己的公钥 PK_C 冒充是 A 的发送给 B，而 C 也截获到 A 发送给 B 的公钥 PK_A。
- B 用收到的公钥 PK_C（以为是 A 的）对数据加密发送给 A。C 截获后用自己的私钥 SK_C 解密，复制一份留下，再用 A 的公钥 PK_A 对数据加密后发送给 A。A 收到数据后，用自己的私钥 SK_A 解密，以为和 B 进行了保密通信。其实，B 发送给 A 的加密数据已被中间人 C 截获并解密了一份，但 A 和 B 对此并不知情。

4. 消息机密性面临的威胁

由于使用了公共网络，攻击者可以很容易破坏消息的机密性(也可能是消息的完整性)。采用前面所讲过的窃听和假冒攻击可以导致消息失去机密性和完整性。下面讨论可能影响消息机密性的其他几种弱点。

(1) 误传。有时，因为网络硬件或软件中存在一些缺陷，可能会导致消息被误传。其中，经常出现的情况是整个消息丢失了，这是一个完整性或可用性问题。然而，偶尔也会出现目的地址被修改或由于某些处理单元失效，从而导致消息被错误地传给了其他人。但是，所有这些“随机”事件都是相当罕见的。

与网络缺陷相比，人为的错误出现得更为频繁。比如，将一个地址“100064,30652”输成了“10064,30652”或“100065,30642”，或者将 David Ian Walker 的缩写 diw 输成了 idw 或 iw，类似的事情简直数不胜数。计算机网络管理员通过无意义的长串数字或“神秘的”首字符缩写去识别不同的人，难免会出现错误，而使用有意义的一些词，如 iwalker，犯错误的可能性会小些。

(2) 暴露。为了保护消息的机密性，必须对从它被创建开始到被释放为止的整个过程进行跟踪。在整个过程中，消息的内容将暴露在临时缓冲区中，遍及整个网络的交换器、路由器、网关和中间主机中，以及在建立、格式化和表示消息的进程工作区中。被动窃听是一种暴露消息的方式，同时也是对传统网络结构的破坏，因为在传统网络结构中，消息只传送到它的目的地。最后要指出的是，在消息的出发点、目的地或者任何一个中间节点通过截取方式都可以导致消息的暴露。

(3) 流量分析。有时不仅消息自身是需要保密的，就连存在这条消息这个事实都是需要保密的。例如，在战争时期，如果被敌人看到了指挥部与一个特别行动小组之间有大量的网络流量，他们就可以推测出对方正在策划一项与该小组有关的重大行动计划；在商业环境中，如果发现一家公司的总经理向另一家竞争公司的总经理发送消息，就能让人推测到他们企图垄断或共谋制定价格；在政治环境中，如果一个国家与另一个国家的外交关系处于停顿状态，一旦发现总理或首相间有通信活动，就能让人推测到两国关系有缓和的可能。在这些情况下，既需要保护消息的内容，也需要保护标识发送者和接收者的报头信息。

5. 消息完整性面临的威胁

在许多情况下，通信的完整性或正确性与其机密性是同等重要的。事实上，在很多情况下完整性是极为重要的，如传递鉴别数据时。

人们依赖电子消息来作为司法证据并指导他们的行动的这种情况越来越多了。例如，如果你收到一条来自一个好朋友的消息，让你在下周星期二的晚上到某家酒馆去喝两杯，你很可能会在约定时间准时到达那里。与此类似，假如你的上司给你发了一条消息，让你立即停止正在做的项目 A 中的所有工作，转而将所有精力投身于项目 B 中，你也可能会遵从命令。只要这些消息的内容是符合情理的，我们就会采取相应的行动，就好像我们收到了一封签名信件、一个电话或进行了一次面对面的交谈一样。

然而，攻击者可能会利用你对消息的信任来误导你。特别是，攻击者可能会作出以下行动。

(1) 改变部分甚至全部消息内容。

(2) 完整地替换一条消息，包括其中的日期、时间及发送者/接收者的身份。

(3) 重用一条以前的旧消息。

(4) 摘录不同的消息片段，组合成一条消息。

（5）改变消息的来源。

（6）改变消息的目标。

（7）毁坏或者删除消息。

5.1.2 网络安全控制

5.1.2.1 数据加密

加密是一种强有力的手段，能为数据提供保密性、真实性、完整性和限制性访问。由于网络常常面临着更大的威胁，因此人们常常使用加密来保证数据的安全，有时可能还会结合其他控制手段。

在研究加密应用于网络安全威胁前，先考虑如下几点。首先，加密不是“灵丹妙药”，一个加密的有缺陷的系统设计仍然是一个有缺陷的系统设计。其次，加密只保护被加密的内容（其实并不尽然），但可能在数据被发送前，在加密处理过程前就已经被泄露了，这些数据在远程被收到并解码后，它们再次被泄露。最好的加密也不能避免邪恶的特洛伊木马攻击，特洛伊木马会在加密前拦截数据。最后，加密带来的安全性不会超过密钥管理的安全性，如果攻击者能猜测或推导出一个弱加密密钥，加密便形同虚设。

在网络应用软件中，加密可以应用于两台主机之间（称为链路加密），也可以应用于两个应用软件之间（称为端到端加密），但不管采用哪一种加密形式，密钥的分发都是一个问题。考虑到用于加密的密钥必须以一种安全的方式传递给发送者和接收者，所以在本节中，也会介绍用于实现网络中安全的密钥分发技术。最后，还会介绍一种用于网络计算环境的密码工具。

1. 链路加密

在链路加密技术中，系统在将数据放入物理通信链路之前对其加密。在这种情况下，加密发生在OSI模型中的第1层或第2层（在TCP/IP协议中是这样）。同样，解密发生在到达并进入接收计算机的时候。链路加密模型如图5.5所示。

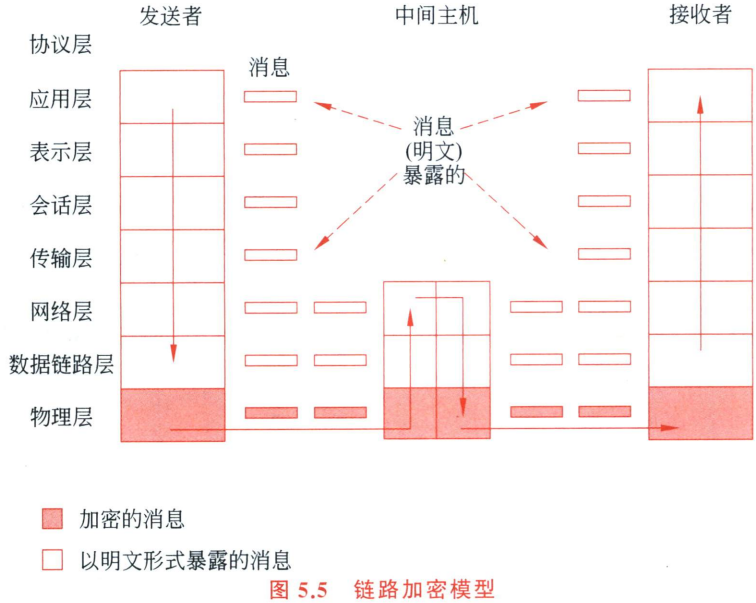


图5.5 链路加密模型

加密保护了在两台计算机之间传输的消息，但存在于主机上的消息是明文（明文意味着

“未经加密”)。请注意,因为加密是在底层协议中进行的,因而消息在发送者和接收者的其他所有层上都是暴露的。如果有很好的物理安全隔离措施,可能不会太在意这种暴露(比如,这种暴露发生在发送者或接收者的主机或工作站上,可以使用安装了警报器或者加了重锁的门保护起来)。然而,应该注意到,在消息经过的路径上的所有中间主机中,消息在协议的上面两层是暴露的。暴露之所以发生,是由于路由和寻址信息不是由底层读取的,而是在更高层上进行的。消息在所有中间主机上都是未经加密的,而且不能保证这些主机都是值得信赖的。

链路加密对用户是透明的。加密实际上变成了由低级网络协议层完成的传输服务,就像消息寻址或传输错误检测一样。图 5.6 表示的是一条典型的经过链路加密的消息,其中,用阴影表示的部分是被加密过的。因为数据链路层的首部和尾部的一些部分是在数据块被加密之前添加上去的,所以每一个块都有一部分是用阴影来表示的。由于消息 M 在每一层都要进行处理,因而首部和控制信息在发送端被加上去,在接收端被删除。硬件加密设备运行起来快速且可靠。在这种情况下,链路加密对操作系统和操作者都是透明的。

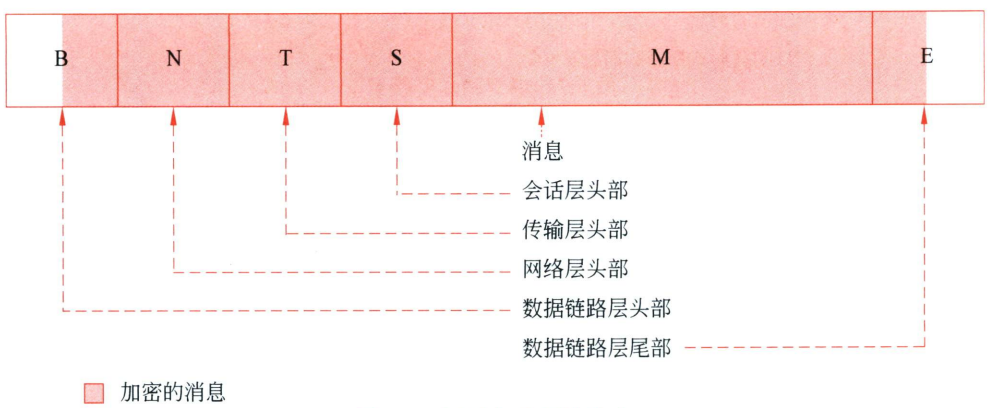


图 5.6 链路加密后的消息

当传输线路是整个网络最大的弱点时,链路加密就特别适用。如果网络上的所有主机都相当安全而通信介质是与其他用户共享或者不够安全的,链路加密就是一种简便易用的方法。

2. 端到端加密

正如其名称所示,端到端加密从传输的一端到另一端都提供了安全保障。加密可以由用户和主机之间的硬件设备来执行,也可以由运行在主机上的软件来进行。在这两种情况下,加密都是在 OSI 模型的最高层(第 7 层——应用层;也可能是第 6 层——表示层)上完成的。端到端加密模型如图 5.7 所示。

由于加密先于所有的寻址和传输处理,所以消息以加密的数据形式通过整个网络。这种加密方式可以克服在传输模型的较低层上存在的潜在弱点,即使一个较低层不能保持安全,将它收到的消息泄密了,数据的机密性也不会遇到危险。

图 5.8 表示一条典型的经过端到端加密的消息,其中也对加密的部分用阴影标注出来了。

使用端到端加密,消息即使经过了多台主机也能够保证机密性。消息的数据内容仍然是加密的,而且消息在传输的时候也是加密的(可以防范在传输过程中泄密)。因此,即使消息必须经过 A 和 B 之间的路径上潜在的不安全节点的传递,也能够防范在传输中泄露消息。

3. 链路加密与端到端加密的比较

对消息进行简单加密不能绝对保证在传输过程中或在传输之后它不会被泄密。然而,在很多情况下,考虑到窃听者破译密码的可能性和消息的时效性,加密的保护程度已经足够强大

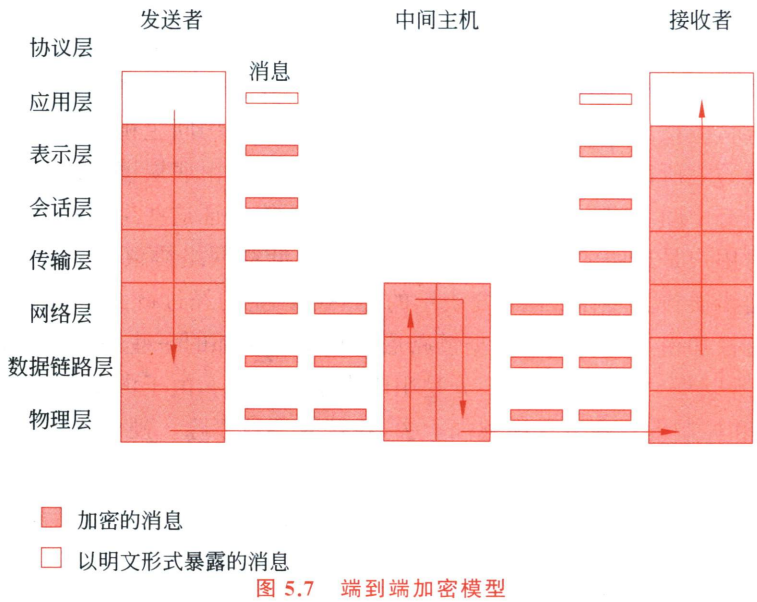


图 5.7 端到端加密模型

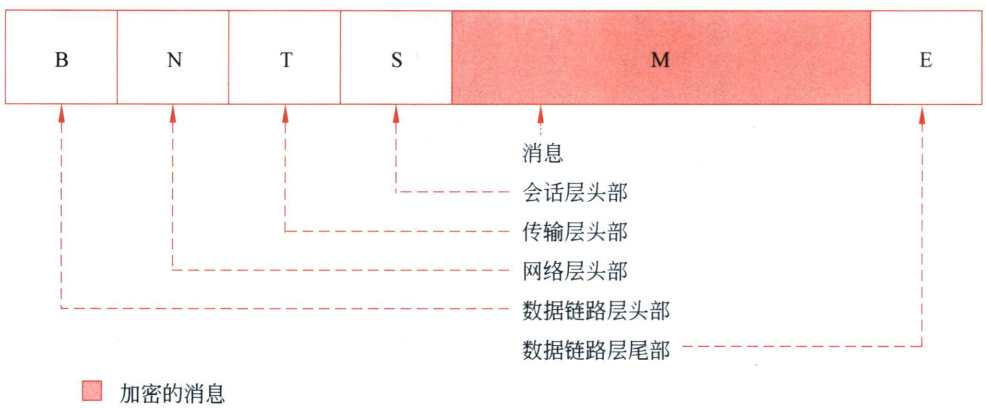


图 5.8 端到端加密的消息

了。因为安全包含很多方面的内容，所以必须在攻击的可能性与保护措施上求得均衡，而不必强调绝对安全保证。

在链路加密方式中，经过一条特定链路的所有传输都要调用加密过程。通常，一台特定的主机与网络只有一条链路相连，这就意味着该主机发出的所有通信都会被它加密。这种加密方案要求接收这些通信的其他每台主机也必须用相应的密码设备来对这些消息解密。而且，所有主机必须共享密钥。一条消息可能经过一台或多台中间主机的传递，最终到达接收端。如果该消息在网络中的某些链路上经过了加密处理，而在其他链路上没有经过加密处理，那么，加密就失去了部分优势。因此，如果一个网络最终决定采用链路加密，通常是对该网络中的所有链路都进行加密处理。

与此相反，端到端加密应用于“逻辑链路”，是两个进程之间的通道，是位于物理路径以上的一层。由于在传输路径上的中间主机不需要对信息进行加密或解密，所以它们不需要任何密码设备。因此，加密仅仅用于需要进行加密处理的消息和应用软件。此外，可以使用软件来进行加密。这样，可以有选择地进行加密，有时对一个应用进行加密，有时甚至可以对一个特定应用中的某一条消息进行加密。

当考虑加密密钥时，端到端加密的可选择性优点却变成了一个缺点。在端到端加密中，每一对用户之间有一条虚拟的加密信道。为了提供适当的安全性，每一对用户应该共享一个唯一的密码密钥，密钥的数量要求与用户对的数量相等，即 n 个用户需要 $n\times(n-1)/2$ 个密钥。随着用户数量的增加，需要的密钥数量会迅速上升。然而，这是假设使用单密钥加密的情况下计算出来的数量，在使用公钥的系统中，每名接收者仅需要一对密钥。

如表 5.1 所示，链路加密对用户而言速度更快、更容易实施，而且使用的密钥更少。端到端加密更灵活，可以有选择地使用，它是在用户层次上完成的，并且可以集成到应用软件之中。没有一种加密形式能够适用于所有情况。

表 5.1 链路加密与端到端加密的比较

比 较 项	链 路 加 密	端到端加密
主机内部安全	数据在发送主机上是暴露的	数据在发送主机上是加密的
	数据在中间节点上是暴露的	数据在中间节点上是加密的
用户的任务	由发送主机使用	由发送进程使用
	对用户不可见	用户使用加密
	由主机维护加密	用户必须寻找相应算法
	一套设施提供给所有用户使用	用户选择加密
	加密通常采用硬件完成	软、硬件实现均可
	数据要么都加密，要么都不加密	用户可以选择是否加密，选择可以针对每个数据项
实现时考虑的问题	要求每一对主机一个密钥	要求每一对用户一个密钥
	提供节点鉴别	提供用户鉴别

在某些情况下，两种加密方式都可以使用。如果用户不信任系统提供的链路加密质量，则可以使用端到端加密。同样，如果系统管理员担心某个应用程序中使用的端到端加密方案的安全性，也可以安装一台链路加密设备。如果两种加密方式都相当快，重复使用两种安全措施几乎没有负面影响。

4. SSH 加密

安全外壳协议(Secure Shell Protocol，SSH)是一对协议(版本 1 和版本 2)，最初是为 UNIX 定义的，但也可用于 Windows 2000 系统，为 Shell 或操作系统命令行解释器提供了一个鉴别和加密方法。为实现远程访问，SSH 的两个版本都取代了 UNIX 的系统工具(如 Telnet、rlogin 和 rsh 等)。SSH 能有效防止欺骗攻击和修改通信数据。

SSH 协议还包括在本地与远程站点之间协商加密算法(如 DES、IDEA 和 AES 算法)及鉴别(包含公钥和 Kerberos)。

5. SSL 加密

安全套接层(Secure Sockets Layer，SSL)协议最初是由 Netscape 公司设计来保护浏览器与服务器之间的通信的，也被称为传输层安全(Transport Layer Security，TLS)。SSL 实现了应用软件(如浏览器)与 TCP/IP 协议之间的接口，在客户与服务器之间提供服务器鉴别、可选客户鉴别和加密通信通道。客户与服务器为会话加密协商一组相互支持的加密方式，可能使

用三重 DES 和 SHA1，或者 128 位密钥的 RC4 及 MD5。

要使用 SSL，客户首先要请求一个 SSL 会话。服务器用它的公钥证书响应，以便客户可以确认服务器的真实性。客户返回用服务器公钥加密的对称会话密钥部分。服务器与客户都要计算会话密钥，然后使用共享的会话密钥进行加密通信。

该协议虽然简单，但是很有效，而且是因特网上使用最广的安全通信协议。但是，SSL 只保护从客户端浏览器到服务器解密点这一段（服务器解密点通常指服务器的防火墙，或者稍微强一点，是到运行 Web 应用的计算机）。从用户键盘到浏览器，以及穿过接收者公司网络，数据都有可能被泄露。Blue Gem Security 已开发了一种被称为 LocalSSL 的产品，该产品可以在输入数据时进行加密，直到操作系统将它传递给浏览器，这样，可以避免键盘记录的特洛伊木马攻击（这类木马一旦植入用户计算机，就可以泄露用户输入的任何数据）。

6. IPSec

为了解决 32 位的 IPv4 网络地址逐渐枯竭的问题，IPv6 应运而生。同时，针对 IPv4 协议的一些缺陷（如容易遭受欺骗、窃听和会话劫持等攻击），IPv6 采用了 IP 安全协议（IP Security Protocol，IPSec），定义了一种标准方法来处理加密的数据。IPSec 协议是在 IP 层上实现的，所以它会影响到上面各层，特别是 TCP 和 UDP。因此，IPSec 要求不改变已经存在的大量 TCP 和 UDP 协议。

IPSec 在某些方面与 SSL 有些相似，它们都在某种程度上支持鉴别和机密性，也不会对其上的层（在应用层）或其下的层进行必需的重大改变。像 SSL 一样，IPSec 被设计成与具体的加密协议无关，并允许通信双方就一套互相支持的协议达成一致。

7. 签名代码

前面曾提到一些人可以将活动代码放置在网站上，等着毫无戒备心的用户下载。活动代码将使用下载它的用户的特权运行，这样，将会造成很严重的破坏，如删除文件、发送电子邮件消息，甚至使用特洛伊木马造成轻微而难以察觉的损害等。如今，网站的发展趋势是允许从中心站点下载应用软件和进行软件升级，因此，下载到一些怀有恶意的文件的危险性正在增加。

签名代码是减少这种危险的一种方法。一个值得信赖的第三方对一段代码追加一个数字签名，言外之意就是使代码更值得信赖。PKI 中有一个签名结构有助于实现签名。

谁可以担当可信赖的第三方呢？一个众所周知的软件生产商可能是公认的代码签名者。但是，对于生产设备驱动程序或代码插件的不出名的小公司是不是也值得信赖呢？如果代码的销售商不知名，则他的签名是没有用处的，因为无赖也可以发布自己的签名代码。

然而，在 2001 年 3 月，Verisign 宣布它以微软公司的名义错误地发布了两个签名代码证书给一名声称是（但实际上不是）微软公司的职员。在错误被检查出来之前，这些证书已经流通了将近两个月的时间。虽然后来 Verisign 检查出了这个错误并取消了这些证书，而且只需要检查 Verisign 的列表就可以知道该证书已被撤销，但绝大多数人都不会对下载有微软签名的代码产生怀疑。

8. 加密的 E-mail

一个电子邮件消息很像一张明信片的背面。邮件投递员（以及在邮政系统中经手明信片传递的任何人）都可以阅读其中的地址和消息部分的任何内容。为了保护消息和寻址信息的私有权，可以使用加密来保护消息的机密性及其完整性。

正如在其他几种应用中看到的一样，加密是一个相对比较容易的部分，密钥管理才是一个更困难的问题。密钥管理通常有两种主要的方法，分别是使用分层的、基于证书的 PKI 方案

来交换密钥，以及使用单一的、个人对个人的交换方式。分层方法称为 S/MIME，已经广泛用于商业邮件处理程序，如 Microsoft Exchange 或 Eudora。个人方法称为 PGP，是一种商业附加软件。

5.1.2.2 虚拟专用网

链路加密可为网络用户提供一种环境，在这种环境中，使他们感觉仿佛处在一个专有网络中。由于这个原因，这种方法被称为虚拟专用网络(Virtual Private Network，VPN)。

一般情况下，物理安全性和管理安全性对于保护网络周界内的传输已经足够了。因此，对用户而言，用户的工作站(或客户机)与主机网络(或服务器的周界)之间是最大的暴露之处。

防火墙是一种访问控制设备，常常安置在两个网络或者两个网络段之间。它过滤了在受保护的(即“内部”)网络与不可信的(即“外部”)网络或网络段之间的所有流量。

许多防火墙都可用于实现 VPN。当用户第一次与防火墙建立一个通信时，用户可以向防火墙请求一个 VPN 会话。用户的客户机与防火墙通过协商获得一个会话加密密钥，随后防火墙和客户机使用该密钥对它们之间的所有通信进行加密。通过这种方法，一个较大的网络被限制为只允许进行由 VPN 所指定的特殊访问。换句话说，用户的感觉就像网络是专有的。有了 VPN，通信就经过了一个加密隧道。VPN 的建立如图 5.9 所示。

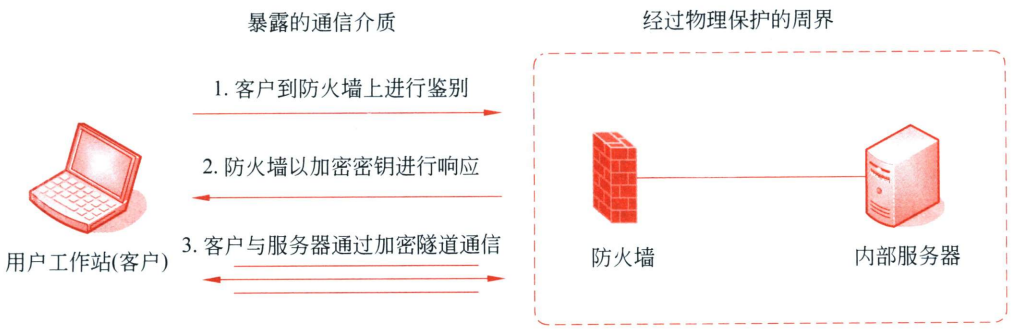


图 5.9 建立虚拟专有网络的过程

在防火墙与网络周界内的鉴别服务器交互时，建立虚拟专有网络。防火墙会将用户鉴别数据传递给鉴别服务器，在确认了用户的鉴别身份以后，防火墙将给用户提供适当的安全特权。例如，一位熟悉的可信赖之人(如一名雇员或者系统管理员)可能会被允许访问普通用户不能访问的资源。防火墙在 VPN 的基础上实现了访问控制。

5.1.2.3 PKI 与证书

公钥基础设施(Public Key Infrastructure，PKI)是一个为实现公钥加密而建立的进程，常常用于一些大型(和分布式)应用环境中。PKI 为每一个用户提供了一套与身份鉴别和访问控制相关的服务，包括内容如下。

(1) 使用(公开的)加密密钥建立与用户身份相关的证书。

(2) 从数据库中分发证书。

(3) 对证书签名以增加证书真实性的可信度。

(4) 确认(或否认)一个证书是有效的。

(5) 无效证书意味着持有该证书的用户不再被允许访问，或者他们的私钥已经泄密。

PKI 常常被当作一种标准，但事实上它定义了一套策略、产品和规程的框架。其中的策略定义了加密系统的操作规则，尤其是其中指出了怎样处理密钥和易受攻击的信息，以及如何使

控制级别与危险级别相匹配。规程规定了怎样生成、管理和使用密钥。最后，产品实际上实现了这些策略，并实现了生成、存储和管理密钥。

PKI建立的一些实体被称为证书管理中心(certificate authority)，实现了PKI证书管理规则。通常认为证书管理中心是可信赖的，因此，用户可以将证书的解释、发放、接收和回收工作委托给证书管理中心来做。证书管理中心的活动概括如下。

(1) 对公钥证书的整个生命周期进行管理。

(2) 通过将一个用户或者系统的身份绑定到一个带有数字签名的公钥来发放证书。

(3) 为证书安排终止日期。

(4) 通过发布证书撤销列表来确保证书在需要的时候被撤销。

证书管理中心的功能可以在管理中心的内部、一个商业服务或可信任的第三方进行。

PKI还包含一个注册管理中心，充当用户和证书管理中心之间的接口。注册管理中心获取并鉴别用户的身份，然后向相应的证书管理中心提交一个证书请求。从这个意义上来看，注册管理中心非常像美国邮政管理局：邮政管理局扮演的角色是充当美国政府部门的代理，允许美国公民获取护照(美国官方证书)。当然，之前公民必须提供一些适当的表格、身份证明，并向护照发行办公室(证书管理中心)提出真实护照(与证书类似)申请。与护照类似，注册管理中心的性质决定了发放证书的信任级别。

许多国家正在为实现PKI而努力，目的是允许公司和政府代理实现PKI相互操作。例如，美国联邦PKI Initiative最终将允许任何美国政府代理在合适的时候向任何其他美国政府代理发送安全的通信。该组织也规定了实现PKI的商业工具应该怎样工作，以便这些代理可以去买已经做好的PKI产品，而不需要他们自己来开发。主流PKI解决方案开发商包括Baltimore Technologies、Northern Telecom/Entrust及Identrus。下面举例说明PKI在银行中的商业应用。

Lloyd's TSB是总部设在英国的一家储蓄银行，2002年，该银行实施了一项名为KOB(key online banking)的试验计划——用智能卡实现在线银行业服务。KOB是第一个将基于智能卡的PKI用于大范围网上银行业务的项目。市场研究结果显示：75%的银行客户是被KOB提供的可靠的安全性吸引来的。

要想使用KOB，客户需要将智能卡插入一台像ATM机一样的设备，然后输入一个唯一的PIN。这样，在进行任何金融交易之前，要求采用的鉴别方法是两步法。智能卡中包含着PKI密钥对和数字证书。当客户完成交易之后，他通过注销并取出智能卡来结束与银行的会话。

依照Lloyd's TSB的分布式商务银行主管Alan Woods的话说："KOB的优点在于它降低了商用数字身份证书被泄露的危险。这是因为与标准PKI系统不同，在KOB的PKI中，用户的私钥不是保存在他们的工作站桌面上，而是通过智能卡本身来发布、存储和撤销的。这种KOB智能卡可以随时保存在用户身边。"使用它，客户可以更安全地进行交易。

绝大多数PKI进程使用证书来将身份与一个密钥绑定在一起。但是，目前正在研究将证书的概念扩展为一些更广的信任特征。例如，信用卡公司可能对验证用户的经济状况比验证身份更感兴趣，他们使用的PKI方案可能会用一个证书将用户的经济状况和一个密钥绑定在一起。简单分布式安全基础设施(Simple Distributed Security Infrastructure，SDSI)采用了这种方案，包含身份证书、组成员关系证书和名称绑定证书。目前已经出现了两个相关标准的草案：ANSI标准X9.45和简单公钥基础设施(Simple Public Key Infrastructure，SPKI)。

PKI还是一个不成熟的处理方案，仍有很多问题需要解决，尤其是PKI还没有在大规模

的应用环境中实现。表5.2列出了在学习有关PKI的更多内容时应该注意的几个问题。然而，有些事情已经很清楚了。首先，证书管理中心应该经过独立实体的批准和验证。证书管理中心的私钥应该存储在一个抗篡改的安全模块中。其次，对证书管理中心和注册管理中心的访问应该进行严密控制，通过一些强用户鉴别方式（如智能卡）可加以实现。

表5.2 与PKI相关的应注意的问题

特 性	问 题
灵活性	应该如何实现互操作性及如何与其他PKI的实现保持一致： • 开放的、标准的接口； • 兼容的安全策略
	应该如何注册证书： • 面对面注册、电子邮件注册、Web注册还是通过网络注册； • 单个注册还是成批注册（如身份证、银行卡）
易用性	应该如何训练人们设计、使用和维护PKI
	应该如何配置和集成PKI
	应该如何与新用户合作
	应该如何进行备份及故障恢复
对安全策略的支持	PKI如何实现一个组织机构的安全策略
	谁有责任，有什么样的责任
可伸缩性	应该如何加入更多的用户
	应该如何加入更多的应用软件
	应该如何加入更多的证书授权
	应该如何加入更多的注册授权
	应该如何扩展证书的类型
	应该如何扩展注册机制

在对证书进行保护时涉及的安全问题还包括管理过程。例如，应该要求多个操作者同时授权证书请求。还应该设置一些控制措施来检测黑客并阻止他们发布伪造的证书请求。这些控制措施可能包括使用数字签名和强加密技术。最后，还必须进行安全审计跟踪，以便在系统出现故障时能够重建证书信息，以及在攻击真正破坏了鉴别过程时能够恢复。

5.1.2.4 身份鉴别

在网络中，安全地实现鉴别可能会很困难，因为网络环境中可能出现窃听和偷听。而且，通信的双方可能需要相互鉴别：在通过网络发送口令之前，用户希望知道自己确实在和所期望的主机进行通信。下面深入探讨适用于网络环境中的鉴别方法。

1. 一次性口令

偷听威胁意味着在一个不安全的网络中传输的用户口令很容易被窃听。采用一次性口令可以预防远程主机的窃听和欺骗。

顾名思义，一次性口令（one-time password）只能使用一次。要想知道它是怎样工作的，要先考虑其最早出现时的情况。那时，用户和主机都能访问同样的口令列表。用户在第一次登

录时使用第一个口令，第二次登录时使用第二个口令，以此类推。由于口令列表是保密的，而且没有人能根据一个口令猜测出另一个口令，因此即使通过偷听获得了一个口令也是毫无用处的。然而，正如一次一密乱码本一样，人们在维护这张口令列表时会遇到麻烦。

为了解决这个问题，可以使用一个口令令牌（password token），这是一种专门的设备，用于产生一个不能预测但可以在接收端通过验证的口令。最简单的口令令牌形式是同步口令令牌，如 RSA Security 公司的 SecurID 设备。这种设备能显示出一个随机数，而且每分钟会产生一个新的随机数。给每个用户一台不同的设备（以保证产生不同的密钥序列），用户读取设备显示的数据，将其作为一个一次性口令输入进去。接收端的计算机执行算法产生适合于当前时刻的口令。如果用户的口令与远程计算得出的口令相符，则该用户就能通过鉴别。由于设备之间可能会出现偏差（比如，一台设备的时钟走得比另一台设备的时钟稍快一点），所以这些设备还需要使用相应的规则来解决时间的漂移问题。

这种方法有什么优缺点呢？首先，它容易使用，因为杜绝了通过偷听重用口令的可能性；由于它采用了一种强口令生成算法，所以也能避免被欺骗。然而，如果丢失了口令生成器，或者遇到更糟糕的情况，口令生成器落入了一名攻击者的手中，系统就会面临危险。由于仅仅每隔一分钟就会产生一个新口令，所以只有一个很小（一分钟）的脆弱性窗口留给窃听者可以重用一个窃听的口令。

2. 质询-响应系统

为了避免丢失和重用问题，一种更为老练的一次一密方案是使用质询-响应方案。质询-响应设备看起来就像一个简单的计算器。用户首先到设备上进行鉴别（通常使用 PIN），远程系统就会发送一个称为“质询”的随机数，用户将其输入设备之中。然后，设备使用另一个数字进行响应，而后用户将其传递给系统。

系统在用户每一次使用时都会用一个新的“质询”来提示用户，因此，使用这种设备消除了用户重用一个时间敏感的鉴别符的弱点。没有 PIN，响应生成器即使落入其他人的手中也是毫无用处的。然而，用户也必须使用响应生成器来登录，而且设备遭到破坏也会造成用户得不到服务。最后，这些设备不能排除远程主机是无赖的可能性。

3. Digital 分布式鉴别

早在 20 世纪 80 年代，Digital Equipment Corporation 就已经意识到需要在一个计算系统中鉴别除人之外的其他实体。例如，一个进程接收了一个用户查询，然后重构它的格式或进行限制，最后提交给一个数据库管理器。数据库管理器和查询处理器都希望能确保它们之间的通信信道是可信任的。这些服务器既不在人的直接控制下运行，也没有人对其进行监控（尽管每一个进程都是由人来启动的）。因此，适用于人的访问控制用在这里是不合适的。

Digital 为这种需求建立了一种简单的结构，能有效防范以下威胁。

- 一个无赖进程假冒其中一台服务器，因为两台服务器都涉及鉴别。
- 窃听或修改服务器之间交换的数据。
- 重放一个以前的鉴别。

在这种结构中，假设每一台服务器都有自己的私有密钥，而且需要建立一个鉴别信道的进程可以获得相应的公钥或已持有该公钥。为了在服务器 A 和服务器 B 之间开始一次鉴别通信，服务器 A 向服务器 B 发送了一个经过服务器 B 的公钥加密的请求。服务器 B 将该请求解密，并使用一条经过服务器 A 的公钥加密的消息作为响应。为了避免重放，服务器 A 和服务器 B 可以附加一个随机数到加密的消息中。

只要服务器 A 和服务器 B 的任一方选择一个加密密钥(用于保密密钥算法),并在鉴别消息中将密钥发送给对方,就可以由此建立起一个私有信道。一旦鉴别完成,所有基于该保密密钥的通信都可以认为是安全的。为了保证信道的保密性,Gasser 设计了一种分离的加密处理器(如智能卡),可以使私钥永远不会暴露在处理器之外。

这种鉴别机制在实现的时候仍然需要解决两个难题:怎样才能发布大量的公钥?这些公钥怎样发布才能确保安全地将一个进程与该密钥进行绑定?Digital 意识到需要一台密钥服务器(也许有若干个类似的服务器)来分发密钥。第二个难题采用证书和证明等级来解决。

协议的其余部分在某种程度上本身就暗示了这两种设计结果。另一种不同的方法是使用 Kerberos,接下来对其进行介绍。

4. Kerberos

Kerberos 是由麻省理工学院设计的系统,支持在分布式系统中实现鉴别。其在最初设计时,采用的是对称密钥加密的工作方式;在最近的版本中,使用公钥技术支持密钥交换。

Kerberos 用于智能进程之间的鉴别,如客户对服务器或者用户工作站对其他主机的鉴别。Kerberos 的思想基础是:中心服务器提供一种称为票据(ticket)的已鉴别令牌,向应用软件提出请求。其中,票据是一种不能伪造、不能重放的加密数据结构可以用来鉴别用户或服务器,其中也包含时间戳和一些控制信息。

Kerberos 通过以下设计来抵御分布式环境中的各种攻击。

- 网络中的无口令通信。
- 加密保护防止欺骗。
- 有限的有效期。
- 时间戳阻止重放攻击。
- 双向鉴别。

Kerberos 不是解决分布式系统安全问题的完美答案,其存在着以下问题。

- Kerberos 要求一台可信任的在线票据授权服务器。
- 服务器的真实性要求在票据授权服务器与每一台服务器之间保持一种信任关系。
- Kerberos 要求实时传输。
- 一个被暗中破坏的工作站可以存储用户口令并在稍后重放该口令。
- 口令猜测仍能奏效。
- Kerberos 不具有可伸缩性。
- Kerberos 是一整套解决方案,不能与其他方案结合使用。

5. WEP

IEEE 802.11 无线标准依赖的加密协议被称为有线等效保密(Wired Equivalent Privacy,WEP)协议。WEP 提供的用户保密性等效于有线专用的保密性,可防止偷听和假冒攻击。WEP 在客户端与无线访问点间使用共享密钥。为了鉴别用户,无线访问点发送一个随机的数字给客户端,客户端使用共享密钥加密,再返回给无线访问点。从这时起,客户端与无线访问点已被鉴别,可使用共享密钥进行通信。

WEP 标准使用 64 位或 128 位密钥。用户以任何方便的方式输入密钥,通常是十六进制数字,或可转换为数字的包含文字和数字的字符串。输入十六进制数的 64 位或 128 位数字要求客户端和访问点选择并正确地输入 16 个或 32 个符号。常见的十六进制字符串如 C0DE

C0DE…。在字典攻击面前，口令是脆弱的。

即使密钥是强壮的，但是在算法中的使用方式还是决定了密钥的有效长度只有 40 位或 104 位。对于 40 位密钥，暴力攻击会很快成功。甚至对于 104 位密钥，RC4 算法中的缺陷及其使用方式也将导致 WEP 安全失效。从 WEPCrack 和 AirSnort 开始，有几个工具帮助攻击者通常能在几分钟内破解 WEP 加密。在 2005 年的一次会议上，美国联邦调查局（Federal Bureau of Investigation，FBI）演示了破解 WEP 安全的无线会话非常容易。

基于这些原因，2001 年，IEEE 开始对无线设计一个新鉴别和加密方案。遗憾的是，一些仍然在市场流通的无线设备仍在使用 WEP。

6. WPA 和 WPA2

替代 WEP 的一项安全技术是 2003 年通过的 WiFi 保护访问（WiFi Protected Access，WPA）。2004 年通过了 WPA2，它是 IEEE 802.11i 标准，是 WPA 的扩展版。WPA 是如何改进 WEP 的呢？

首先，直到用户在客户端和无线访问点输入新的密钥之前，WEP 使用的密钥是不能改变的。因为一个固定的密钥给攻击者提供了大量的密文来进行尝试，并有充足的时间来分析它，所以，加密学家讨厌不改变密钥。WPA 有一种密钥改变方法，其称为暂时密钥集成程序（Temporal Key Integrity Program，TKIP），使用 TKIP 可针对每个包自动改变密钥。

其次，尽管不安全，WEP 仍然使用密钥作为鉴别器。WPA 使用可扩展鉴别协议（Extensible Authentication Protocol，EAP），在这种协议中，口令、令牌、数字证书或其他机制均可用于鉴别。对小型网络（家用网络）用户，可能仍然共享密钥，这还是不理想。用户易于选择弱密钥（如短数字或口令）而遭受字典攻击。

WEP 的加密算法是 RC4，这种算法在密钥长度和设计上有加密缺陷。在 WEP 中，针对 RC4 算法，初始化向量只有 24 位，以至于经常发生碰撞；此外，还不经检查就重用初始化向量。WPA2 增加了 AES 作为可能使用的加密算法（基于兼容性考虑，仍然支持 RC4）。

WEP 包含与数据分开的 32 位完整性检查。但因为 WEP 加密易于遭受密码分析破译法攻击，完整性检查也将遭受攻击，这样，攻击者可能修改内容和相应的检查数据，而不需要知道关联的密钥。WPA 包括 64 位加密的完整性检查。

WPA 和 WPA2 建立的协议比 WEP 建立的更健壮。WPA 协议的建立涉及三个步骤：鉴别、4 次握手（确保客户端可生成加密密钥，在通信的两端，为加密与完整性生成并安装密钥）和可选的组密钥握手（针对组播通信）。WPA 和 WPA2 解决了 WEP 缺乏的安全性。

5.1.2.5 访问控制

鉴别解决安全策略中谁实施访问的问题，而访问控制解决安全策略中如何实施访问及允许访问什么内容的问题。

1. ACL 和路由器

路由器的主要任务是定向网络流量，它们将流量发送到自己所控制的子网，或者发送给其他路由器，以便随后传递到其他子网。路由器将外部 IP 地址转换成本地子网中对应主机的内部 MAC 地址。

假设有一台主机被一台恶意的无赖主机发来的数据包塞满了（被淹没了）。可以配置路由器的访问控制列表（Access Control List，ACL），使其拒绝某些特定主机对另一些特定主机的访问。这样，路由器就可以删除源地址是某台无赖主机的数据包，以及目的地址是某台目标主机的数据包。

然而，这种方法存在着三个问题。首先，一个大型网络中的路由器要完成大量工作：它们必须处理流入和流出网络的每一个包。在路由器中增加一些 ACL 就要求路由器将每一个包与这些 ACL 进行比较。增加一个 ACL 就会降低路由器的性能；增加的 ACL 太多，就会使路由器的性能变得使人不能接受。第二个问题也是一个效率问题：因为路由器要做大量工作，所以它们被设计成仅仅提供一些必需的服务。日志记录工作通常不会在路由器上进行处理，因为需要处理的通信量非常大，如果再记录日志，就会降低性能。然而，对 ACL 而言，日志却是很有用的，从日志中可以知道有多少包被删除了，以及知道一个特定的 ACL 是否可以被删除（以此来提高性能）。但是，由于路由器不提供日志记录服务，所以不可能知道一个 ACL 是否被使用了。这两个问题共同暗示了：路由器上的 ACL 是最有效的防止已知威胁的方法，但却不能不加选择地使用它们。

在路由器上设置 ACL 的最后一个问题是出于对攻击本身的考虑。路由器仅仅查看源和目的地址。攻击者通常不会暴露实际的源地址，暴露真实的源地址无异于银行劫匪在抢劫时留下了家庭住址和一个计划存放赃款地点的说明。

由于在 UDP 数据报中可以很容易地伪造任何源地址，所以许多攻击者都使用有伪造源地址的 UDP 协议实施攻击，以便攻击不会轻易地被一个有 ACL 的路由器所阻止，因为路由器的 ACL 仅仅是在攻击者发送很多使用相同的伪造源地址的数据报时才会有用。

从总体上来说，路由器是一个出色的访问控制点，因为它处理了子网中每一个流入和流出的包。在某些特定环境下（主要指内部子网），可以有效地使用 ACL 来限制某些通信流。例如，只允许某些主机（地址）访问一个内部网络的管理子网。但是如果在大型网络中过滤普通流量，路由器不如防火墙实用。

2. 防火墙

防火墙被设计来完成不适合路由器做的过滤工作。这样，路由器的主要功能是寻址，而防火墙的主要功能是过滤。当然，防火墙也可以做一些审计工作。而且更重要的是，防火墙甚至可以检查一个包的全部内容，包括数据部分。而路由器仅仅关心源和目的 MAC 地址与 IP 地址。

5.2 防 火 墙



防火墙作为网络安全防御体系中的第一道防线，通过一组软、硬件设备，在内部安全网络和外部不安全网络之间构建一道保护屏障，对二者之间的网络数据流量进行控制，阻止对信息资源的非法访问，做到御敌于外。简单地说，防火墙是位于两个或多个网络之间，实施访问控制策略的一组组件。

5.2.1 防火墙概述

1. 什么是防火墙

防火墙（firewall）的本义指古代建造木质结构的房屋时，在房屋周围用坚固的石块堆砌的一道屏障，以防火灾发生时火势的蔓延。在网络安全中，防火墙是位于两个信任程度不同的网络之间（如企业内部网络和 Internet 之间）的软件或硬件设备的组合，如图 5.10 所示。它对两个网络之间的通信进行控制，通过强制实施统一的安全策略，防止对重要信息资源的非法存取和访问以达到保护系统安全的目的。防火墙应用的典型情况是，保护企业内部网络免受外部不安全的因特网的侵害，但也不局限于此，防火墙也可用于内联网各部门网络之间（如某公司

的财务部和市场部之间，即内部防火墙）。

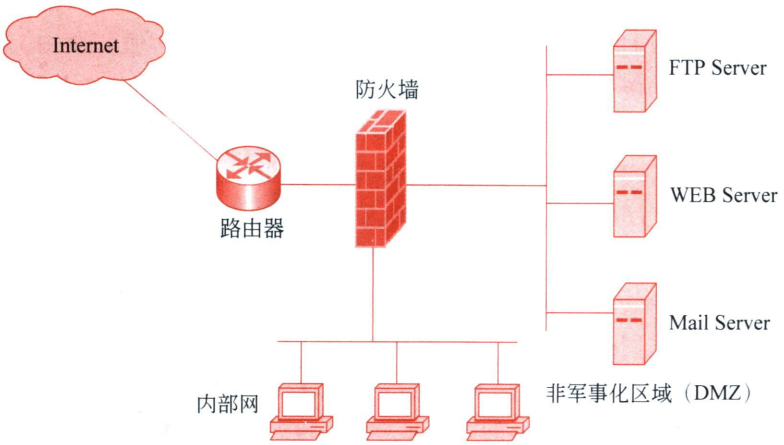


图 5.10 防火墙示意图

一个好的防火墙应该满足如下条件。

（1）内部和外部之间的所有网络数据流必须经过防火墙。

（2）只有符合安全策略的数据流才能通过防火墙。

（3）防火墙本身应对渗透免疫。

（4）使用智能卡、一次口令认证等强认证机制。

（5）人机界面良好，用户配置方便，易管理。

2. 防火墙的作用

防火墙作为内部网与外部网之间的一种访问控制系统，常常安装在内部网和外部网交界的点上。它经常被比喻为网络安全的门卫，对所有进出大门的人员的身份和进出权限进行检查。检查的依据则是防火墙上部署的安全策略，以此建立全方位的防御体系来保护机构的信息资源。如果只部署防火墙系统，而没有全面的安全策略，那么防火墙就形同虚设。防火墙主要通过以下四种手段来执行安全策略和实现网络访问控制。

（1）服务控制：确定可以访问的网络服务类型，可基于 IP 地址和 TCP 端口过滤通信。

（2）方向控制：确定允许通过防火墙的特定服务请求发起的方向。

（3）用户控制：控制访问服务的人员。

（4）行为控制：控制服务的使用方式，如 E-mail 过滤等。

除了网络流量过滤这一主要功能外，防火墙一般还能实现各种网络安全管理的功能，如网络监控审计、支持网络地址翻译（Network Address Translation，NAT）部署、支持 VPN 等。

3. 防火墙的局限性

虽然防火墙可以提高内部网络的安全性，但是，防火墙并非万能，也存在一些缺陷和不足，有些缺陷甚至是目前根本无法解决的。NIST 曾客观地对防火墙做出如下评价。

（1）限制有用的网络服务。防火墙采取的访问控制机制，限制或关闭了很多有用但存在安全缺陷的网络服务，给用户造成不便，这可能会带来传输延迟、性能瓶颈和单点失效。

（2）无法防范来自内部的攻击。由于防火墙最初的设计思想是以本地专用网络的安全为前提，要防范的只是来自外部的可能的攻击，因此不能对内部威胁提供支持，也不能对绕过防火墙的攻击提供保护。

（3）无法防范数据驱动型的攻击。防火墙不能有效地防范数据驱动型的攻击，对病毒传

输的保护能力也很弱，没有对多媒体信息传输包的内容检测，存在潜在的威胁。

(4) 无法防范新的网络安全问题。防火墙是一种被动式的防护手段，只能对现在已知的网络威胁起作用，并不能自动防范网络上不断出现的新的威胁和攻击。

5.2.2 防火墙的类型

根据防火墙的技术特征，常见的防火墙可以分为如下几个类型。

(1) 包过滤(packet filtering)。

(2) 状态包过滤(stateful packet filter)。

(3) 应用层网关/代理(application level gateway/proxy)。

1. 包过滤防火墙

包过滤防火墙是第一代防火墙，它实质上是一个拦截和检查所有通过它的数据包的路由器。它面向网络底层数据流进行审计和管控，主要工作在网络层和传输层，在网络上的逻辑位置如图 5.11 所示。

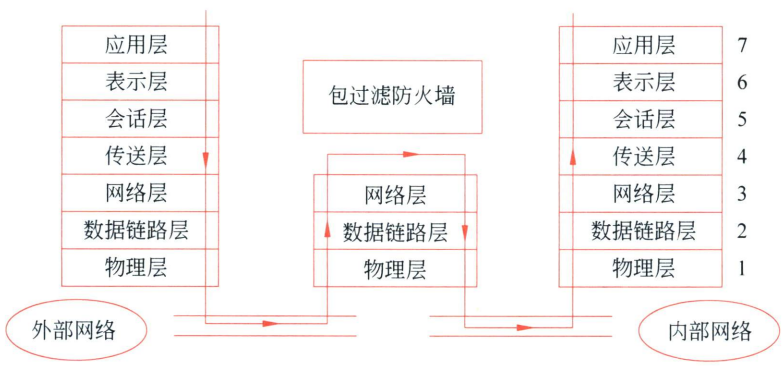


图 5.11 包过滤防火墙的逻辑位置

包过滤防火墙的安全策略是一组预定义的规则，主要根据数据包 IP 头和 TCP 头包含的一些关键信息，来决定是否允许该数据包通过，不合乎规则的数据包将被丢弃。对于 IP 数据包而言，其判断依据有以下几项。

(1) 源 IP 地址、目的 IP 地址。

(2) 数据包的协议类型，如 TCP、UDP、ICMP、IGMP 等。

(3) TCP 或 UDP 的源端口、目的端口。

(4) TCP 标志位，如 ACK、SYN、FIN、RST 等。

(5) IP 分片标志位。

(6) 数据包流向，即 inbound 或 outbound。

(7) 数据包流经的网络接口。

例如，用户可以在包过滤防火墙上制定如表 5.3 所示的过滤规则。

表 5.3 包过滤规则示例

规则	方　向	源 地 址	目 的 地 址	传输层协议	动　作
1	进站	可信外网主机(162.22.34.56)	内网(10.*.*)	HTTP	允许(permit)

续表

规则	方　向	源　地　址	目的地址	传输层协议	动　作
2	出站	内网	可信外网主机（162.*.*）	SMTP	允许(permit)
3	进站/出站	任意	任意	TFTP	拒绝(deny)

其中规则1允许来自外网可信主机162.22.34.56的HTTP数据包；规则2允许内网主机访问外网可信主机上的电子邮件服务；规则3拒绝TFTP和Telnet服务，如图5.12所示。

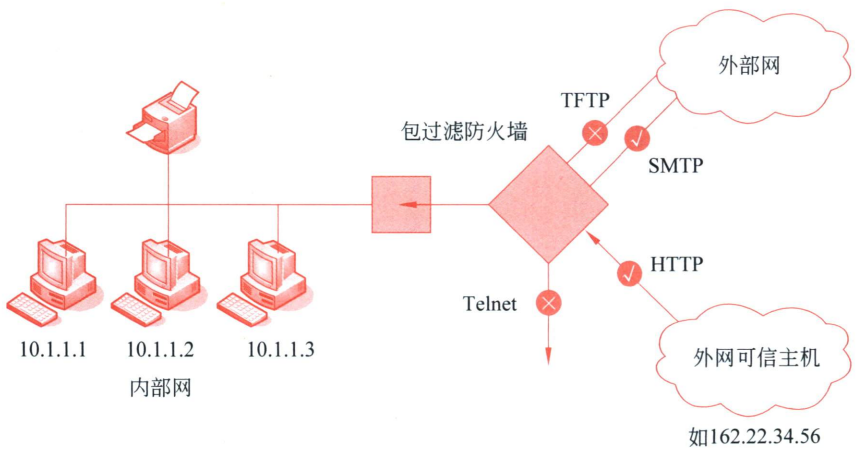


图5.12　包过滤防火墙过滤规则示意图

包过滤防火墙的原理简单，易于理解，但是存在如下缺陷。

(1) 包过滤的规则难以配置。由于要保证逻辑的一致性、封堵端口的有效性和规则集的正确性，一般操作人员难以胜任，也容易出错。而且要实现复杂的过滤，规则集会十分复杂。例如，拒绝所有23号端口(Telnet)的通信量，这很简单而且直接。但如果要允许部分Telnet的流量，则需要对允许通信的IP地址在规则集中逐一进行定义，这样就会导致规则集变得很长。

(2) 包过滤防火墙仅依据包头中几个有限的关键字段进行处理，无法处理内部数据的细节。例如，要允许某些Telnet命令而拒绝其他命令，就超出了包过滤防火墙的处理能力。

(3) 包过滤是无状态的，因为包过滤不能保持与传输相关的状态信息，或与应用相关的状态信息。

(4) 易造成数据驱动型攻击的潜在危险。

2. 状态包过滤防火墙

传统包过滤防火墙每次处理一个包(接受或拒绝)，然后对下一个包进行处理。从一个包到另一个包过渡时，没有“状态”或“上下文”的概念。这种无状态正是传统包过滤防火墙的主要缺陷的原因。若攻击者将一个攻击包分割成多个包，使得每个包具有很短的长度，这样，防火墙就检查不到分布在多个包中的攻击信号。因为在TCP协议下，包可以以任意顺序到达，协议组负责将这些包按照正确的顺序重组后再交给应用层。而状态包过滤防火墙针对传统包过滤进行了功能扩展，它可以通过跟踪包序列和从一个包到另一个包的状态来防止这种攻击。

状态包过滤防火墙采用状态检测包过滤的技术，是一种基于连接的状态检测机制，将属于同一连接的所有包作为一个整体数据流看待，构成连接状态表，通过规则表与状态表的共同配

合，对表中的各个连接状态因素加以识别。这里动态连接状态表中的记录可以是以前的通信信息，也可以是其他相关应用程序的信息。因此，与传统包过滤防火墙的静态过滤规则表相比，它具有更好的灵活性和安全性。

然而，状态检测包过滤技术是根据会话的信息来决定单个数据包是否可以通过，不能实际处理应用层数据，无法彻底识别数据包中大量的垃圾邮件、广告及木马程序等。

3. 应用层代理防火墙

应用层代理防火墙与包过滤技术完全不同，包过滤技术是在网络层拦截所有的信息流，而应用层代理技术是针对每一个特定应用都有一个程序。它的逻辑位置在应用层上，如图 5.13 所示。由于包过滤防火墙仅看包头不看包的内部数据，因此若过滤规则允许入站连接到 25 号端口，那么包过滤防火墙会将任何包传递到该端口。但是某些应用软件（如电子邮件转发代理）常常代表所有用户，从而要求赋予它们所有用户的特权（如存储进入的邮件信息供内部用户阅读等），从而存在许多潜在的安全威胁。

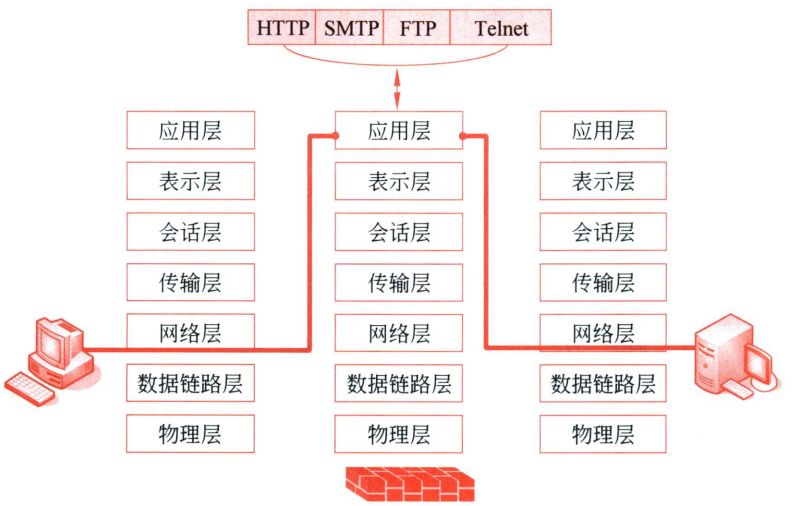


图 5.13 应用层代理防火墙的逻辑位置

而应用层代理防火墙能彻底隔断内部网与外部网的直接通信，内部网对外部网的访问变成防火墙对外部网的访问，而外部网返回的信息再由防火墙转发给内网用户。所有通信都必须经应用层代理转发，访问者任何时候都不能与外部服务器建立直接的 TCP 连接，应用层的协议会话过程必须符合代理的安全策略要求。其工作原理如图 5.14 所示，当代理服务器接收到客户的请求后，会检查用户请求是否符合相关安全策略的要求，如果符合，代理服务器会代表客户去服务器那里取回所需信息，再转发给客户。



图 5.14 应用层代理防火墙的工作原理

目前常见到的应用层代理防火墙产品有商业版代理（cache）服务器、开源防火墙软件 TIS FWTK（firewall toolkit）、Apache 和 Squid 等。

应用层代理网关加强了防火墙的安全性，隔断了内网与外网的直接通信，避免了数据驱动型攻击的发生，但也存在以下较严重的缺陷。

（1）代理是不透明的，用户可能需要改造网络的结构甚至应用系统，在访问代理服务的每个系统上安装特殊的软件。

（2）为了应付大量的网络连接并还原到应用层，防火墙额外的处理负载大幅攀升，从而影响性能，处理速度比包过滤防火墙要慢，甚至成为网络瓶颈。

（3）对每一个应用，都需要一个专门的代理来解释应用层命令的功能，如解释 FTP、Telnet 等命令就需要专门的 FTP 代理服务器、Telnet 代理服务器等，灵活性不够。

（4）在面临应用升级或出现新的应用层协议时，代理服务程序也需要随之改变。

4. 网络地址转换技术

目前的防火墙产品都提供了网络地址转换（Network Address Translation，NAT）技术，主要用在以下两方面。

（1）隐藏和保护内部网络的 IP 地址。

（2）解决 IP 地址不足的问题，将内部网络私有 IP 地址翻译为公用地址（合法 IP 地址）。

实际上，NAT 就是把内部网络中的 IP 包头内的内部 IP 地址信息，用可以访问外部网络的公用 IP 地址信息替换，如图 5.15 所示。公用地址是由 Internet 网络信息（InterNIC）分配的 IP 地址，要想在 Internet 上实现通信，就必须有一个公用地址。

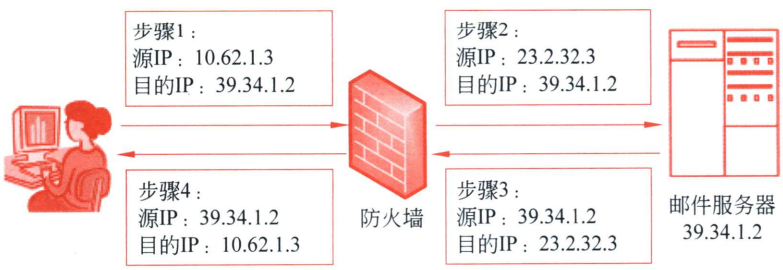


图 5.15 NAT 示意图

根据 NAT 的工作方式，可以将其分为静态 NAT、动态 NAT 和端口地址转换（Port Address Translation，PAT）。静态 NAT 中，IP 地址映射是一对一的，将某个私有 IP 地址转换为特定的某个公用 IP 地址，如图 5.16 所示。动态 NAT 中，将内部网络的私有 IP 地址转换为公用地址时，是随机地从预先配置的地址池中选取一个。端口地址转换是把内部地址映射到外部网络的一个公用 IP 地址的不同端口上。

5. 个人防火墙

个人防火墙（personal firewall）运行在它所要保护的计算机上，用来隔离用户不希望的、来自网络的通信量。个人防火墙是常规防火墙功能的补充，可以针对单台主机设置可接受的数据类型，或者在连接互联网时，用来弥补常规防火墙中缺少的过滤规则。现有商业个人防火墙包括天网个人防火墙、Norton 个人防火墙、McAfee 个人防火墙、瑞星个人防火墙和 Zone Alarm 等。

与网络防火墙过滤进出网络的通信量类似，个人防火墙过滤单个工作站的通信量。工作站对恶意代码或恶意活动代理（ActiveX 或 Java Applet）、存储在工作站上的个人数据泄露、为寻找潜在弱点的弱点扫描等攻击方式的防御能力差。个人防火墙经过配置后可以实施一些安全策略。例如，用户可以确定某些网址（如公司内部网中的计算机）具有很高的可信度，而其他站点则不可信赖；用户可以定义相应的策略，以便允许在本公司所在网段实现代码下载、无限制的数据共享及管理访问，而不允许来自其他站点的访问。

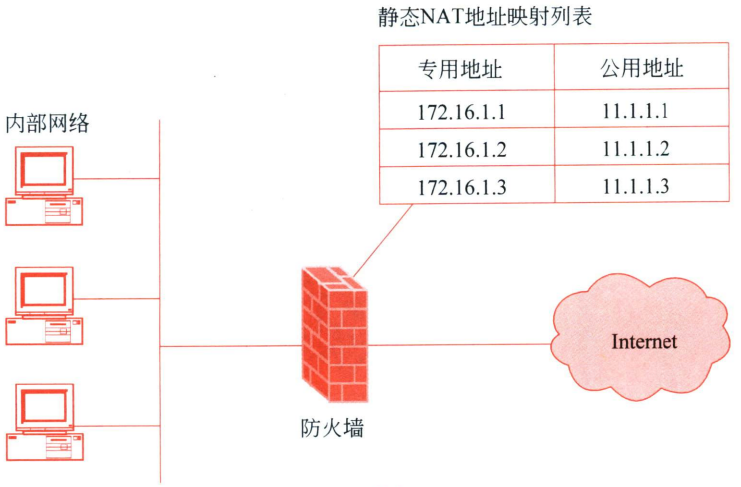


图 5.16 静态 NAT

把病毒扫描器和个人防火墙结合在一起使用不但有效，而且效率高。用户并不是每天运行病毒扫描器，而是偶尔运行，而且此时病毒扫描器在用户内存中执行时，检查到的问题是在既成事实之后(病毒已随电子邮件附件下载到本地之后)。但如果将病毒扫描器和个人防火墙结合起来，个人防火墙就会对所有进入的电子邮件中未打开的附件进行事先的检查。

6. 几种类型防火墙的比较

表 5.4 对几种类型防火墙的不同之处进行了概括。

表 5.4 不同类型防火墙的比较

包过滤防火墙	状态包过滤防火墙	应用层代理防火墙	个人防火墙
最简单	较复杂	更复杂	与包过滤器防火墙相似
只看见地址和服务协议类型	能看见地址和数据	看见包的全部数据部分	看见包的全部数据部分
审计困难	可能审计	能审计活动	能审计活动，并通常实现了审计活动
基于连接规则的过滤	基于通过包的信息过滤——首部或数据段	基于代理的行为过滤	基于单个包中的信息(使用首部或数据)过滤
复杂的寻址规则使得配置困难	通常预先配置以检测攻击信号	简单的代理可以代替复杂的寻址规则	通常以“拒绝所有入站”模式开始，当它们出现时，可添加信任地址

5.2.3 防火墙体系结构

在一个网络系统中，防火墙可能是单个的主机系统，但更多的是多个设备组成的一个安全防护系统，其体系结构可能多种多样。防火墙体系结构的设计需要根据业务和安全控制的需求，合理规划内部网络的拓扑结构，合理划分安全区域，恰当地部署防火墙。从本质上讲，现有的防火墙体系结构主要有：双宿网关、屏蔽主机、屏蔽子网、多防火墙等。

1. 双宿网关

双宿网关(dual-homed gateway)的基本结构如图 5.17 所示，它拥有两个连接到不同网络上的网络接口。例如，一个连接外部不可信任的网络，另一个连接内部可信任的网络。这种体系结构最大的优点是 IP 层的通信是被阻止的，两个网络之间的通信可通过应用层代理服务的

方法实现。双宿主机是唯一的隔开内部网络和外部网络之间的屏障，所以其用户口令控制是安全的关键，应配备强大的身份认证系统以阻挡外部不可信网络的非法登录。

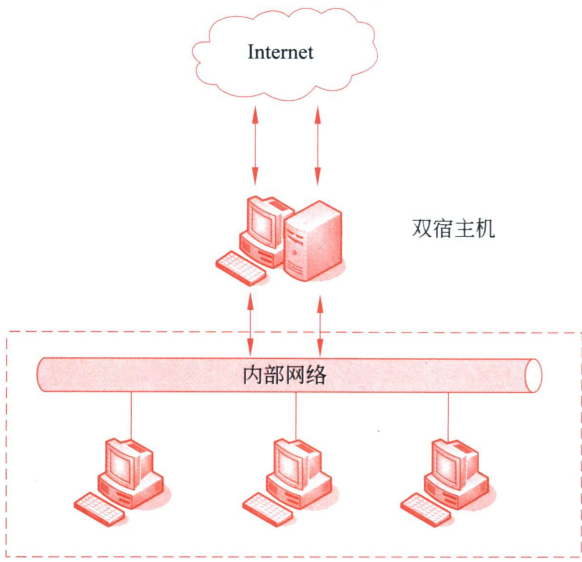


图 5.17　双宿网关体系结构

2. 屏蔽主机

屏蔽主机防火墙强迫所有的外部主机与一个堡垒主机相连，而不让它们直接与内部主机相连，其体系结构如图 5.18 所示，由包过滤路由器和堡垒主机组成。包过滤路由器配置在内部网和外部网之间，保证外部系统对内部网络的操作只能经过堡垒主机。入侵者要破坏内部网络，需要首先渗透这两种不同的安全系统，因此屏蔽主机防火墙实现了更高的安全性。堡垒主机配置在内部网络上，是外部网络主机连接到内部网络主机的桥梁，因此它需要拥有高等级的安全。

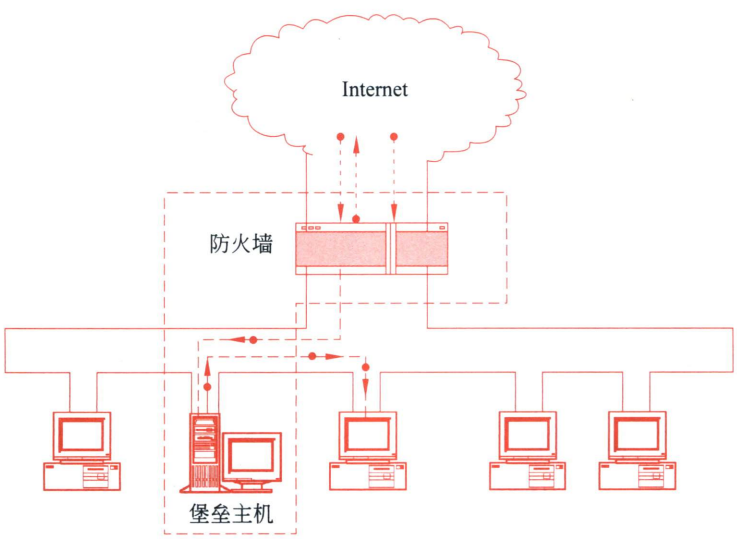


图 5.18　屏蔽主机体系结构

3. 屏蔽子网

屏蔽子网体系结构是目前很多机构采用的体系结构，其在本质上与屏蔽主机体系结构一

样，但添加了额外的一层保护体系——周边网络，或者称为非军事化区域(Demilitarized Zone，DMZ)，如图 5.19 所示。堡垒主机位于周边网络上，周边网络和内部网络被内部路由器分开。DMZ 存在的好处是，通过周边网络隔离堡垒主机，减少堡垒主机被侵入的影响，保护内部网络。入侵者即使控制了堡垒主机，也只能侦听到周边网络的数据，而不能侦听到内部网络的数据。

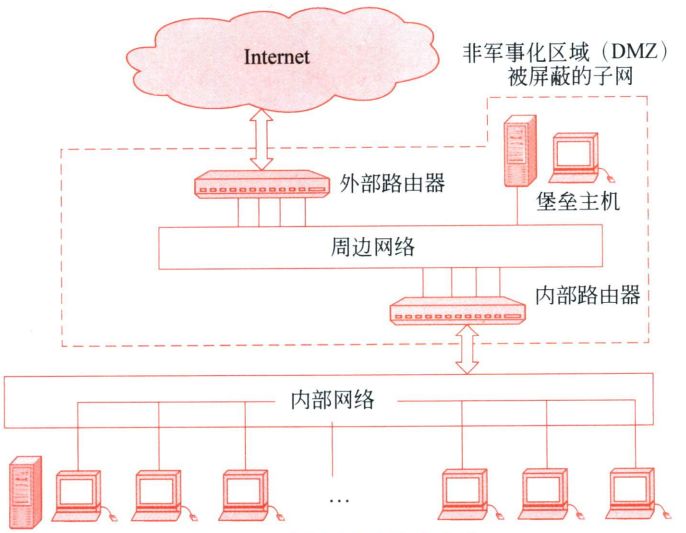


图 5.19 屏蔽子网体系结构

5.2.4 防火墙部署与配置案例

【例 5-1】 针对 H 市中小企业服务平台建设的实际需求，可以采用图 5.20 所示的防火墙部署方案。

(1) 采用屏蔽子网体系结构，设置非军事化区域(DMZ)。

(2) 平台内部网络划分部门子网，包括普通员工子网、服务和运维部门子网、管理和财务部门子网，并为不同的用户设置不同的 Internet 访问权限，可以控制用户不同时段的 Internet 访问权限，合理分配网络资源。

(3) 对平台重要部门，如管理部门和财务部门，进行单独划分区域地址组，配置内部防火墙，添加策略只有授权用户才能访问，不能被其他未授权部门的员工计算机访问，更不能被互联网访问操作。

可采取如下配置策略。

(1) 中小企业服务平台 Web 服务器部署在 DMZ，可以对外发布新闻、公文、通知、公告、政策等信息，与各区县各企业进行信息互通互联。

(2) 财务部门为了防止不安全因素的侵入，可以配置成只允许收发邮件、访问某些财务网站或网银目的地，并且使用 MSN 等通信工具。

(3) 服务部门可以定向访问内网服务器，并使用 QQ、MSN 等通信软件与用户交流，满足 H 市与县区和企业间在线沟通的需要。

(4) 管理部门由于业务需要获取信息的优先级比较高，可以纵览全局，允许各种上网请求。

(5) 普通员工在上班时间限制使用 MSN、QQ 等通信工具，以及迅雷等多线程高速下载工具，防止有些员工大量占用公司网络带宽下载非工作私人流量而导致的网络卡、慢，使企业员

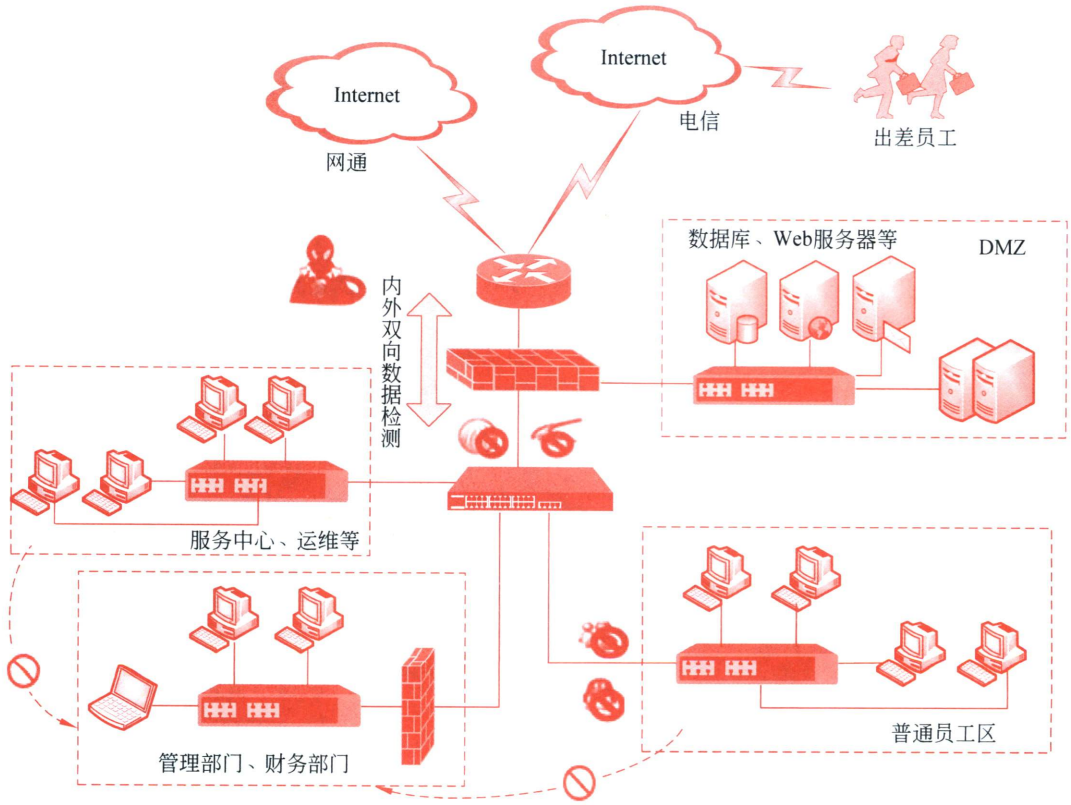


图 5.20 H市中小企业服务平台防火墙体系结构

工上班时间不受干扰，高效工作；下班时间，可以放开上述上网限制。

（6）出差员工可以在计算机或移动终端设备上，利用虚拟专用网，通过电信或网通等运营商提供的网络，方便接入单位内部网络，使用内部资源进行网上远程办公，在移动终端设备上查阅、签批文件和事务。

netfilter/iptables组合是目前Linux开源操作系统中普遍使用的防火墙技术解决方案，利用它可以实现上述安全策略的配置。netfilter是Linux内核中实现的防火墙功能模块，实现了静态包过滤和状态报文检查（即动态包过滤）等基本防火墙功能，此外也支持NAT共享上网、利用NAT构建透明代理、构建QoS或策略路由器等其他功能，并提供了多层API接口以支持第三方扩展。iptables则是应用层的防火墙管理工具，是netfilter框架下定义的一个包过滤子系统，用户通过命令配置规则，可以对进出计算机的数据包进行过滤。

iptables的所有命令都是以iptables开头，其总体的命令结构如下：

```
iptables [-t table] command [match] [target/jump]
```

（1）表（table）。“表”是包含仅处理特定类型信息包的规则和链的信息包过滤表。iptables包含三个最基本的规则表，分别是用于包过滤处理的filter表、用于网络地址转换处理的nat表，以及用于特殊目的数据包修改的mangle表。[-t table]选项表示当前的策略属于哪个表。在缺省情况下，filter作为默认表，因为iptables的主要工作是过滤进出本地网络适配器的数据包，如果是mangle表或nat表则需要注明。各表实现的功能如表5.5所示。

表 5.5 iptables 表功能

表名	实现功能
filter	默认的表，包含内建的链 INPUT(处理进入的包)、FORWORD(处理通过的包)和 OUTPUT(处理本地生成的包)
nat	这个表被查询时表示遇到了产生新的连接的包，由三个内建的链构成：PREROUTING(修改到来的包)、OUTPUT(修改路由之前本地的包)、POSTROUTING(修改准备出去的包)
mangle	用于对指定的包进行修改。它有两个内建规则：PREROUTING(修改路由之前进入的包)和 OUTPUT(修改路由之前本地的包)

(2) 命令(command)。命令部分是 iptables 最重要的部分，它指定 iptables 对提交的规则要做什么样的操作，iptables 常用的命令参数如表 5.6 所示。

表 5.6 iptables 命令参数

参 数	解 释	范 例
-A 或 -append	在所选链末尾添加一条或多条规则	iptables -A INPUT
-D 或 -delete	从所选的链中删除规则，可以用编号表示被删除的规则，也可以用整条规则来匹配策略	iptables -D INPUT 8
		iptables -D FORWARD -p tcp -s 192.168.1.12 -j ACCEPT
-R 或 -replace	从选中的链中取代一条规则	iptables -R FORWARD 2 -p tcp -s 192.168.1.0 -j ACCEPT
-I 或 -insert	根据给出的规则序号向所选链中插入一条或更多规则	iptables -I FORWARD 2 -p tcp -s 192.168.1.0 -j ACCEPT
-L 或 -list	列出所选链的所有策略	iptables -t nat -L
		iptables -L INPUT
-F 或 -flush	清空所选的链的配置规则	iptables -F
		iptables -t nat -F
-N 或 -new-chain	添加新的链，如 ACCEPT、DROP、REJECT、LOG、REDIRECT 等	iptables -N tcp_allowed
-X 或 -delete-chain	删除指定的用户自定义链	iptables -X tcp_allowed
-P 或 -pollicy	设置链的目标规则	iptables -P INPUT DROP

(3) 匹配(match)。iptables 的可选匹配部分指定信息包与规则匹配所应具有的特征，如源地址、目的地址、协议等。匹配分为通用匹配和特定协议(TCP、UDP、ICMP 等)的匹配两大类。表 5.7 是一些重要且常用的通用匹配。

表 5.7 iptables 常用匹配参数表

参 数	解 释
-p 或-protocol	规则或包检查(待检查包)的协议。指定协议可以是 TCP、UDP、ICMP 中的一个或全部
-s 或-source	指定源地址，可以是主机名、网络名和清楚的 IP 地址
-d 或-destination	指定目标地址

续表

参　数	解　释
-j 或-jump	目标跳转
-i 或-in-interface	进入的(网络)接口
-o 或-out-interface	输出接口“[名称]”

(4) 目标(target)添加规则。目标是由规则指定的操作，对于那些规则匹配的信息包执行这些操作。表 5.8 是常用的一些目标及示例说明。除了允许用户定义的目标外，还有许多可用的目标选项。

表 5.8　iptables 目标参数表

参　数	解　释
ACCEPT	允许数据包通过
DROP	将数据包丢弃
QUEUE	把数据包传递到用户空间
RETURN	停止这条链的匹配，到前一个链的规则重新开始

iptables 的更多参数信息，可以用命令 man iptables 获取。iptables 在实际应用中的常用规则举例如下。

(1) 查看规则集：

```
[root@localhost ~]# iptables -list
```

(2) 清除预设表 filter 中的所有规则链的规则：

```
[root@localhost ~]# iptables -F
```

(3) 对于数据中心、财务部门等安全级别要求较高的区域，可以采用默认拒绝策略，即采用白名单机制，默认拒绝所有访问行为，然后再通过配置防火墙安全访问控制策略为用户打通访问链路。为每一个链设置默认拒绝的规则：

```
[root@localhost ~]# iptables -P INPUT DROP
[root@localhost ~]# iptables -P OUTPUT ACCEPT
[root@localhost ~]# iptables -P FORWARD DROP
```

(4) 来自内部网络的封包可以直接放行：

```
[root@localhost ~]# iptables -A INPUT -s 172.16.0.0/24 -j ACCEPT
[root@localhost ~]# iptables -A INPUT -s 192.168.0.254 -j ACCEPT
```

(5) 允许远程 SSH 登录，开启 22 端口：

```
[root@localhost~]# iptables -A INPUT -p tcp --dport 22 -j ACCEPT
```

(6) 允许内部网络访问外部网络的 Web 服务器，开启 80～83 端口：

```
[root@localhost~]# iptables -A FORWARD -o eth0 -p tcp -s 172.16.0.0/24 --sport
1024:65535 --dport 80:83 -j ACCEPT
[root@localhost~]# iptables -A FORWARD -i eth0 -p tcp --syn --sport 80:83 -d 172.
16.0.0/24 --dport 1024:65535 -j ACCEPT
```

(7) 设置 E-mail 服务,可接收电子邮件,使用 SMTP 的 25 端口:

```
[root@localhost~]# iptables -A FORWARD -i eth0 -p tcp --sport 1024:65535 -d 172.
16.0.0/24 --dport 25 -j ACCEPT
[root@localhost~]# iptables -A FORWARD -o eth0 -p tcp --syn -s 172.16.0.0/24 --
sport 25 --dport 1024:65535 -j ACCEPT
```

(8) 开放内部网络可以对外部网络的 POP3 Server 取信件:

```
[root@localhost~]# iptables -A FORWARD -o eth0 -p tcp -s 172.16.0.0/24 --sport
1024:65535 --dport 110 -j ACCEPT
[root@localhost~]# iptables -A FORWARD -i eth0 -p tcp --syn --sport 110 -d 172.16.
0.0/24 --dport 1024:65535 -j ACCEPT
```

5.3 入侵检测系统

5.3.1 IDS 概述

入侵检测系统(Intrusion Detection System,IDS)是一种设备,通常是另一台独立的计算机,通过监视内部的活动来识别恶意的或可疑的事件。IDS 是一种探测器,像烟雾探测器一样,如果发生了指定的事件就会触发警报。入侵检测系统采用实时(或近似实时)运行方式,监视活动并及时向管理员报警,以便采取保护措施。

IDS 是对网络安全极好的补充。防火墙能封锁到达特定端口或地址的通信量,并限制使用某些协议来降低其影响。但根据定义,防火墙必须允许一些通信量进入一个受保护区域。监视通信量在受保护区域内的真实活动便是 IDS 的工作。IDS 能实现以下多种功能。

(1) 监视用户和系统活动。

(2) 审计系统配置中存在的弱点和错误配置。

(3) 评估关键系统和数据文件的完整性。

(4) 识别系统活动中存在的已知攻击模式。

(5) 通过统计分析识别不正常活动。

(6) 管理审计跟踪,当用户违反策略或正常活动时,给出警示。

(7) 纠正系统配置错误。

(8) 安装、运行陷阱以记录入侵者的相关信息。

但没有一个 IDS 能实现上述所有功能。在理想情况下,IDS 应该快速、简单、准确,同时也应该相当完善。它应该能以极小的性能代价检测出所有的攻击。一个 IDS 中可能会使用下面所列的部分或全部设计方法。

(1) 在包头上进行过滤。

(2) 在包内容上进行过滤。

(3) 维护连接状态。

（4）使用复杂的多包标记。

（5）使用最少的标记产生最大的效果。

（6）实时、在线过滤。

（7）隐藏自己。

（8）使用优化的滑动时间窗口大小来匹配标记。

1. 警报响应

不论哪种入侵检测系统都应在发现入侵时报警。警报的范围包含从普通到重大的所有事件，如写审计日志的注释、记录系统安全管理员操作等。一些特别设计的入侵检测系统还允许用户决定系统对什么样的事件采取什么样的措施。

哪些是可能的响应呢？其范围是无限的，可以是管理员（和程序）能想到的任何事情。一般情况下，响应主要分为如下三类（三类响应可部分或全部应用到单个响应中）。

（1）用监视器收集数据，可能会在必要时增加收集数据的总量。

（2）保护，采取行动减少暴露。

（3）向人报警。

对具有一般（最初的）影响的攻击，采用监视器比较恰当。监视器的真正目标在于观察入侵者，看他访问了哪些资源或者试图进行什么样的攻击。另一种可能使用监视器的情况是记录来自给定源地址的所有通信量，用于以后分析。监视器对攻击者应是不可见的。保护意味着增加访问控制措施，甚至使得一个资源不可用（比如，关闭一个网络连接或使一个文件不能访问）。系统甚至可能切断攻击者正在使用的网络连接。与监视器相反，保护对攻击者常常是可见的。最后，向人报警类型的入侵检测系统允许个人进行辨别，IDS能立即采取初步的防御措施，同时也向人报警，人也许会花几秒钟、几分钟甚至更长的时间进行响应。

2. 错误结果

入侵检测系统并不是完美无缺的，其最大的问题是出现错误。虽然IDS大多数情况下能正确检测到入侵者，但也可能会犯两种不同类型的错误：一种是对非真正攻击报警（误报），另一种是对真正的攻击不报警（漏报）。太多的误报意味着管理员将降低对IDS报警的信任，有可能导致真正的报警被忽略。但漏报意味着真正的攻击通过IDS而没有采取措施。误报和漏报的程度代表了系统的敏感性。所以绝大多数IDS允许管理员调整系统的敏感性，以便在误报和漏报之间取得可接受的平衡。

5.3.2 IDS的类型

常用的入侵检测系统是基于签名的IDS和启发式IDS。基于签名（signature-based）的入侵检测系统实现简单的模式匹配，并报告与已知攻击类型的模式匹配情况。启发式（heuristic）入侵检测系统（又称基于异常的入侵检测系统）建立了一个可接受行为模型，并对该模型的出错情况做上标记；在以后使用时，管理员可以将带标记的行为作为可接受的行为，以便启发式IDS把以前未分类的行为作为可接受的行为进行处理。

入侵检测设备可以是基于网络的或是基于主机的。基于网络（network-based）的IDS是附加在网络上的一台单独的设备，监视经过该网络的通信量；基于主机（host-based）的IDS运行在单个工作站、客户端或主机上，用于保护该主机。

1. 基于标记的入侵检测

对一种已知的攻击类型做简单的标记可描述以下情况：一系列的TCP SYN包被连续发往

许多不同的端口，而且有时彼此很接近，这是端口扫描时会发生的情况。入侵检测系统可能不会发现第一个 SYN 包（如发往 80 端口）中有什么异常情况，然后另一个到 25 端口的包（从相同的源地址发来的）也是如此。但是，随着越来越多的端口收到 SYN 包，尤其在一些没有开放的端口也收到了 SYN 包，这种模式反映了可能有人在进行端口扫描。同样，如果收到数据长度为 65 535 字节的 ICMP 包，表明某些协议栈的实现出现了故障，这样的包就是一种需要观察的模式。

基于标记的入侵检测中存在的问题就是标记本身。攻击者会对一种基本的攻击方式加以修改，使之与这种攻击的已知标记不匹配。例如，攻击者可以把小写字母转换为大写字母，或者把符号（如空格）转换为其等价的字符代码“%20”。这样，为了识别“%20”与空格匹配，IDS 必须对数据流的规范形式进行必要的处理。攻击者也可能插入一些 IDS 会看到的、格式错误的包，故意引起模式不匹配，协议处理栈会因为其格式不对而丢弃这些包。这些变化都可以被 IDS 检测到，只是更多的标记要求 IDS 做更多的附加工作，这会降低系统的性能。

当然，基于标记的入侵检测因为标记还没有安装在数据库而不能检测一种新的攻击。在每种攻击类型刚开始时，由于是一种新模式，IDS 是无法对这类攻击发出警告的。

基于标记的入侵检测趋向于使用统计分析方法，通过使用统计工具可得到关键指标的测量样本（如外部活动总量、活动进程数、事务数等），也可决定收集测量数据是否适合预先确定攻击标记。

理想的标记应该匹配每一种攻击实例，匹配攻击的微妙变化，而不会匹配不是攻击部分的通信量。然而，这个目标遥不可及。

2. 启发式入侵检测

由于标记受到特定的、已知的攻击模式的限制，使得另一种形式的入侵检测有了用武之地。启发式入侵检测寻找的是异常的举动，而不是寻求匹配。其初期工作是关注个人的行为，试图发现有助于理解正常和异常行为的个人特征。例如，某个用户可能总是以阅读电子邮件开始一天的工作，使用文字处理器编写大量的文档，偶尔备份一下文件，这是一些正常活动。该用户看起来很少使用管理员的系统功能，如果这个人试图访问敏感的系统管理功能，这一新的行为可能暗示着其他人正在以该用户的身份活动。

如果考虑正在使用的是有安全隐患的系统，它开始是“干净的”，没有被入侵，后来则变“脏”了，完全处于危险之中。在系统从“干净”变“脏”的过程中，没有使用行为跟踪点，系统很可能是在开始时只稍微有点“脏”事件发生，甚至是偶然的，然后，随着“脏”事件逐渐增加，系统逐渐陷入更深的危险之中。这些事件中的任何一个可能被接受，如果只累积计算，这些事件发生的顺序、速度可能就是一种信号，它表明有不能被接受的事件发生了。入侵检测系统的推理引擎可以持续分析系统，当系统“脏”事件超过了阈值后，系统就会发出警告。

推理引擎有两种工作方式。一种是基于状态的入侵检测系统查看系统审查所有被修改的状态或配置。当系统转向不安全模式时，它们就尝试进行入侵检测。其他时候，则尝试将当前的活动与不可接受活动的模式进行比较，当两者相似时，则发出警告。另一种是入侵检测根据已知不良活动模型开始工作。例如，除使用少量的系统功能（注册、修改口令、创建用户）之外，任何其他访问口令文件的企图都是可疑的。在这种入侵检测方式中，会将实际的活动与已知的可疑范围进行比较。

所有的启发式入侵检测都将行为归纳为以下三类：好的/良好的、可疑的和未知的。随着时间的推移，IDS 会逐步学习某种行为是否可接受。根据学习的结果，特定的行为可以从一种类型转换成另一种类型。

与模式匹配一样，启发式入侵检测受到以下限制：系统所能见到的信息量非常大（如何将行为正确归类）；当前行为与某一类型的匹配程度如何。

3. 秘密模式

IDS是一种网络设备（在基于主机的IDS中，是运行在网络设备上的一个程序）。面对网络攻击，任何一种网络设备都有其潜在的弱点。如果IDS自身被拒绝服务攻击所淹没，它还会有用吗？如果攻击者成功登录被保护网络中的系统，难道他下一步不会设法禁止IDS吗？

为解决这些问题，大多数IDS都运行在秘密模式（stealth mode）下，所以，IDS有两个网络接口：一个用于正在被监视的网络或网段，另一个用于产生报警和其他可能的管理需求。IDS把被监视的接口仅作为输入使用，决不通过此接口往外发送包。通常，为这个设备的该接口配置不公开的地址。这样，路由器不能直接路由任何信息到这个地址，因为路由器不知道有这个设备的存在。这是完美的被动窃听，如果IDS需要产生一个警报，它只在完全隔离的控制网络上使用警报接口即可，这种结构如图5.21所示。

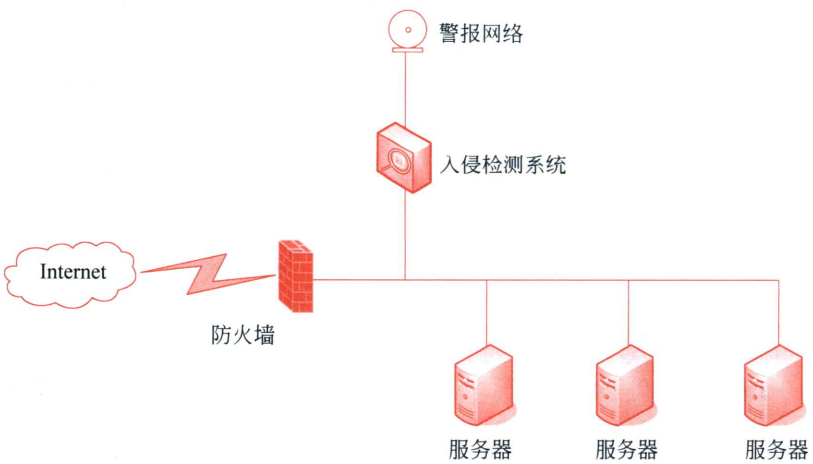


图5.21 与两个网络相连的秘密模式IDS

4. 其他IDS类型

一些安全工程师也在考虑使用其他设备作为IDS。例如，要检测不可接受的修改代码的行为，通过程序来比较软件代码的活动版本和代码摘要的存储版本就能够实现。Tripwire程序是最著名的软件（或静态数据）比较程序。用户可以在一个新系统上运行Tripwire，它会为每一个文件产生一个Hash值，然后可以在一个安全的地方存储这些Hash值（离线存储，以便在修改一个系统文件时没有入侵者能修改它们）。如果用户怀疑系统遭到了破坏，重新运行Tripwire，并提供已存储的Hash值。Tripwire会重新计算这些Hash值并对任何不匹配的情况进行报告，这些不匹配情况能指出被修改的文件。

系统弱点扫描器（如ISS Scanner或Nessus）可以针对网络运行，它们能够检测已知的弱点并报告所发现的缺陷。

“蜜罐”是一种故意诱惑攻击者的人为环境。它可以记录入侵者的行为，甚至试图通过对行为、包数据或者连接的跟踪来努力识别攻击者。从这种意义上来说，蜜罐可以看作一种IDS。

5.3.3 IDS配置案例

目前的入侵检测产品中，Cisco的NetRanger、ISS的RealSecure都采用的是误用检测的

方法，AT&T 的 Computer Watch、NAI 的 CyberCop 则是基于异常检测技术。SRI 的 IDES、NIDES 及 Securenet Corp 的 Securenet 同时采用了以上两种技术。

Snort 是一款非常著名的开源网络入侵检测系统，具有实时数据流量分析和日志 IP 网络数据包的能力；能够进行协议分析，对内容进行搜索匹配；能够检测各种不同的攻击方式，对攻击进行实时报警。Snort 在网络安全界多年来积累的流行度和影响力，使其成为网络入侵检测系统的事实标准，其特征库规则被广泛接受，并成为网络安全专家编写和发布针对最新攻击行为规则检测的通用格式，各种商业网络入侵检测产品基本上也会对 Snort 格式的攻击规则库进行支持。Snort 采用了标准的捕获数据包函数库 libpcap，具有非常好的可移植性。目前，Snort 可以在包括 x86、SPARC、PowerPC、Alpha 等指令集平台架构上的 Linux、Windows、MAC OS 及各种 UNIX 操作系统上运行。

Snort 入侵检测系统的基本架构如图 5.22 所示。

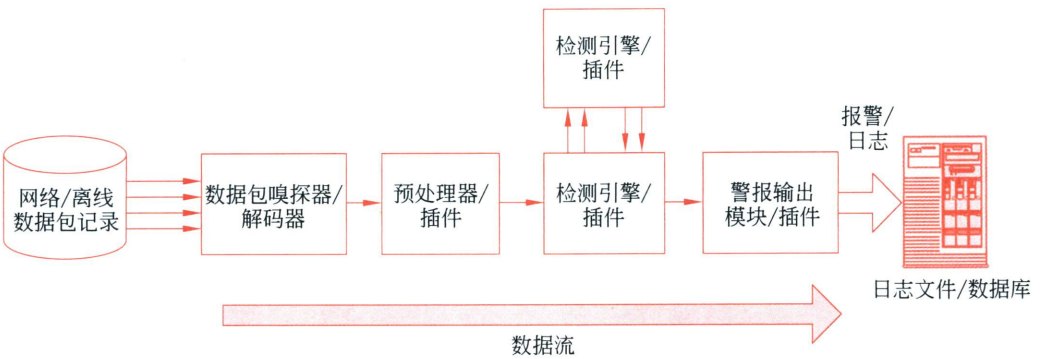


图 5.22 Snort 入侵检测系统的基本架构

Snort 入侵检测系统主要由以下 4 个基本部分组成。

(1) 数据包嗅探器/解码器(sniffer)。数据包嗅探器是一个并联在网络中的设备(可以是硬件，也可以是软件)，它的工作原理和电话窃听很相似，不同的是电话窃听的是语音网络而数据包嗅探的是数据网。Snort 主要通过两种机制实现捕获数据的需要：将网卡设置为混杂模式；利用 libcap/winpcap 从网卡上捕获数据。在 IP 数据包中包含了不同类型的协议，如 TCP、UDP、ICMP、IPSec 和路由协议等，因此很多数据包嗅探器还会做协议分析，并把分析结构展现出来。

(2) 预处理器/插件(preprocessor)。预处理器的主要作用就是针对捕获的数据进行预处理。预处理器用相应的插件检查原始的数据包，这些插件分析数据包，从中发现这些数据的“行为”——原始数据的应用层表现是什么。Snort 预处理器包括三种类型的插件：TCP/IP 协议栈模拟、应用层协议解码与规范化、异常检测。

(3) 检测引擎/插件(detection engine)。检测引擎是 Snort 的核心模块。当数据包从预处理器里送过来后，检测引擎依据预先设置的规则检查数据包，一旦发现数据包的内容和某条规则相匹配，就会通知报警模块。Snort 采用的检测技术是误用检测，也称为基于特征规则的检测，它的实现依赖于各种不同的规则设置，检测引擎依据规则来匹配数据包。Snort 的规则很多，并根据不同类型(木马、缓冲区溢出、权限溢出等)做了分组，规则要经常升级。

Snort 的攻击特征规则集是基于文本的，通常存在于 Snort 的 etc/rules 目录下，规则文件按照不同的攻击类型进行了分类。比如，文件 ftp.rules 包含了针对 FTP 服务的攻击特征规则。Snort 的规则集描述了已知网络攻击的检测特征，而检测引擎就是根据这些规则，采用特

征检测方法来检查当前数据包/连接是否满足已知攻击特征，从而检测出入侵行为。Snort 规则集文件由 Sourcefire 公司负责维护和更新，并在 http://www.snort.org/vrt/发布，每日更新的规则集版本需要购买 Sourcefire 公司的商业付费服务，但普通用户可以免费获得随 Snort 发布的规则集。

(4) 警报输出模块/插件(output modules)。如果检测引擎中的某条规则被匹配，或者预处理器中检测到一些异常和攻击时，就会触发一条报警，输出模块可以将报警信息通过网络 syslog、UNIX Sockets、Windows Popup 或 SNMP 协议的 trap 命令等多种方式发送给日志文件，也可以被记入 SQL 数据库中，如 MySQL、Postgres、MS SQL 等。此外，还有各种专门为 Snort 开发的日志报告辅助分析工具，如 ACID、BASE 等。



5.4 虚拟专用网络

防火墙可以对进出网络的信息和行为进行控制，将用户内部可信任网络和外部不可信任网络隔离。然而越来越多的企业在全国乃至世界各地建立分支机构开展业务，随着办公场地和分支机构的分散化，以及日渐庞大的移动办公大军的出现，分散在不同地点的机构，也需要考虑安全传输的问题。虚拟专用网(Virtual Private Network，VPN)技术应运而生，其既可以实现企业网络的全球化，又能最大限度地利用公共资源。VPN 技术的核心是在互联网上实现保密通信。

5.4.1 VPN 概述

1. 什么是 VPN

随着企业自身的不断发展和规模的扩大，越来越多的企业开始在不同的地方设立分支机构，以拓展业务，如图 5.23 所示。这些机构相互之间如何通过 Internet 传输机密信息？当员工出差在外时，如何通过 Internet 访问公司内部网络的保密数据，且保证数据在传输过程中不被窃听、篡改或丢失呢？

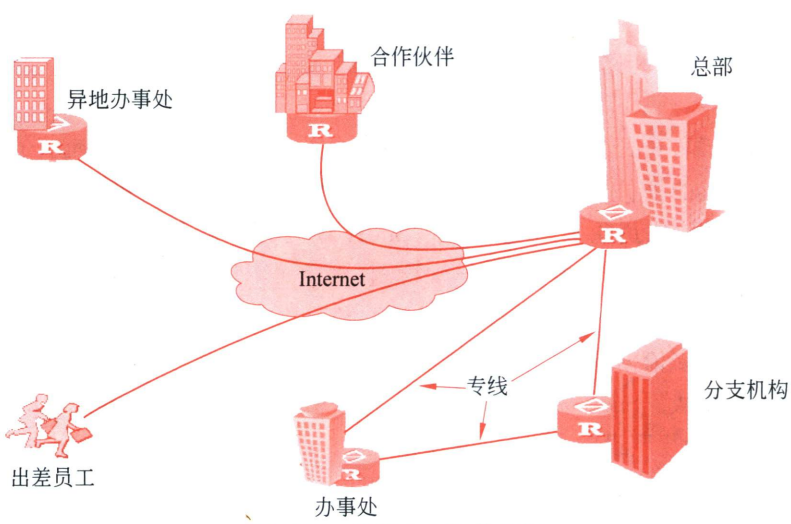


图 5.23 典型企业应用场景

一种方法是建立自己的专用网，将不同地区各个局域网之间通过模拟或数字专线连接。

但是架设专线非常昂贵，还需要拥有授权，才能开挖道路、铺设通信电缆或光缆，这对绝大多数企业来说并不现实。

另一种方法是通过隧道技术在公共网络上仿真一条点到点的专线，从而达到信息安全传输的目的，这就是 VPN。VPN 技术采用了认证、存取控制、机密性、数据完整性等措施，以保证信息在传输中不被窃听、篡改、复制。典型 VPN 的构成如图 5.24 所示。

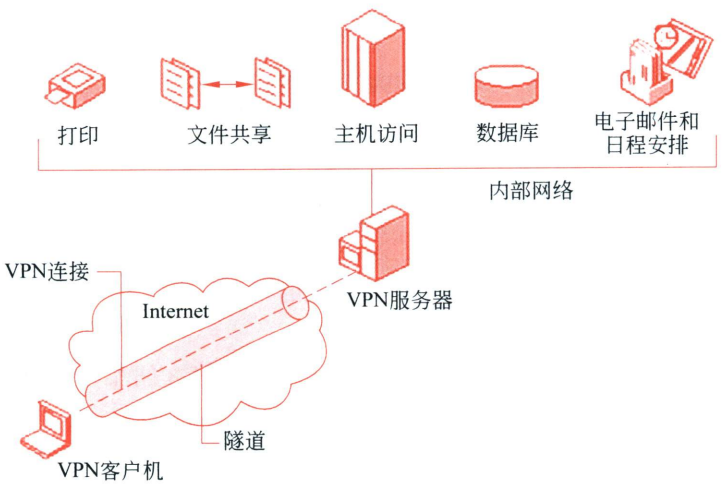


图 5.24 典型 VPN 的构成

图 5.24 中所示内容如下。

(1) VPN 客户机：可以是终端计算机，也可以是路由器。

(2) VPN 服务器：接受来自 VPN 客户机的连接请求。

(3) 隧道：VPN 客户机和服务器间的数据传输通道，在其中传输的数据必须经过封装。

(4) VPN 连接：在 VPN 连接中，数据必须经过加密。

这样，VPN 客户机通过本地因特网服务提供者(ISP)连接 Internet，并通过企业内部 VPN 服务器认证后，可以建立一条跨域 Internet 的安全连接，实现与其他地区企业内部网络之间的安全通信。

2. VPN 的功能

VPN 的主要功能是要保证信息在传输中不被窃听、篡改、复制，内容如下。

(1) 数据封装。VPN 技术提供带寻址报头的数据封装机制。

(2) 认证。VPN 可以提供 VPN 服务器对 VPN 客户机的单向认证及双向认证。

(3) 数据完整性。检查数据来源，以及传输过程中是否被篡改。

(4) 数据加密。加解密过程要求发送方和接收方共享密钥。

3. VPN 关键技术

为了满足 VPN 的功能要求，VPN 需要使用各种安全技术，其核心的关键技术包括隧道技术、密码技术和服务质量(QoS)保证技术。

(1) VPN 的隧道技术。VPN 技术可以在多个层次上实现，其核心是采用隧道技术，在公共网络中将用户的数据封装在隧道里进行传输。隧道实际上是一种数据封装技术，将一种协议封装在另一种协议中传输，实现被封装协议对封装协议的透明性，从而可以传输不同网络层协议的数据包，实现各种形式的接入，如拨号、Cable Modem、xDSL、ISDN、专线，甚至无线接入等。

互联网上最常见的隧道协议主要有第二层隧道协议和第三层隧道协议，区别主要在于用户数据在网络协议栈的第几层被封装。表5.9列出了各种常见VPN技术所属的层次。

表5.9 VPN技术的实现层次

ISO/OSI参考模型	VPN协议	TCP/IP参考模型
会话层	SOCKS v5	
传输层	SSL	传输层
网络层	IPSec，MPLS，GRE	网络层
数据链路层	PPTP，L2TP	网络接口层

（2）VPN的密码技术。VPN中传输的数据应满足机密性、完整性、可认证性和不可否认性等安全要求，涉及加密、身份认证、密钥交换、密钥管理等密码技术。在隧道技术和密码技术的基础上，便能够建立起一个具有安全性、互操作性的VPN。

4. VPN与防火墙

防火墙能够在可信任的内部网络和不可信任的外部网络之间架构一道安全屏障，只允许被授权的用户或数据通过，而非法数据会被拒之门外。而VPN则能够在不安全的互联网上建立起一个虚拟的专用通道，保证远程访问时机密数据的安全。目前许多防火墙都集成了VPN的功能，被称为VPN防火墙，如图5.25所示。VPN防火墙结合了二者的优点，能够阻止恶意企图，保证只有认证数据流才能达到VPN。

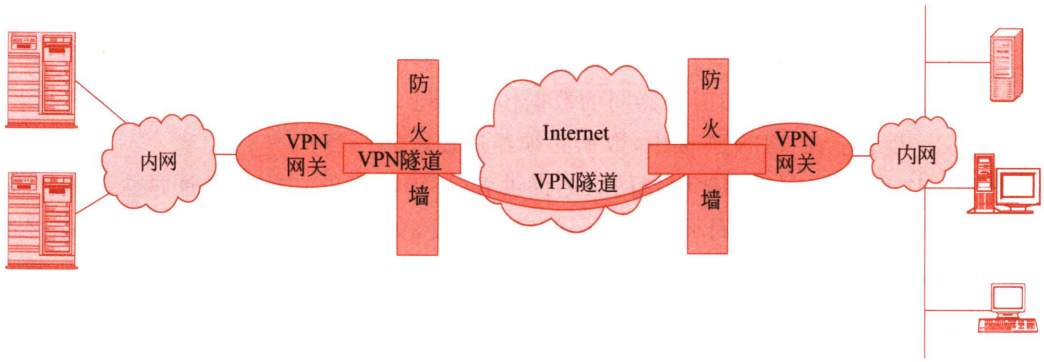


图5.25 VPN与防火墙的部署

VPN和防火墙也可以单独部署，二者的位置关系需要根据安全需求和网络结构的不同而采取不同的设计。通常防火墙作为第一道防线位于最前端，将VPN网关部署在防火墙之后的DMZ。防火墙阻止所有来历不明的数据包，通过了防火墙安全策略检查的数据包才能进入VPN隧道，VPN网关还会根据安全策略进一步过滤。

5.4.2 VPN的类型

VPN对物理网络施加逻辑网络技术，利用互联网的公共网络基础设施，使用安全通信技术把互联网上两个专用网连接起来，提供安全的网络互联服务。

根据VPN隧道封装协议及隧道协议所在网络层次的不同，VPN技术可以分为以下3类。

（1）第二层VPN技术：使用L2F/L2TP、PPTP等协议在TCP/IP协议栈网络接口层实现的VPN技术。

(2) 第三层 VPN 技术：通过 IPSec、GRE 等协议在 TCP/IP 协议栈网络层实现的 VPN 技术。

(3) 其他 VPN 技术：包括使用介于二三层之间的 MPLS 隧道协议实现的 VPN 系统、基于 SOCKS v5 VPN、基于传输层 SSL 协议实现的 VPN 等。

根据 VPN 的基本实现方式可将其分为以下 3 类。

(1) Host-to-Site VPN：连接一台主机与一个网络，又称为远程访问 VPN(remote access VPN)，可以实现分支机构、外地出差员工等的安全的远程访问。

(2) Host-to-Host VPN：连接两台主机。

(3) Site-to-Site VPN：连接两个网络，既可以用于组建企业各个分支机构之间的安全的内联网，即 Intranet VPN；也可以用于组建企业与其他相关业务单位、合作伙伴之间的外联网，即 Extranet VPN。

1. 远程访问 VPN

远程访问 VPN 可以为远程办公或在家办公的员工，建立安全的通信链路，访问企业内部网络的资源(图 5.26)。远程用户首先通过其当地的 ISP 连接到 Internet，然后再使用 VPN 客户端通过 Internet 访问企业内部局域网，通过企业 VPN 网关的身份认证后，便通过公网与企业内部的 VPN 网关之间建立了一个隧道，这个隧道实现对数据的加密传输。远程访问 VPN 的核心技术是第二层隧道技术。

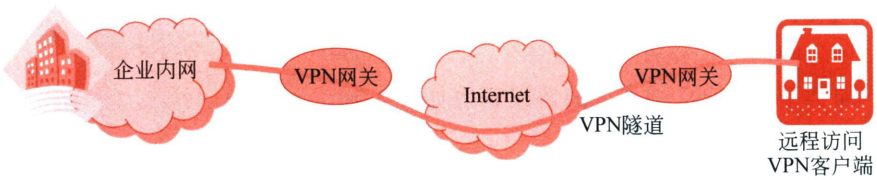


图 5.26 远程访问 VPN

2. Host-to-Host VPN

在两台主机之间建立 VPN 隧道，保证主机到主机的安全数据传输，有时也被称为 Host-to-Host VPN。在数据传输之前，两台主机之间需要进行认证与密钥交换，然后建立 VPN 隧道，保证数据的真实性、完整性和机密性，如图 5.27 所示。此类型的连接，允许员工或合伙人安全地访问一个特定的网络资源(如服务器/数据库)，但可能不允许访问网络内的其他资源。

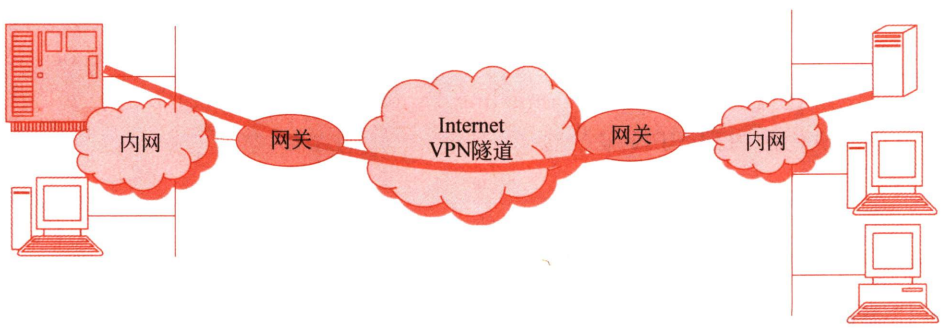


图 5.27 Host-to-Host VPN

3. Site-to-Site VPN

若要进行企业内部各分支机构之间的互联，或者企业的合作者之间互联，采用 Site-to-Site VPN 是很好的方式。这种类型的 VPN 隧道是在两个网络的 VPN 网关之间构建的，如图 5.28 所

示。两个局域网分别设置了 VPN 服务器，VPN 服务器之间形成信息传输隧道，进行用户身份认证和数据加密。

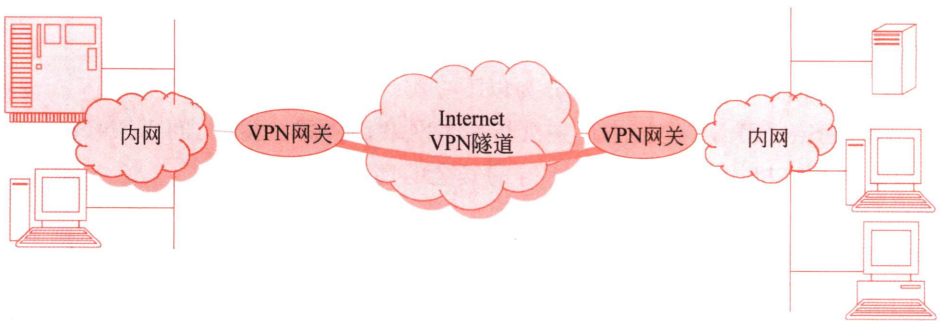


图 5.28 Site-to-Site VPN

Site-to-Site VPN 主要使用 IPSec 协议来建立加密传输数据的隧道。采用 Site-to-Site VPN 能使用灵活的拓扑结构，包括全网络连接；能够更快更容易地连接新的站点。

在企业各个分支机构之间建立的虚拟专用网，称为内联网 VPN(intranet VPN)。在企业与其相关业务单位、合作伙伴之间建立的虚拟专用网，称为外联网 VPN(extranet VPN)，可以为合作伙伴的员工指定特定的许可权，允许对方一定级别的管理人员访问一个受保护的服务器上的资源，同时不能访问其他资源。外联网 VPN 并不假定连接的不同企业之间存在双向信任关系，外联网 VPN 应采用更高强度的加密算法，支持多种认证方案，并考虑不同网络结构和操作平台之间的互操作性。

实现不同类型的 VPN 所基于的协议列表如表 5.10 所示。

表 5.10 不同类型 VPN 的实现

Site-to-Site VPN	远程访问 VPN	Site-to-Site VPN	远程访问 VPN
IPSec	PPTP	MPLS	Cisco L2F
GRE Or IP Tunneling	L2TPv3		SSL

5.4.3 VPN 协议

5.4.3.1 数据链路层 VPN 协议

数据链路层 VPN 协议包括点对点隧道协议(Point-to-Point Tunneling Protocol，PPTP)、L2F 协议和第二层隧道协议(Layer 2 Tunneling Protocol，L2TP)等，通常用于支持拨号用户远程接入企业或机构的内部 VPN 服务器。

1. 点对点隧道协议

点对点隧道协议 PPTP 由微软公司设计，是一种支持多协议虚拟专用网的网络技术，工作在 OSI 模型的第二层。PPTP 协议定义了一种点对点协议(Point-to-Point Protocol，PPP)分组封装机制，令 PPP 帧可以通过 IP 网络封装发送。PPP 协议为在点对点连接上传输多协议数据包提供了一种标准方法，支持身份验证、加密和 IP 地址动态分配服务等。PPTP 协议将 PPP 帧封装进 IP 数据报中，通过 IP 网络(如互联网或其他企业专用内联网)传输，如图 5.29 所示。

PPTP 协议通过使用扩展的通用路由封装协议(Generic Routing Encapsulation，GRE)进行封装，可以加密并/或压缩封装的 PPP 帧的负载。有关 GRE 详细文档可参见 RFC 1701 和

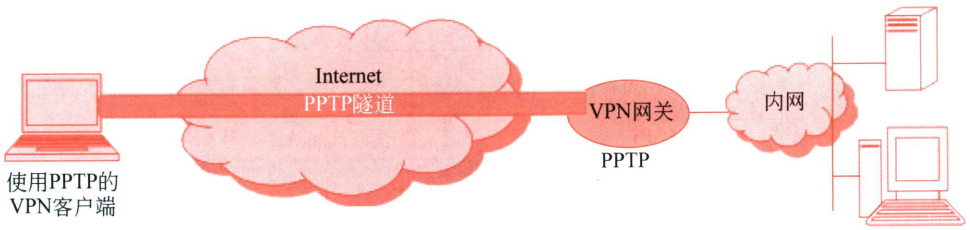


图 5.29 PPTP 隧道

RFC 1702，它规定了怎样用一种网络层协议去封装另一种网络层协议的方法。

PPTP 协议数据的隧道化采用多层封装的方法：初始 PPP 有效载荷经过加密后，添加 PPP 报头，封装形成 PPP 帧；PPP 帧再进一步添加 GRE 报头，经过第二层封装形成 GRE 报文；第三层封装是在 GRE 报头外再添加 IP 报头，IP 报头包含数据包源地址和目的地址；最后进行数据链路层封装。PPTP 通过 TCP 控制连接来创建、维护和终止一条隧道。

在 PPTP 协议实现的过程中，使用的认证机制与创建 PPP 连接时相同，主要内容如下。

(1) 询问握手认证协议(Challenge-Handshake Authentication Protocol，CHAP)。

(2) 微软询问握手认证协议(Microsoft Challenge-Handshake Authentication Protocol，MS-CHAP)。

(3) 扩展身份认证协议(Extensible Authentication Protocol，EAP)。

(4) 口令认证协议(Password Authentication Protocol，PAP)。

PPTP 协议支持 DES、triple DES、RC4、RC5 等常用的加密算法。

2. 第二层隧道协议

除微软公司提出的 PPTP 协议之外，另外一些厂家也做了许多开发工作，如思科公司开发的 L2F(Layer2 Forwarding)隧道协议。微软、思科、Ascend、3com、Bay 等厂商将 L2F 和 PPTP 融合，共同制定了第二层隧道协议 L2TP，并发布为标准 RFC 2661。

L2TP 采用用户数据报协议(UDP)封装和传送 PPP 帧，还通过 UDP 消息对隧道进行维护。PPP 帧的有效载荷可以经过加密、压缩或两者的混合处理。创建 L2TP 隧道时必须使用与 PPP 连接相同的认证机制，如 EAP、MS-CHAP、CHAP、SPAP 和 PAP 等。L2TP 主要由接入集中器(L2TP Access Concentrator，LAC)和网络服务器(L2TP Network Server，LNS)组成。LAC 支持客户端的 L2TP，用于发起呼叫、接收呼叫和建立隧道。LNS 是所有隧道的终点。

PPTP 与 L2TP 最大的优点是简单易行，对于微软操作系统用户来说很方便。它们最大的缺点是安全强度差，没有强加密和认证支持，不支持外联网 VPN。

5.4.3.2 网络层 VPN 协议

TCP/IP 协议的网络层实现了互联网上任何两台主机之间的点对点通信，因此在第三层实现 VPN 技术可以兼顾用户的透明需求和技术实现的简单性。在第三层实现的 VPN 最主要、最成功的技术就是基于 IPSec 体系的技术。

1. IPSec 协议

IPSec 是 IETF IPSec 工作组为了在 IP 层提供通信安全而制定的一套协议簇，是一个应用广泛、开放的 VPN 安全协议体系。IPSec 安全体系结构如图 5.30 所示，包含如下 4 个主要部分。

(1) 安全协议：认证首部(Authentication Header，AH)和封装安全载荷(Encapsulation Security Payload，ESP)。

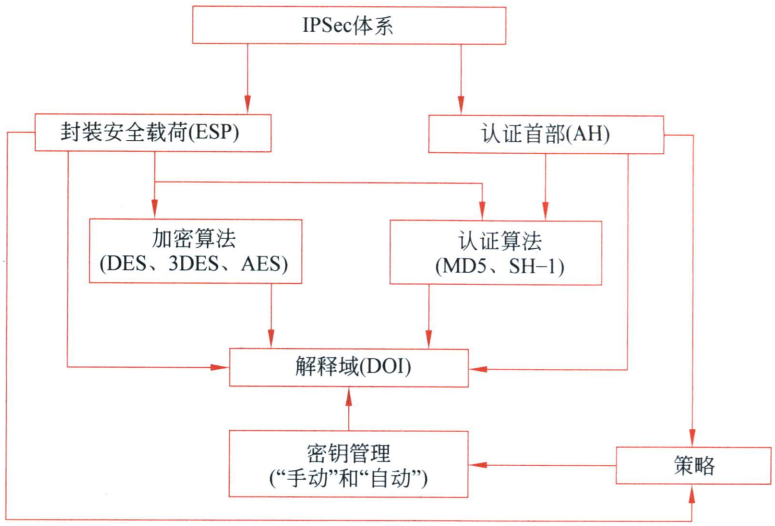


图 5.30 IPSec 安全体系结构

（2）安全关联（Security Associations，SA）。

（3）密钥管理：手动和自动互联网密钥交换（Internet Key Exchange，IKE）。

（4）密码算法：加密算法、认证算法。

IPSec 可以在两种不同操作模式下运行：隧道模式（tunnel mode）、传输模式（transport mode）。传输模式适合点到点的连接，即主机与主机之间的 VPN 可以采用此模式，其数据分组中原始 IP 包首部保留不动，在后面插入 AH 或 ESP 的首部和尾部，仅对数据净荷进行加密和认证，网络中的寻址根据原始 IP 地址进行。隧道模式适用于 VPN 安全网关之间的连接，将 IPv4 数据包整体加密封装，再在前面加入一个新的 IP 包首部，用新的 IP 地址将数据分组路由到接收端。

（1）认证首部：IP 数据包的完整性仅由 IP 首部中的校验和来保证，缺乏安全性。AH 协议使用消息认证码（如 HMAC）对 IP 进行认证，提供了更强的数据完整性保护，以及数据源认证和防重放攻击。但 AH 不提供加密功能，数据以明文传输。

AH 由 5 个固定长度域和 1 个变长的认证数据域组成，如图 5.31 所示。其中 ICV 是 AH 或 ESP 用来验证 IP 数据包完整性所用的校验数据，AH 的 IP 协议号是 51。

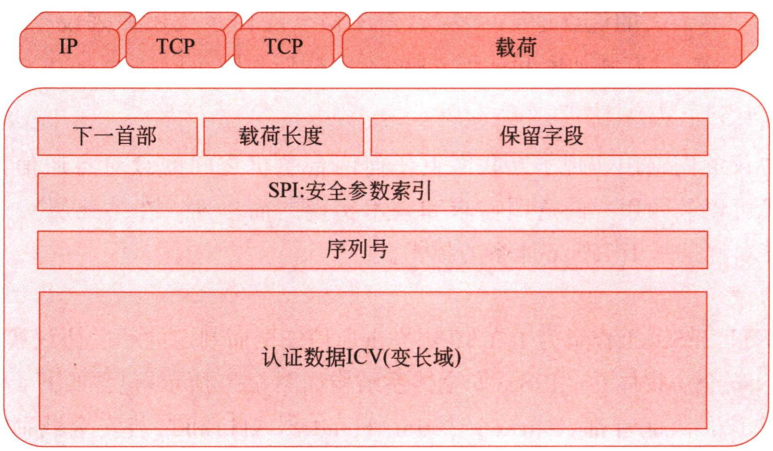


图 5.31 认证首部格式

AH 在不同操作模式下的格式如图 5.32 所示。

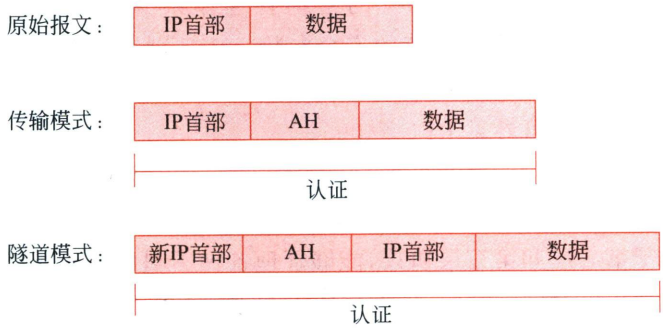


图 5.32 传输模式与隧道模式下的 AH

(2) 封装安全载荷：ESP 协议提供数据机密性、数据源认证、抗重放攻击和有限的数据流机密性等服务。ESP 采用对称密码算法来加密数据包，使用消息认证码 MAC 提供认证服务，如 HMAC-MD5、HMAC-SHA-1、Null 算法等。

ESP 数据包由 4 个固定长度的域和 3 个变长域组成，如图 5.33 所示。其中 ESP 的 IP 协议号为 50。

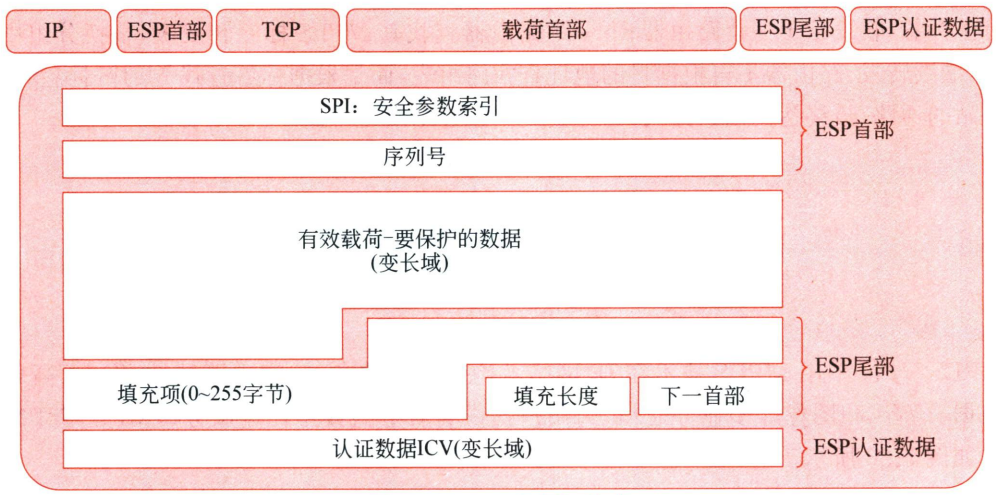


图 5.33 ESP 数据包格式

ESP 首部在不同操作模式下的格式如图 5.34 所示。

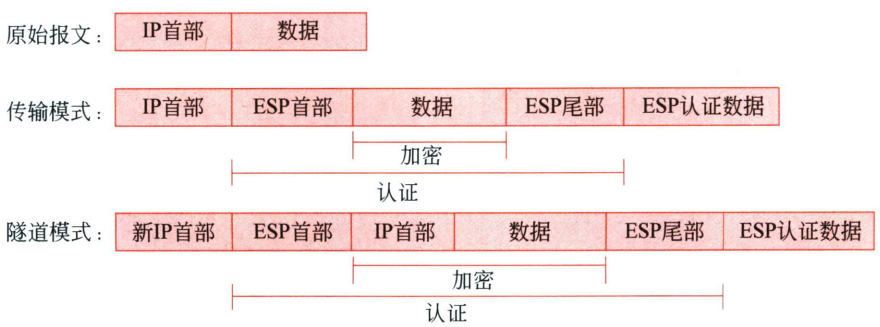


图 5.34 传输模式与隧道模式下的 ESP 首部

ESP 和 AH 可以结合使用。

（3）互联网密钥交换：AH 和 ESP 协议给出了 IPSec 数据封装格式，封装过程中要用到各种安全参数，包括算法、密钥等。IPSec 的密钥管理体系完成这些参数的协商和管理。IPSec 通过安全关联 SA 来描述数据封装的安全参数。IKE 则用于在 IPSec 通信双方之间通过协商建立起共享安全参数及验证过程的密钥，建立安全关联。IKE 协议的核心是 Diffie-Hellman 密钥交换，详细文档可参见 RFC 2409。

2. MPLS

多协议标签交换（Multi-Protocol Label Switching，MPLS）是一种用于快速数据包交换和路由的体系，它独立于第二层和第三层协议，能够管理各种不同形式的通信流。MPLS 提供了一种将 IP 地址映射为简单、具有固定长度的标签的机制，可用于不同的数据分组转发和交换技术。

在 MPLS 中，数据传输发生在标签交换路径（Label Switch Path，LSP）上。LSP 是每一个沿着从源端到终端的路径上的节点的标签序列。将数据标记交换转发数据与网络层的 IP 路由相结合，可以加快数据分组的转发速度。

MPLS 标签被插入第二层包首部和第三层 IP 分组之间，如图 5.35 所示。MPLS 标签具体包括标签、服务类信息、堆栈底、存活时间（Time-To-Live，TTL）。IP 分组在 MPLS 路由器间转发过程如下：MPLS 入口路由器根据目的地址查找路由表，找到其下一跳路由器的转发标签；将该 IP 分组打上标签，转发给下一跳路由器；下一跳路由器查找其 MPLS 标签转发表，替换分组中原有标签后，继续转发，路由器不再根据目的地址查找路由表，而是根据标签查找 MPLS 标签转发表，选择出站的通路；最终达到出口路由器，标签交换过程结束。



图 5.35　MPLS 标签

MPLS VPN 采用 MPLS 技术在 IP 网络上构建企业的专网，实现跨地域、安全、高效而可靠的数据、语音、和图像等多业务通信，为用户提供高质量的数据传输服务。MPLS VPN 网络的组成如图 5.36 所示。

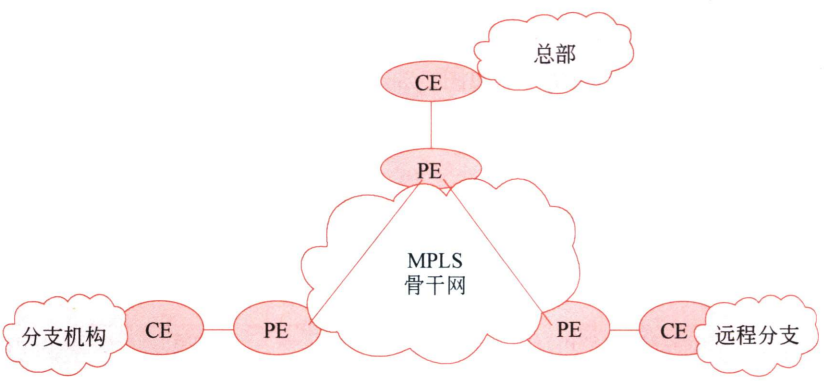


图 5.36　MPLS VPN 网络的组成

其中，用户网络边缘路由器（Custom Edge router，CE）直接与服务提供商网络相连，它“感知”不到 VPN 的存在。骨干网边缘路由器（Provider Edge router，PE）与用户的 CE 直接相

连，复制 VPN 业务接入，处理 VPN-IPv4 路由，是 MPLS 三层 VPN 的主要实现者。PE 负责快速转发数据，不与 CE 直接相连。

MPLS VPN 采用标签交换，一个标签对于一个用户数据流，便于隔离用户间的数据，最大限度地优化配置网络资源，提供高可用性和高可靠性。

5.4.3.3 传输层 VPN 协议

为了保护 Web 通信协议 HTTP/S-HTTP，Netscape 公司开发了 SSL（Secure Socket Layer）协议。SSL 协议是基于会话的加密和认证的 Internet 协议，在两个实体（客户和服务器）之间提供了一个安全的通道。SSL 工作在传输层，与使用的应用层协议无关。

SSL 协议由 SSL 记录协议和 SSL 握手协议两部分组成。SSL 记录协议对数据进行加密、解密和认证。SSL 握手协议建立连接会话状态的密码参数。SSL 协议可以实现服务器认证、客户认证（可选）、SSL 链路上数据的完整性和保密性。

SSL VPN 指采用 SSL 协议来实现远程接入的 VPN 技术。目前 SSL 协议被广泛内置于各种浏览器中，使用 SSL 协议进行认证和数据加密的 SSL VPN 可省略安装客户端。

5.4.4 VPN 配置案例

【例 5-2】 根据 H 市中小企业服务平台建设的实际需求，出差员工可以使用 OpenVPN 工具来构建虚拟专用网，实现远程办公。OpenVPN 是一个基于 OpenSSL 加密库中 SSLv3/TLSv1 协议函数库实现的应用层 VPN 软件包，可以在 Solaris、Linux、OpenBSD、FreeBSD、NetBSD、Mac OS X 与 Microsoft Windows 及 Android 和 iOS 上运行。

OpenVPN 的技术核心是虚拟网卡和 SSL 协议实现。虚拟网卡是使用网络底层编程技术实现的一个驱动软件。安装此类程序后主机上会增加一个非真实的网卡（TAP 或 TUN），如图 5.37 所示，并可以像其他网卡一样进行配置。服务程序可以在应用层打开虚拟网卡，如果应用软件（如网络浏览器）向虚拟网卡发送数据，则服务程序可以读取到该数据。如果服务程序写合适的数据到虚拟网卡，应用软件也可以接收得到。虚拟网卡在很多操作系统中都有相应的实现，这也是 OpenVPN 能够跨平台使用的一个重要原因。

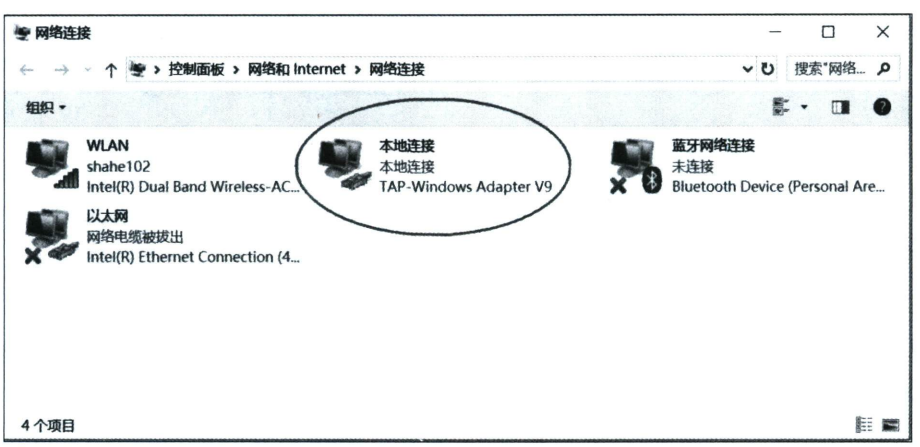


图 5.37 TAP 虚拟网卡

在 OpenVPN 中，如果用户访问一个远程的虚拟地址（属于虚拟网卡配用的地址系列，区别于真实地址），则操作系统会通过路由机制将数据包（TUN 模式）或数据帧（TAP 模式）发送

到虚拟网卡上，服务程序接收该数据并进行相应的处理后，会通过 SOCKET 从外网上发送出去。这便完成了一个单向传输的过程，反之亦然。当远程服务程序通过 SOCKET 从外网上接收到数据，并进行相应的处理后，又会发送回给虚拟网卡，则该应用软件就可以接收到。

OpenVPN 使用了 OpenSSL 库来加密数据与控制信息，提供了 HMAC 功能以提高连接的安全性，并提供以下多种身份验证方式，用以确认连接双方的身份。

（1）预共享密钥。

（2）PKI。

（3）用户名/密码组合。

预共享密钥最为简单，但它只能用于创建点对点的 VPN；基于 PKI 的第三方证书提供了最完善的功能，但是需要额外维护一个 PKI 证书系统。OpenVPN2.0 后引入了用户名/口令组合的身份验证方式，它可以省略客户端证书，但是仍需要一份服务器证书用作加密。OpenVPN 连接成功时如图 5.38 所示。

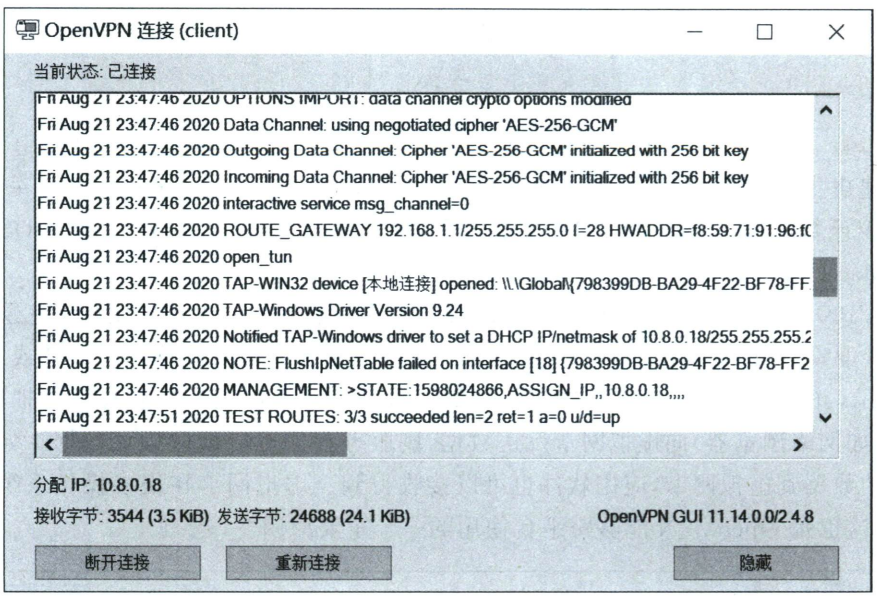


图 5.38 OpenVPN 连接成功

5.5 无线网络安全

5.5.1 无线网络安全概述

无线网络采用无线电传送数据，摆脱了长久以来对有线通信线路的依赖和束缚，彻底改变了人类进行信息交流的方式。但是由于无线网络传输媒体的开放性、无线终端的移动性、网络拓扑结构的动态性，以及无线终端计算能力和存储能力的局限性，使得无线网络比有线网络面临更多的安全威胁。

1. 无线网络划分

无线网络根据覆盖范围、传输速率和用途的不同，可以分为：无线广域网、无线城域网、无线局域网和无线个人网。

（1）无线广域网（Wireless Wide Area Network，WWAN）：主要指通过移动通信卫星进

行的数据通信，覆盖范围最大。代表技术有第三代移动通信(3th Generation，3G)、第四代移动通信(4th Generation，4G)、第五代移动通信(5th Generation，5G)等。3G的数据传输速率一般在3 Mb/s以上，而5G可以支持0.1～1 Gb/s的用户体验速率、数十Gbps的峰值速率。

(2) 无线城域网(Wireless Metropolitan Area Network，WMAN)：主要指通过移动电话或车载装置进行的移动数据通信，可以覆盖城市中大部分的地区，代表技术是IEEE 802.16系列标准。

(3) 无线局域网(Wireless Local Area Network，WLAN)：一般用于区域间的无线通信，其覆盖范围较小，代表技术是IEEE 802.11系列标准，数据传输速率为11～56 Mb/s，甚至更高。

(4) 无线个人网(Wireless Personal Area Network，WPAN)：无线传输距离一般在10m左右，典型技术是IEEE 802.15和蓝牙(bluetooth)技术，数据传输速率在10 Mb/s以上。

2. 无线网络安全的威胁

无线网络扩展了用户的自由空间，网络结构方便、灵活，可以提供无线覆盖范围内的全功能漫游服务。但是这种自由也同时带来了新的挑战，而且由于无线通信设备在存储能力、计算能力和电源供电时间等方面的局限性，使得原来在有线环境下的许多安全方案和安全技术不能直接应用，如计算量大的加解密算法等。因此，与有线网络相比，无线网络面临更加严重、更加复杂的安全威胁。

(1) 无线窃听。在无线网络中，所有网络通信内容，如移动用户的通话信息、身份信息、位置信息、数据信息，以及移动站与网络控制中心之间的信令信息等，都是通过无线信道传送的。无线信道的开放特性，使得窃听更加容易，只需要适当的无线接收设备即可，而且很难被发现。虽然有线通信网络也可能会遭到搭线窃听，但是需要能接触到被窃听的通信电缆，并进行一些专门的处理，很容易被发现。

(2) 假冒攻击。在无线网络中，移动站(包括移动用户和移动终端)要进行身份鉴别，必须通过无线信道向网络控制中心及其他移动站传送其身份信息。如果这些信息被攻击者截获，他就可以利用这个身份信息假冒该合法用户的身份入网，访问网络资源或逃避付费，这就是身份假冒攻击，主动攻击者甚至可以假冒基站欺骗移动用户。

(3) 信息篡改。在移动通信网中，当主动攻击者比移动用户更接近基站时，主动攻击者所发射的信号要比移动用户的强很多倍，使得基站忽略移动用户发射的信号，转而接收主动攻击者的信号，主动攻击者就可以篡改移动用户的信息后再传给基站。

(4) 服务抵赖。交易双方中的一方在交易完成后否认其参与了此交易。例如，在无线通信网络中，用户需要付费来获取服务提供商提供的无线网络服务，该应用存在着两种服务后抵赖的威胁：用户使用了无线网络却拒绝付费；服务提供商收了服务费却拒绝提供网络服务。

(5) 重放攻击。攻击者企图利用一个旧的、曾经有效的信息达到访问系统资源的目的。

(6) 其他安全威胁。无线通信网络与有线通信网络一样，也面临着病毒、拒绝服务攻击等威胁。

5.5.2 移动通信网络安全

移动通信网络经历了几个发展阶段：第一代移动通信系统采用模拟技术，已经基本被淘汰。第二代移动通信完成了模拟技术向数字技术的转变，但仍以语音通信为主，同时有少量的数据通信。第三代移动通信(3G)以媒体业务和宽带数据业务为主。第四代移动通信(4G)与

第三代移动通信技术相比，除了通信速率大幅提高外，还可以借助IP进行通话。第五代移动通信(5G)不仅需要考虑基本的数据和语音通信服务，还将服务于一切可互联的产业，如智慧家庭、智能建筑、智慧城市、三维立体视频、超高清晰度视频、云工作、云娱乐、增强现实、行业自动化、紧急任务应用、自动驾驶汽车等垂直行业，5G已经成为全球移动通信领域新一轮信息技术的热点课题。从1G到5G，移动通信技术经历了数次变革和演进，如表5.11所示。

表5.11 移动通信技术的演进

通信技术	典型频段	传输速率	关键技术	技术标准	提供服务
1G	800～900MHz	约2.4 kb/s	FDMA、模拟语音调制、蜂窝结构组网	NMT、AMPS等	模拟语音业务
2G	900～1800MHz、GSM900、890～900MHz	约64 kb/s GSM900上行/下行速率2.7～9.6 kb/s	CDMA、TDMA	GSM、CDMA	数字语音传输
2.5G		115 kb/s(GPRS) 384 kb/s(EDGE)		GPRS、HSCSD、EDGE	
3G	WCDMA上行/下行1940～1955MHz/2130～2145MHz	一般在几百kb/s以上 125 kb/s～2Mb/s	多址技术、Rake接收技术、Turbo编码及RS卷积联码等	CDMA2000(电信)、TD-CDMA(移动)、WCDMA(联通)	同时传送声音及数据信息
4G	TD-LTE上行/下行555～2575MHz/2300～2320MHz FDD-LTE上行/下行1755～1765MHz/1850～1860MHz	2Mb/s～1Gb/s	OFDM、SC-FDMA、MIMO	LTE、LTE-A、WiMax等	快速传输数据、音频、视频、图像
5G	3300～3600MHz与4800～5000MHz(我国)	理论10Gb/s	毫米波、大规模MIMO、NOMA、OFDMA、SC-FDMA、FBMC、全双工技术等	IMT-2020(5G)	快速传输高清视频、智能家居等

1. 2G移动通信网络

第二代移动通信网络(2G)主要采用数字的时分多址(Time Division Multiple Access，TDMA)和码分多址(Code Division Multiple Access，CDMA)技术提供数字化的语音业务及低速数据业务。代表性的2G系统是全球移动通信系统(Global System For Mobile Communication，GSM)，是欧洲电信标准协会制定的可国际漫游的泛欧数字蜂窝系统标准。

GSM是第一个引入安全机制的移动通信系统，提供的安全措施主要如下。

(1) 用户真实身份和位置信息的机密性保护。

(2) 防止未授权的非法用户接入的认证技术。

(3) 防止在空中接口非法用户窃听的加解密技术。

用户首先要在网络服务提供商处登记，服务商为该用户分配唯一的国际移动身份

(International Mobile Subscriber Identity,IMSI)和一个根密钥,存入用户识别(Subscriber Identity Module,SIM)卡交给用户。用户在发送认证请求时,通过临时识别符 TMSI 对用户身份进行保密,在动态数据库(Visitor Location Register,VLR)处存储 TMSI 和 IMSI 的对应关系。在用户开机或 VLR 数据丢失时,需要用户发送 IMSI,平时只需发送 TMSI,认证成功后更新 TMSI。

GSM 提供了认证机制和加密机制。用户入网时获得的 SIM 卡中包含 IMSI 和根密钥 K,认证中心(Authentication Center,AUC)也存有用户的根密钥 K。基于 IMSI 和二者共享的根密钥 K,对用户持有的 MS(mobile station)进行认证,并建立加密密钥 K_C,并将其传递给基站 BTS。此后从 MS 到基站之间的无线信道就可以用加密的方式传递信息,从而防止窃听。但是,GSM 的安全机制仍然存在如下一些安全缺陷。

(1) 单向认证。GSM 只有网络对用户的认证,而没有用户对网络的认证,因而会存在伪基站攻击。

(2) 根密钥无更新机制。用户 SIM 卡中存储的根密钥 K 无法进行更新,缺乏灵活性,不利于对根密钥的保护。

(3) 无完整性保护。GSM 中移动台和网络间的信令消息没有数据完整性保护,系统很难发现数据在传输过程中是否被篡改、删除或重放。

(4) 加密算法的安全性。GSM 中的加密算法是不公开的,不能得到客观的分析和评价,在实际中也受到了很多攻击。并且没有更多的算法可供选择,缺乏算法协商和加密密钥协商的过程。

(5) SIM 卡克隆。SIM 卡中存放了用户的重要秘密信息——IMSI 和根密钥 K,移动台第一次注册和漫游时,IMSI 以明文形式发送,因此易被攻击者窃取。攻击者可以利用 GSM 单向认证缺陷,向移动台发送大量挑战,分析协议消息而破解根密钥 K,从而克隆 SIM 卡。

2. 3G 移动通信网络

3G 移动通信网络寻址方式是 CDMA,在传输声音和数据的速度上有很大提升,能够在全球范围内更好地实现无线漫游,处理图像、音乐、视频流等多媒体形式,提供包括网页浏览、电话会议、电子商务等多种信息服务。2000 年 5 月,国际电信联盟确立了三个主流的 3G 通信无线接口标准,并且将这三个标准写入了 3G 技术指导性文件中,它们分别是美国倡导的 CDMA2000 标准、欧洲提出的 WCDMA 标准和中国大唐电信公司主推的 TD-SCDMA 标准。

3GPP(3th generation partnership project)是国际上关于 3G 的标准化组织,其成员是各大移动通信公司,其中 SA3 工作组专门负责 3G 移动通信网络安全标准的制定。

3G 移动通信系统的安全体系是在 GSM 安全体系基础上建立起来的,改进了 GSM 中存在的缺陷,同时针对 3G 系统的新特性,增加了更加完善的安全机制和服务。

(1) 提供了增强的用户身份保密机制。增强的用户身份保密机制(Enhanced User Identity Confidentiality,EUIC)定义了用于实现用户身份加密和解密的算法和节点(User Identity Decryption Node,UIDN)。IMSI 不再以明文传输,而是加密后传输,从而防止被窃听。

(2) 提供了双向认证。不但提供了基站对移动台的认证,也提供了移动台对基站的认证,可有效防止伪基站攻击。认证完成后双方计算出数据加密密钥 CK 和数据完整性密钥 IK,为下一步数据传输做准备。

(3) 提供了接入链路信令数据的完整性保护。当移动用户与网络之间的安全通信模式建立后,所有发送的消息都将被保护,包括接入链路数据的完整性保护和机密性保护。利用完整

性算法 f_9 输入完整性密钥 IK、序列号 COUNT、用于防止重放的随机数 FRESH、信令数据 MESSGE、消息发送方向为 DIRECTION，计算认证码 MAC，保证消息的完整性。

（4）提供了密码算法的协商机制。3G 系统中预留了 15 种加密算法和 16 种完整性算法供选择，增加了灵活性，不同的运营商之间只要支持同一种加密算法/完整性算法，就可以实现跨网通信。

虽然 3G 系统的安全体系更加趋于完善，但仍存在一些问题需要解决：3G 系统难以实现用户数字签名，随着移动电子商务的广泛应用，需要系统提供非否认安全服务，该服务一般通过数字签名机制来实现；3G 系统中密钥产生机制和认证机制仍然存在一定的安全隐患。

3. 4G 移动通信网络

第四代移动通信系统（4G）以正交频分复用技术（Orthogonal Frequency Division Multiplexing，OFDM）为核心技术，它是多载波传输的一种。4G 采用单一的全球范围的蜂窝核心网来取代 3G 中的蜂窝网络，采用全数字全 IP 技术，支持不同的接入方式，如 IEEE 802.11a、WCDMA、蓝牙等，不管是上行速度还是下行速度都有了显著提高。4G 移动通信系统的核心网是一个基于全 IP 的网络，即基于 IP 的承载机制、基于 IP 的网络维护管理、基于 IP 的网络资源控制、基于 IP 的应用服务。

同 3G 移动网络相比，4G 系统具有根本性的优点：可以实现不同的网络间的无缝互联。核心网独立于各种具体的无线接入方案，能提供端到端的 IP 业务，能同已有的核心网和公共交换电话网络（Public Switched Telephone Network，PSTN）兼容。核心网具有开放的结构，能允许各种空中接口接入核心网；同时核心网能把业务、控制、传输等分开。采用 IP 后，所采用的无线接入方式和协议与核心网络协议、链路层是分离独立的。IP 与多种无线接入协议相兼容，因此在设计核心网络时具有很大的灵活性，不需要考虑无线接入究竟采用何种方式和协议。

4G 采用长期演进（Long Term Evolution，LTE）和高级长期演进（Long Term Evolution-Advanced，LTE-A）安全架构，但是目前的 LTE/LTE-A 仍然存在如下一些弱点。

（1）LTE 基于全 IP 的平坦结构导致易受诸如注入、修改、窃听等攻击。

（2）全 IP 网络为恶意攻击者提供了更直接的侵入基站的路径。由于移动管理组件（Mobility Management Entity，MME）管理着大量演进型基站（evolved Node B，eNBs），因此与管理着少量无线网络控制器（Radio Network Controller，RNCs）的 UTMS 3G 网络相比，LTE 网络基站更易受攻击。一旦攻击者侵入某个基站，便可利用 LTE 的全 IP 性质危害整个网络。

（3）LTE 系统结构在切换认证过程中可能会产生新的问题。

（4）LTE 采取的 EPS AKA 方案缺乏隐私保护机制，不能抵抗 DoS 攻击。

（5）LTE 切换过程缺乏后向安全，易受去同步攻击和重放攻击。

4. 5G 移动通信网络

随着全球新一轮科技革命和产业变革加速发展，5G 作为新一代信息通信技术演进升级的重要方向，是实现万物互联的关键信息基础设施、经济社会数字化转型的重要驱动力量。世界主要国家都把 5G 作为经济发展、技术创新的重点，将 5G 作为谋求竞争新优势的战略方向。根据全球移动供应商协会（Globalmobile Suppliers Association，GSA）统计，截至 2019 年底，全球 119 个国家或地区的 348 家电信运营商开展了 5G 投资，其中，61 家电信运营商已经推出 5G 商用服务。

为提升其业务支撑能力，5G 在无线传输技术和网络技术方面将有新的突破。在无线传输

技术方面，将引入能进一步挖掘频谱效率提升潜力的技术，如先进的多址接入技术、大规模多天线技术(massive-MIMO)、先进的编码调制技术、新的波形设计技术等；在无线网络方面，将采用更灵活、更智能的网络架构和组网技术，如采用控制与转发分离的软件定义无线网络(Software Defined Networking，SDN)的架构、统一的自组织网络(Self-Organizing Network，SON)、异构超密集部署、网络功能虚拟化(Network Functions Virtualization，NFV)等。此外，还包括移动边缘计算(Mobile Edge Computing，MEC)、无线 MESH、按需组网等关键技术。

2015 年，ITU 在 ITU-R M.2083-0 建议书中确定了 5G 的愿景，并在建议书中明确了 5G 支持的 3 大应用场景，内容如下。

(1) 增强型移动宽带(enhanced Mobile Broad Band，eMBB)。此类场景主要处理以人为中心的潜在需求，要求能提供 100Mbps 的用户体验速率，如 3D/超高清视频、虚拟现实(VR)/增强现实(AR)等。

(2) 大规模机器类型通信(massive Machine Type Communications，mMTC)。此类场景主要处理大规模智能设备的通信问题，要求能够支撑百万级低功耗物联网设备终端，如各种穿戴设备的连接服务。

(3) 超可靠和低延迟通信(Ultra-Reliable and Low Latency Communications，URLLC)。此类场景主要处理对可靠性要求极高、时延极其敏感的特殊应用场景，要求在保证远低于 1ms 时延的同时提供超高的传输可靠性，如辅助驾驶、自动驾驶、工业自动化和远程机械控制等。

5G 移动通信标志性的关键技术主要体现在超高效能的无线传输技术和高密度无线网络(high density wireless network)技术，其中基于大规模 MIMO 的无线传输技术将有可能使频谱效率和功率效率在 4G 的基础上再提升一个量级，该项技术走向实用化的主要瓶颈问题是高维度信道建模与估计，以及复杂度控制。

体系结构变革将是新一代无线移动通信系统发展的主要方向。现有的扁平化 SAE/LTE(System Architecture Evolution/Long Term Evolution)体系结构促进了移动通信系统与互联网的高度融合，高密度、智能化、可编程则代表了未来移动通信演进的进一步发展趋势，而内容分发网络(Content Delivery Network，CDN)向核心网络的边缘部署，可有效减少网络访问路由的负荷，并显著改善移动互联网用户的业务体验。

(1) 超密集组网：未来网络将进一步使现有的小区结构微型化、分布化，并通过小区间的相互协作，化干扰信号为有用信号，最大限度地提高整个网络的系统容量。

(2) 智能化：未来网络将在已有 SON 技术的基础上，具备更为广泛的感知能力和更为强大的自优化能力，在异构环境下为用户提供最佳的服务体验。

(3) 可编程：未来网络将具备软件定义网络(SDN)能力；基站与路由交换等基础设施具备可编程与灵活扩展能力，以统一融合的平台适应复杂的、不同规模的应用场景。

(4) 内容分发边缘化部署：移动终端访问的内容虽然呈海量化趋势，但大部分集中在一些大型门户网站，在未来 5G 网络中采用 CDN 技术将提高网络资源利用率。

5G 网络将融合多类现有或未来的无线接入传输技术和功能网络，包括传统蜂窝网络、大规模多天线网络、认知无线网络(CR)、无线局域网(WiFi)、无线传感器网络(WSN)、小型基站、可见光通信(VLC)和设备直连通信(D2D)等，并通过统一的核心网络进行管控，以提供超高速率和超低时延的用户体验和多场景的一致无缝服务，一个可能的 5G 系统架构如图 5.39 所示。

5G 提供的丰富场景服务将实现人、物和网络的高度融合，全新的万物互联时代即将到来。

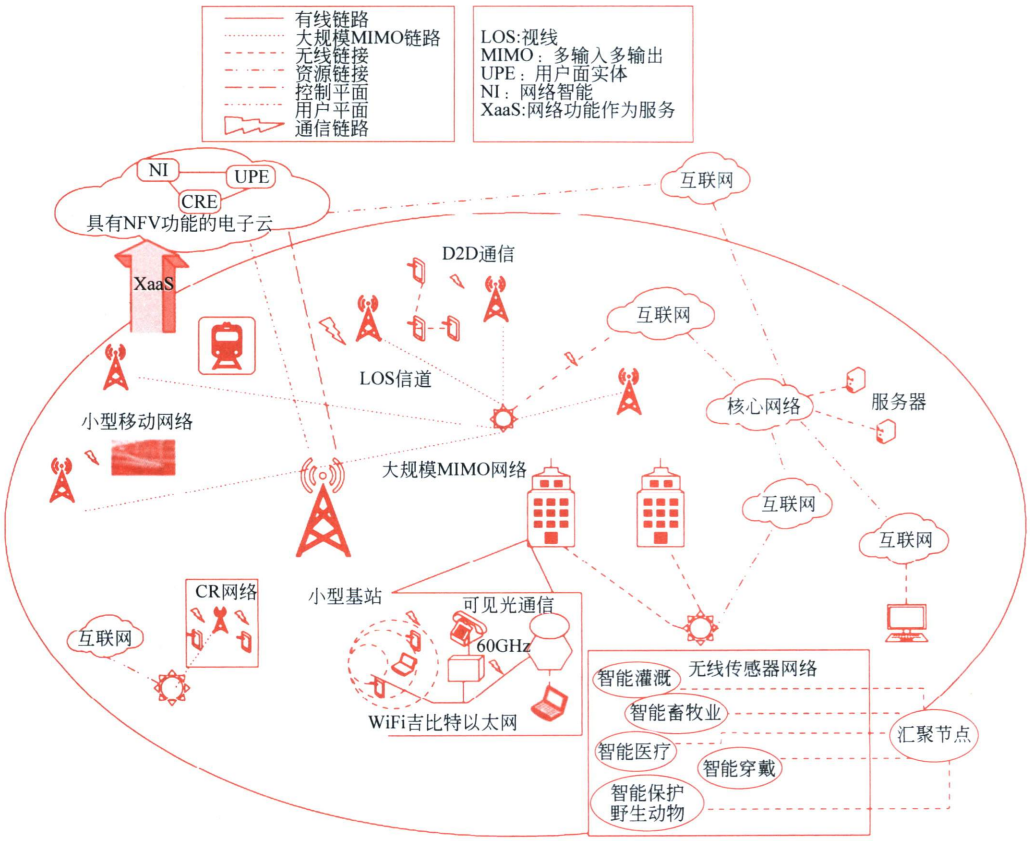


图 5.39 5G 网络架构

但是，现实空间与网络空间的真正连接也将带来空前复杂的安全问题。其安全需求如下。

（1）延续 4G 的安全需求。作为 4G 系统的延续，5G 首先应该至少提供与 4G 同等的安全性，这些基本的安全需求主要包括：用户和网络的双向认证、基于 USIM 卡的密钥管理、信令消息的机密性和完整性保护、用户数据的机密性保护、安全的可视性和可配置性。此外，5G 还应考虑：防 IMSI 窃取的保护、用户数据的完整性保护、服务请求的不可否认性，以及从以 USIM 卡为基础的单一身份管理方式到灵活多样的身份管理方式的过渡，并对所涉及的身份凭证的产生、发放、撤销等整个生命周期内的管理。

（2）新技术驱动的安全需求。5G 需要全新的网络架构来进行网络资源的管理和控制，如网络功能虚拟化（NFV）和 SDN 技术实现网络自动化管理、网络资源虚拟化和网络控制集中化、云计算技术实现按需的网络控制和定制化的客户服务。因此，传统的依赖物理设备隔离来提供安全保障的方式不再适用，5G 必须考虑虚拟化技术带来的基础设施安全问题。例如，NFV 中虚拟化管理层的安全问题、虚拟 SDN 控制网元和转发节点的安全隔离问题等。

（3）垂直行业服务驱动的安全需求。在 5G 环境下，不同的垂直行业对安全的需求差异极大，安全即服务（Security-as-a-Service，SECaaS）的架构必然出现，以提供更灵活的安全配置，并保障一定的安全隔离，防止服务资源在不同服务之间被非授权访问。此外，还需要对数据的可访问性进行严格控制，制定周期的隐私保护策略，建立自动化的安全监控和安全策略配置机制，及时检测并防范未知的安全威胁，以适应新技术驱动和垂直服务产业下灵活多变和个性化的服务安全，实现不同群体不同应用场景下的多级别安全保障。

5.5.3 无线局域网安全

无线局域网(WLAN)是利用无线通信技术将计算机设备互联起来,构成可以互相通信和实现资源共享的网络体系。与有线网络相比,WLAN 具有一定的移动性、灵活性高、建网迅速、管理方便、网络造价低、扩展能力强等特点,因此比较适用于布线困难,或者需要在移动中联网和网间漫游的场合,在石油工业、医护管理、库存控制、会议展览、移动办公等多个领域具有广泛的应用。

随着 WLAN 的广泛应用,人们对其安全性的需求也越来越高。目前,针对 WLAN 安全性的标准如下。

(1) IEEE 802.11 安全标准:使用有线等价保密(Wired Equivalent Privacy,WEP)协议来实现认证与数据加密,其理想目标是为 WLAN 提供与有线网络相同级别的安全保护。但是由于这些安全机制存在设计缺陷,并不能提供足够的安全保护。

(2) IEEE 802.11i 安全标准:针对 WEP 机制的安全缺陷,IEEE 802.11i 工作组提出了一系列的改进措施,于 2004 年颁布。IEEE 802.11i 标准采用 AES 算法代替 WEP 机制中的 RC4 算法,使用 IEEE 802.1x 协议进行认证。

(3) WPA(wifi protected access):WiFi 联盟在 IEEE 802.11i 标准出台之前推出的自己的一套标准。WPA 标准的核心是 IEEE 802.1x 认证协议和临时密钥完整性协议 TKII。

(4) 中国无线局域网安全标准:我国于 2003 年颁布的无线局域网国家标准 GB 15629.11—2003,引入新的安全机制——无线局域网鉴别和保密基础结构(WLAN Authentication and Privacy Infrastructure,WAPI)。

1. 无线局域网架构

WLAN 由无线网卡、无线接入点(Access Point,AP)、计算机和相关设备组成。IEEE 802.11 标准支持两种拓扑结构(图 5.40):独立基本服务集(Independent Basic Service Set,IBSS)和扩展服务集(Extend Service Set,ESS),均使用基本服务集(Basic Service Set,BSS)作为基本组件。BSS 提供一个覆盖区域,使其中的站点保持充分的连接。

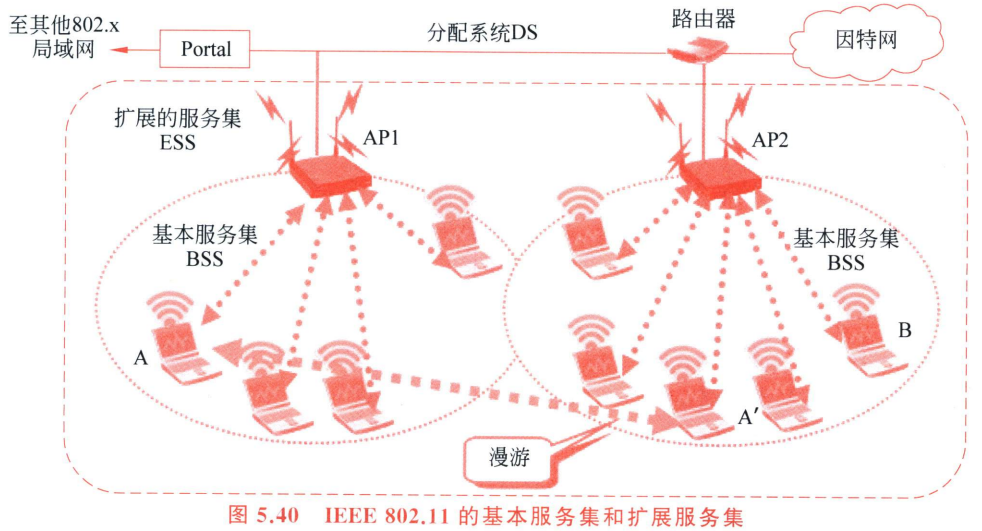


图 5.40 IEEE 802.11 的基本服务集和扩展服务集

IBSS 是一个独立的 BSS,没有中枢链路基础结构,又被称为自组织无线局域网(ad hoc

WLAN）。ESS是由多个AP、多个BSS通过分配系统DS联结形成的结构化网络。

2. IEEE 802.11 安全机制

在IEEE 802.11中考虑了无线局域网的接入安全问题，并提供了一些身份认证、数据加密与完整性验证等安全机制。

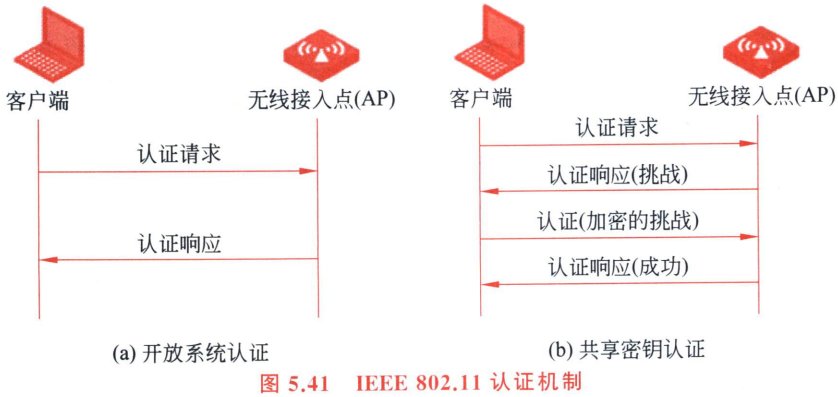
（1）加密机制。WEP是IEEE 802.11中保障数据传输安全的核心。WEP采用的是RC4加密算法，同时引入初始向量 ***IV*** 和完整性校验值ICV，以防止数据的篡改和传输错误。每一个客户端及AP中存储一个相同的40位长度的密钥，作为共享密钥来完成加解密。然而由于WEP中RC4算法在使用过程中存在弱密钥、***IV*** 重用等问题，易遭受密码破解攻击，并且已经存在许多自动化的破解工具。

WEP使用循环冗余校验码（CRC-32）来验证传输数据的正确性，然而CRC校验码并不能抵御数据篡改。

（2）认证机制。IEEE 802.11定义了两种认证方式：开放系统认证（open system authentication）和共享密钥认证（shared key authentication）。

开放系统认证是IEEE 802.11的默认认证机制，整个认证过程以明文方式进行。整个过程只有两步：认证请求和响应，如图5.41（a）所示。通过这种认证方式，AP并不能认证工作站（Station，STA）的合法身份，因此相当于是空认证。

共享密钥认证是可选的，认证过程如图5.41（b）所示。STA提出认证请求；AP收到后随即产生一个挑战字符串发送给STA；STA利用共享密钥K通过WEP算法对挑战字符串进行加密，产生的密文作为对挑战的响应发送给AP；AP利用共享密钥K解密并验证挑战字符串是否一致，若一致则认证成功，否则认证失败。



(a) 开放系统认证　　(b) 共享密钥认证

图 5.41　IEEE 802.11 认证机制

IEEE 802.11中的共享密钥认证机制是单向的，使得伪装AP的攻击很容易实现，并且存在会话劫持和中间人攻击的可能性。

3. IEEE 802.11i 安全机制

为了进一步加强无线网络的安全性，IEEE 802.11i工作组开发了新的安全标准IEEE 802.11i，将安全解决方案升级为WPA2，在身份认证、加密机制、数据包检查方面增强了安全性，并提升了无线网络的管理能力。

（1）加密机制。IEEE 802.11i定义了TKIP（temporal key integrity protocol）和CCMP（counter-mode/ CBC-MAC protocol）两种加密机制。其中TKIP是一种过渡算法，仍采用RC4作为核心加密算法，但将初始向量 ***IV*** 扩展到48位、增加消除弱密钥机制、利用消息完整性代码MIC防止数据被篡改，在一定程度上提高了破解难度。CCMP机制基于高级加密标准

AES加密算法和CCM认证方式，采用计数器(CTR)模式和完整性校验(CBC-MAC)模式进行数据保护，是IEEE 802.11i最强的安全算法，能够更好地解决WLAN安全问题。

(2) 认证机制。IEEE提出IEEE 802.1x协议来解决IEEE 802.11认证机制中存在的安全缺陷。IEEE 802.1x提供了可靠的用户认证和密钥分发的框架，核心是可扩展认证协议(Extensible Authentication Protocol，EAP)。EAP是一种封装协议，在具体应用中可以根据不同的认证方法进行扩展，包括EAP-TLS、PEAP、EAP-SIM等，最常见的是EAP-TLS，已经成为国际标准RFC 2716。

EAP-TLS基于TLS实现，要求双方都有公钥证书，服务器与客户的双向认证是通过公钥证书，进行TLS建立会话密钥。由于该协议不对用户身份进行保护，可以被攻击者窃听。该协议在STA和认证服务器间实现双向身份认证，AP被错误地认为是可信任的实体，缺乏对AP的认证，有遭受假冒AP攻击的可能。

5.6 本章小结

本章首先对网络安全威胁和几种主要的网络安全控制技术进行了详细描述，包括数据加密、虚拟专用网、PKI与证书、身份鉴别和访问控制；其次，对防火墙、入侵检测系统和虚拟专有网进行了详细分析，包括防火墙的体系结构、防火墙的配置实例、IDS的功能及类型、虚拟专有网的类型和协议；最后，介绍了无线网络安全，包括移动通信网络安全和无线局域网安全。

思考题



1. 你的个人计算机以前或现在是“僵尸”吗？后果如何？如果你是一位系统管理员，正在查找你管理的网络中的“僵尸”，你会查找些什么？

2. 什么是“中间人”攻击？请举出一个实际生活中存在这种攻击的例子(不要举来自计算机网络方面的例子)。假设有一种方法能够让发送者和接收者排除中间人攻击：①请举出一种不使用加密的方法；②请举出一种使用了加密但也能保证中间人不能在密钥交换过程中实施这种攻击的方法。

3. 你是否应用过VPN？请举例。

4. 一些人认为对PKI进行证书授权应该由政府来做，而其他人认为证书授权应该由一些私有实体——银行、企业或学校来做。这两种方案各有什么优缺点？

5. 你的个人计算机上是否装有防火墙？如果有，进行了哪些设置？请举出几种流行的个人防火墙。

6. 你的个人计算机上是否装有入侵检测系统？是什么？请举出几种流行的入侵检测系统。

7. 无线网络面临哪些安全威胁？2G、3G、4G、5G的安全性如何？IEEE 802.11和IEEE 802.11i提供了哪些安全机制？